

深入浅出
计算机网络

微
视频
版

高 军 陈 君 唐 秀 明 张 剑 / 编 著

清华大学出版社

B站口碑爆棚的“计算机网络微课堂”升级版

深入浅出 计算机网络

高 军 陈 君 唐 秀 明 张 剑 / 编 著



附赠：100+个视频 | 教学大纲 | PPT课件

思维导图 | 配套习题

清华大学出版社

第7章 网络安全

7.1 **网络安全概述**

7.2 **密码学与保密性**

7.3 **报文完整性与鉴别**

7.4 **实体鉴别**

7.5 **密钥分发**

7.6 **访问控制**

7.7 **网络体系结构各层采取的安全措施**

7.8 **防火墙访问控制与入侵检测系统**

7.9 **常见的网络攻击及其防范**

7.1 网络安全概述

01

网络安全威胁

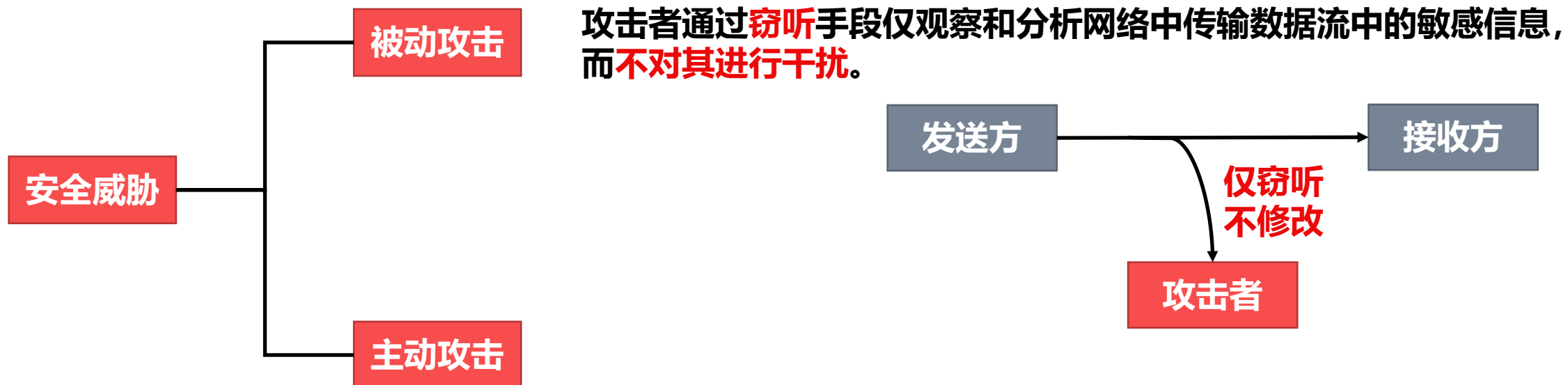
02

网络安全服务

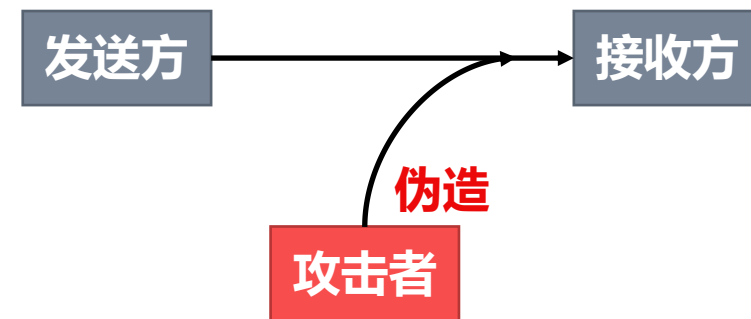
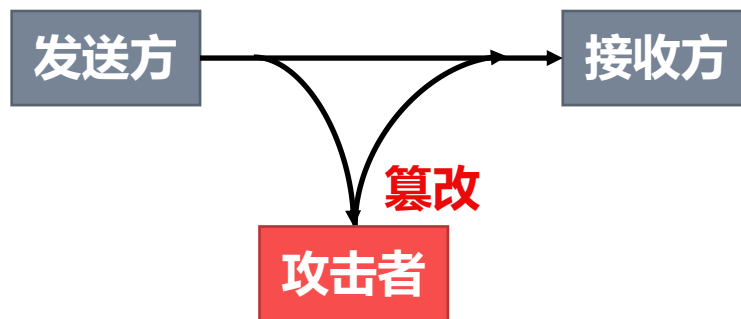
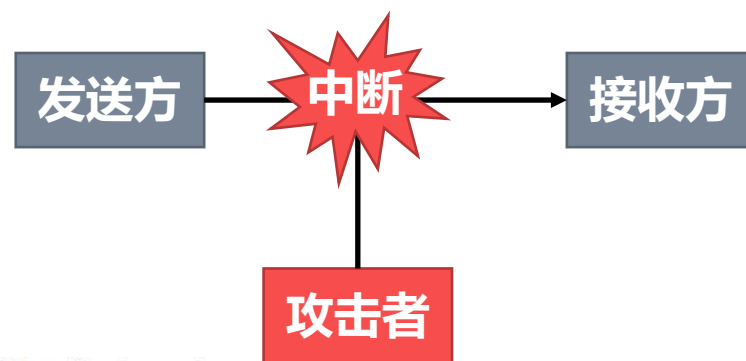
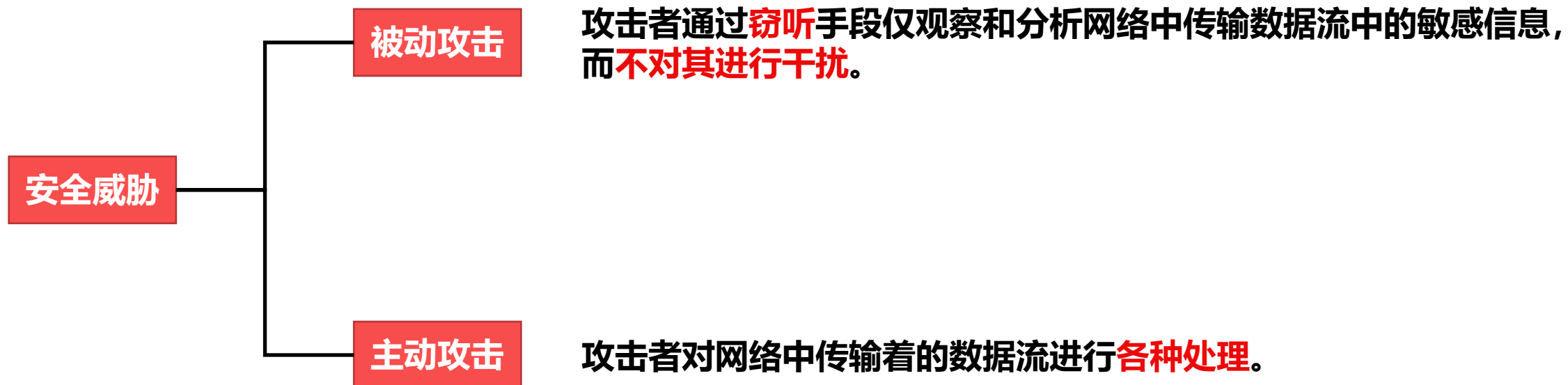




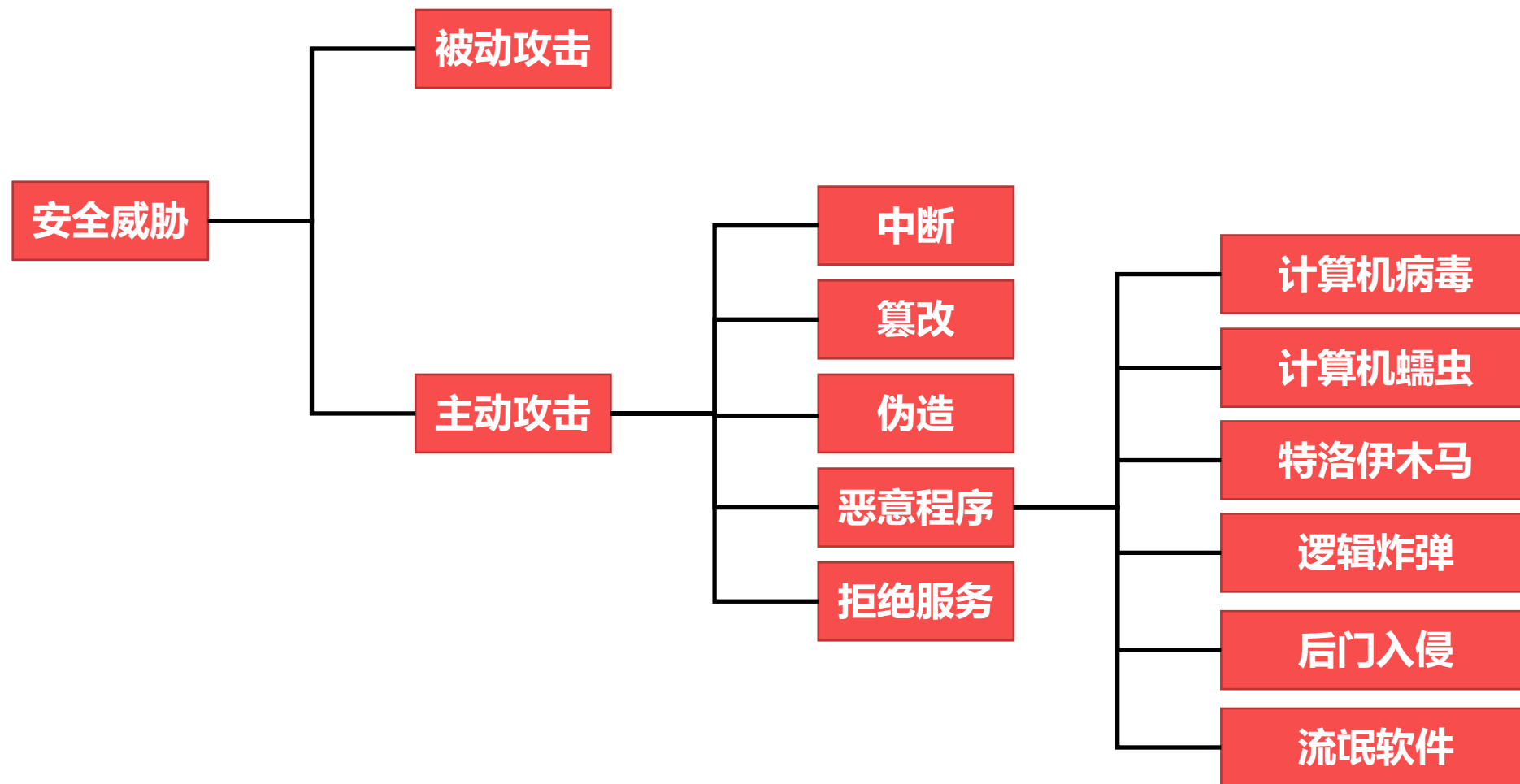
01 安全威胁



01 安全威胁



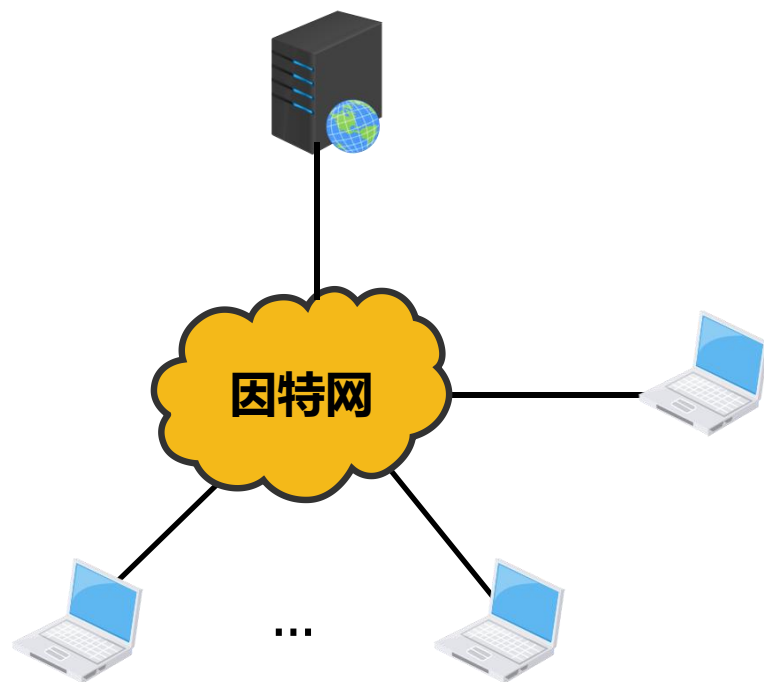
01 安全威胁



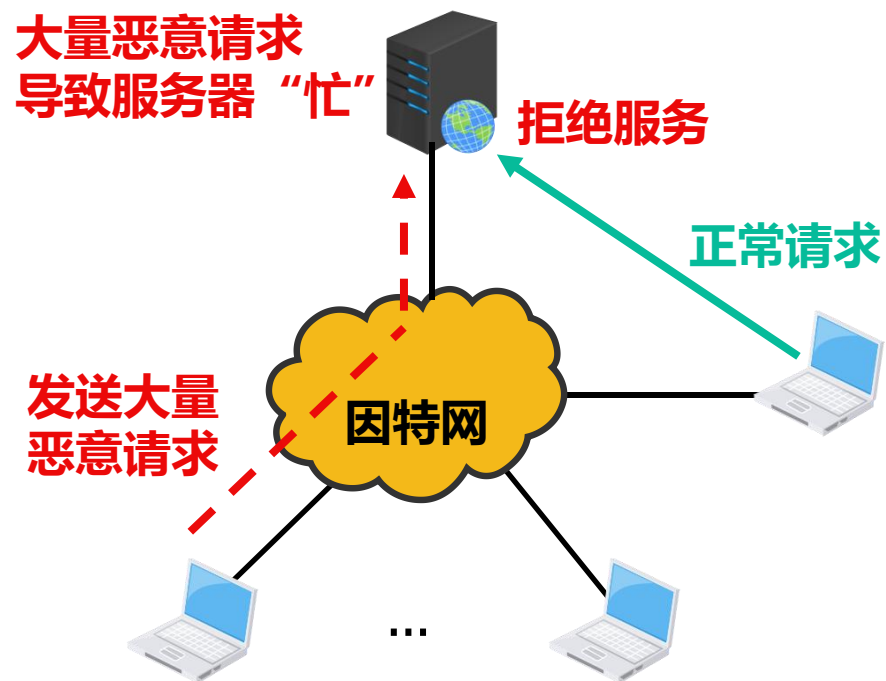
01 安全威胁

拒绝服务

(Denial of Service, DoS)



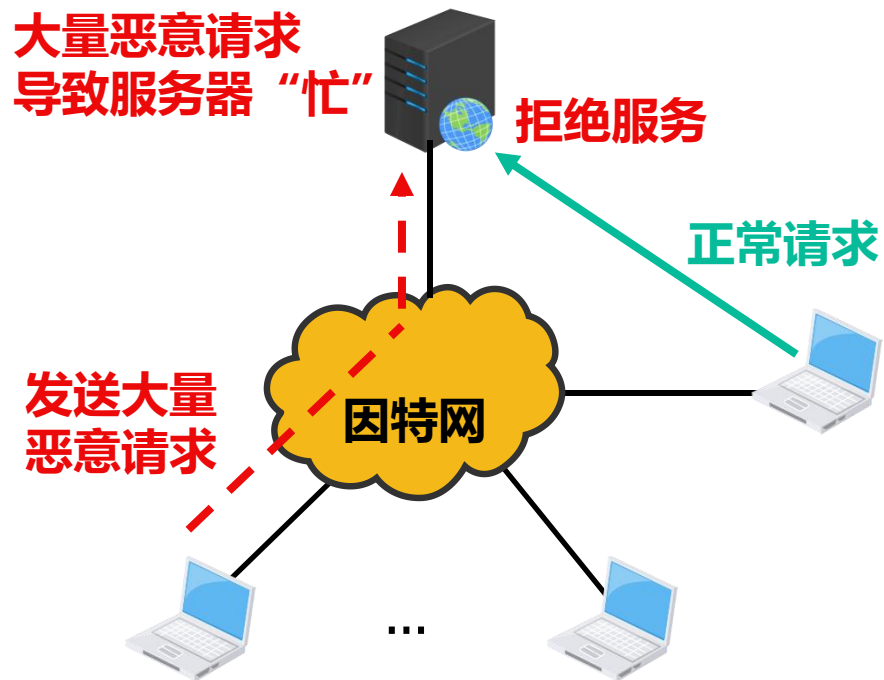
01 安全威胁

拒绝服务 (Denial of Service, DoS)

01 安全威胁

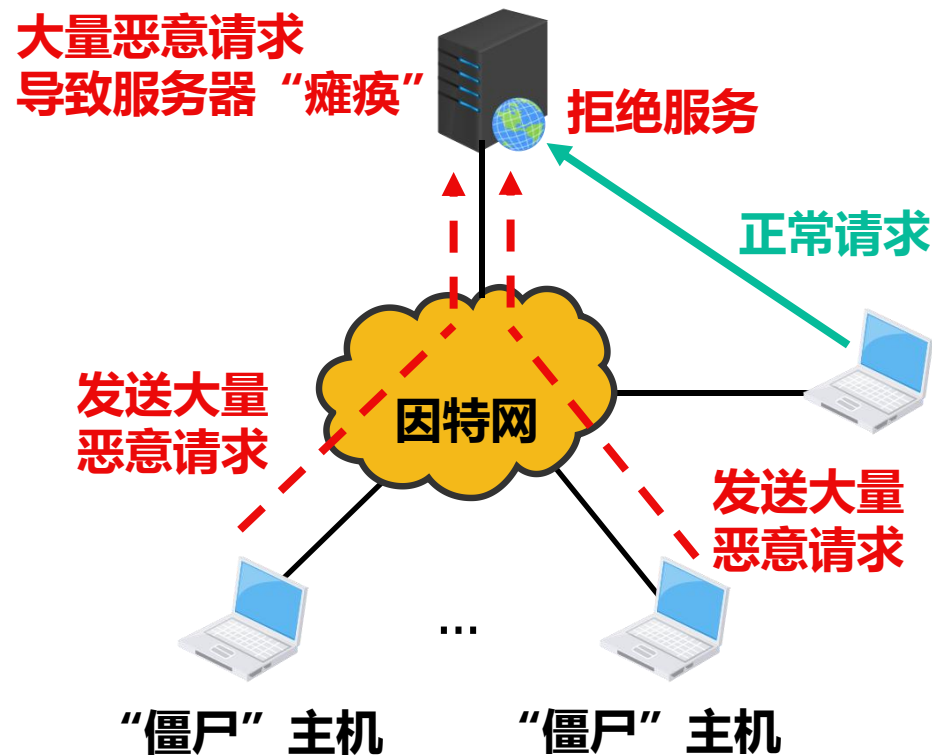
拒绝服务

(Denial of Service, DoS)



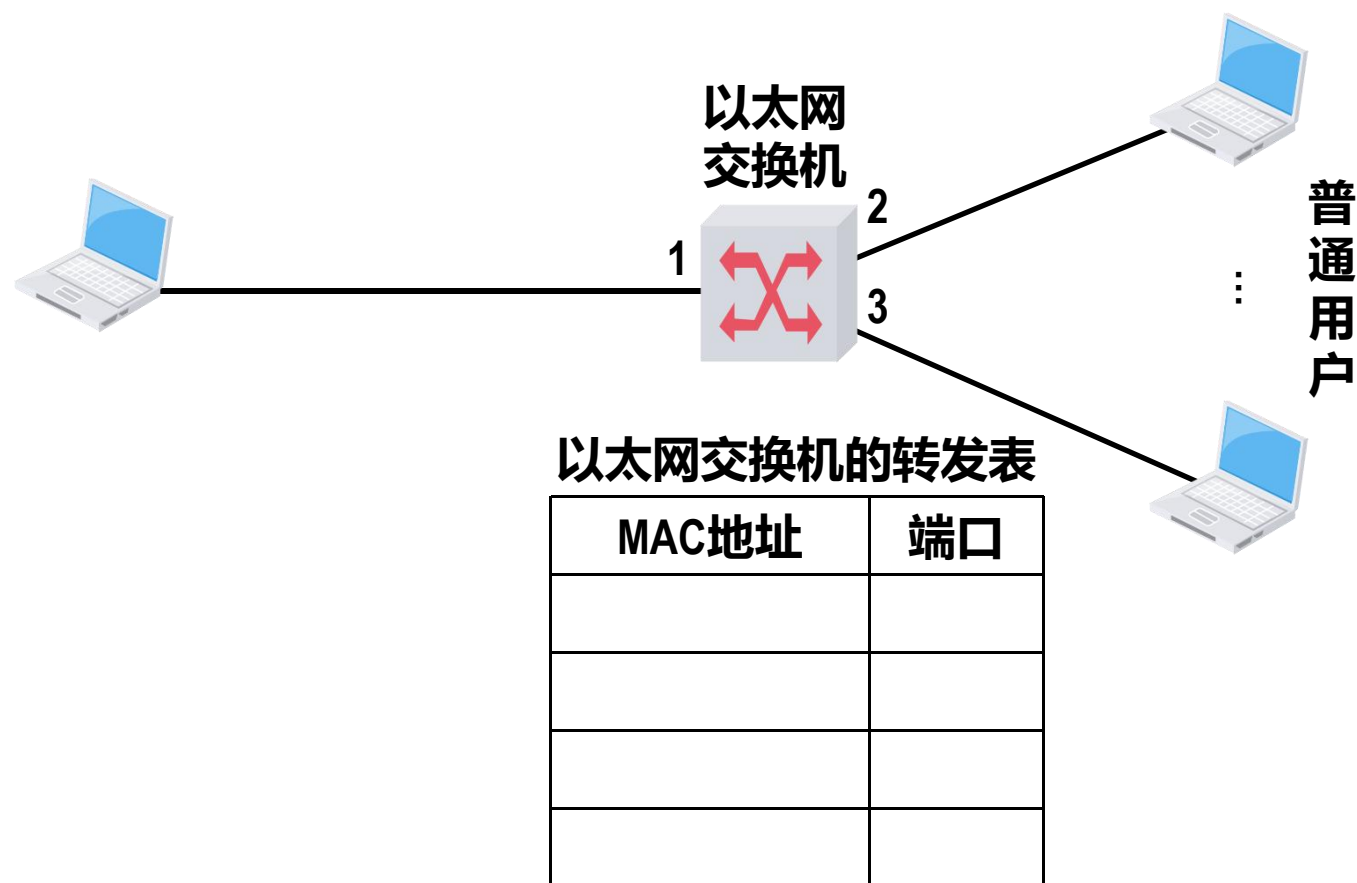
分布式拒绝服务

(Distributed Denial of Service, DDoS)



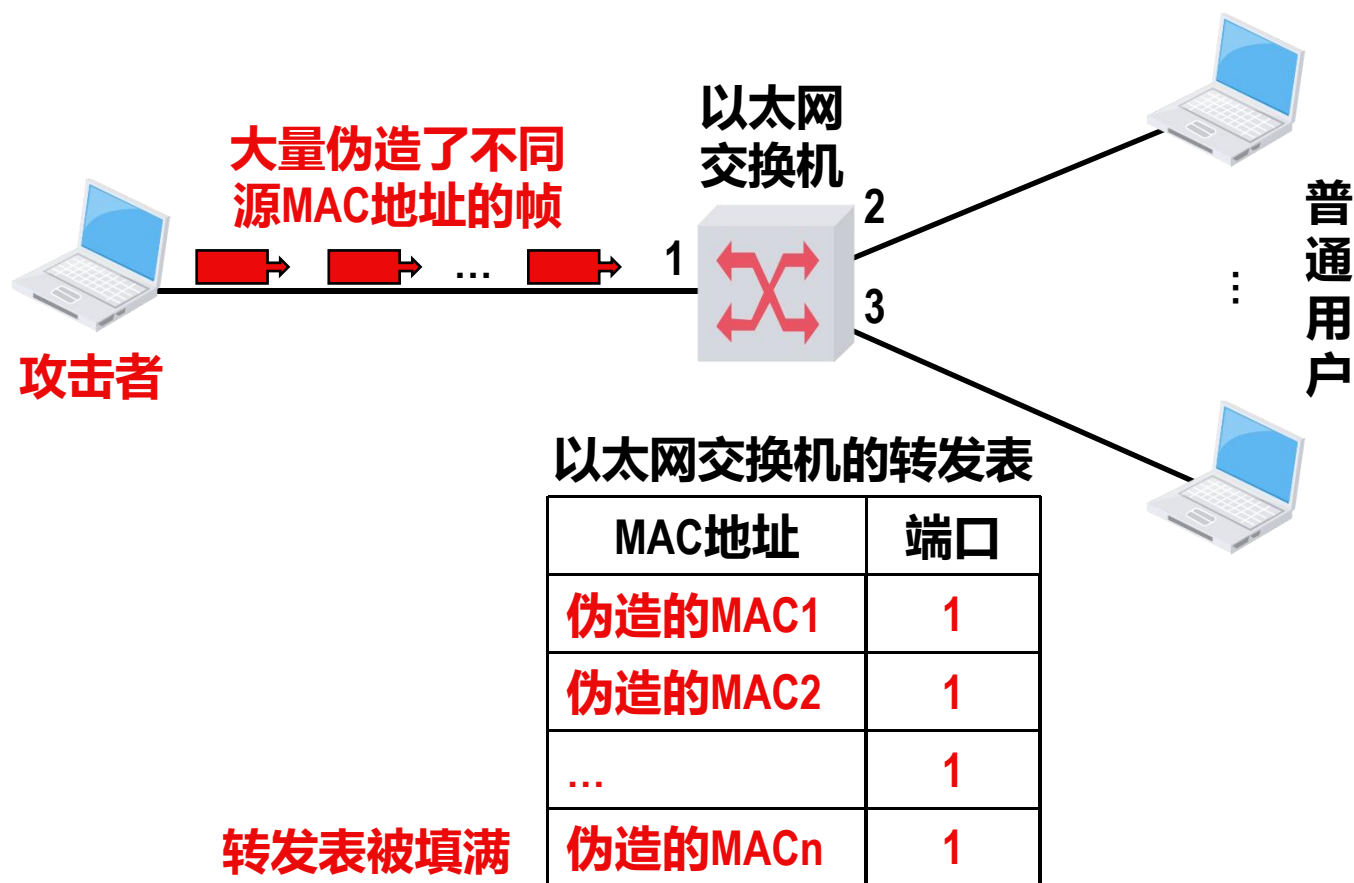
01 安全威胁

交换机中毒

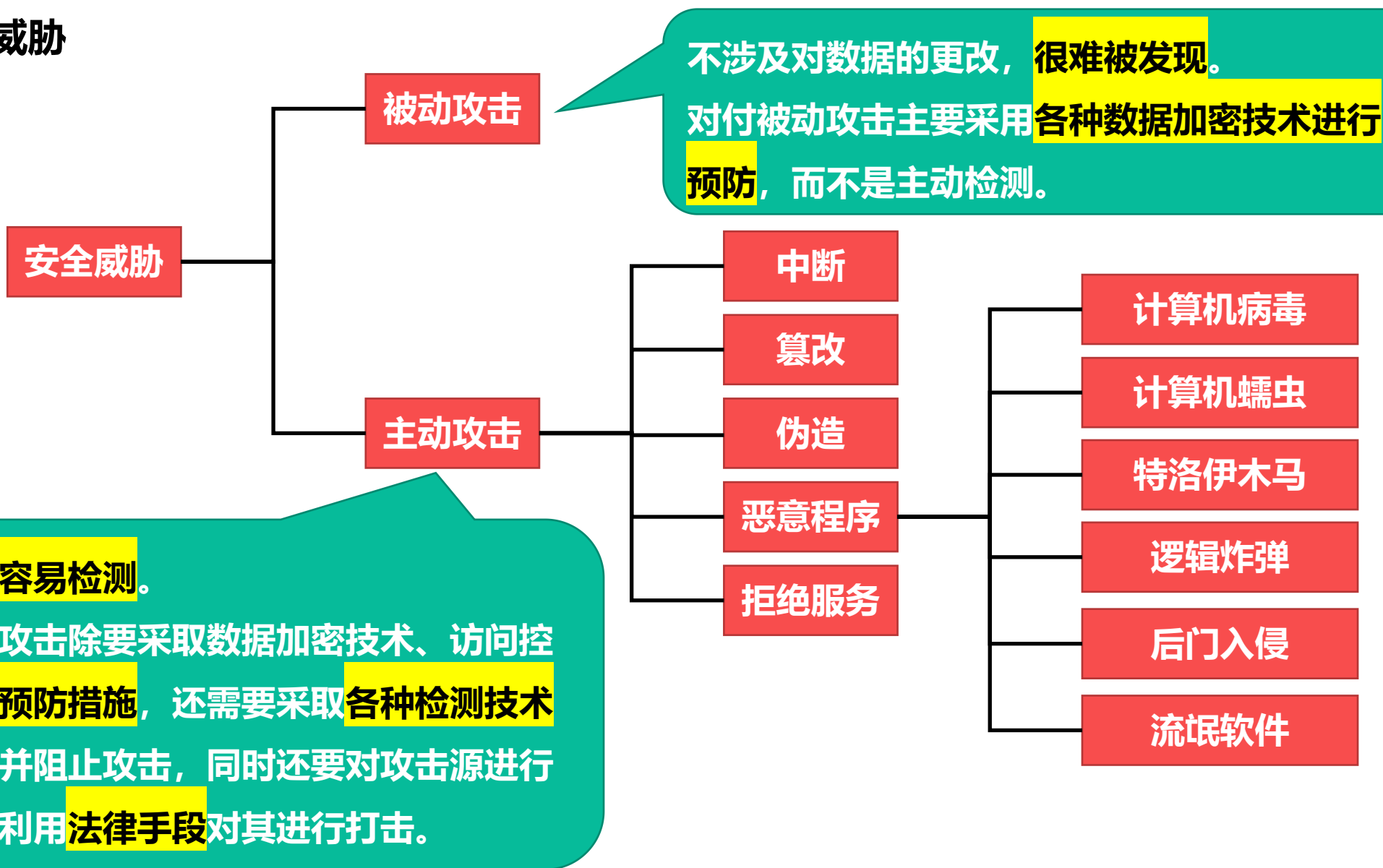


01 安全威胁

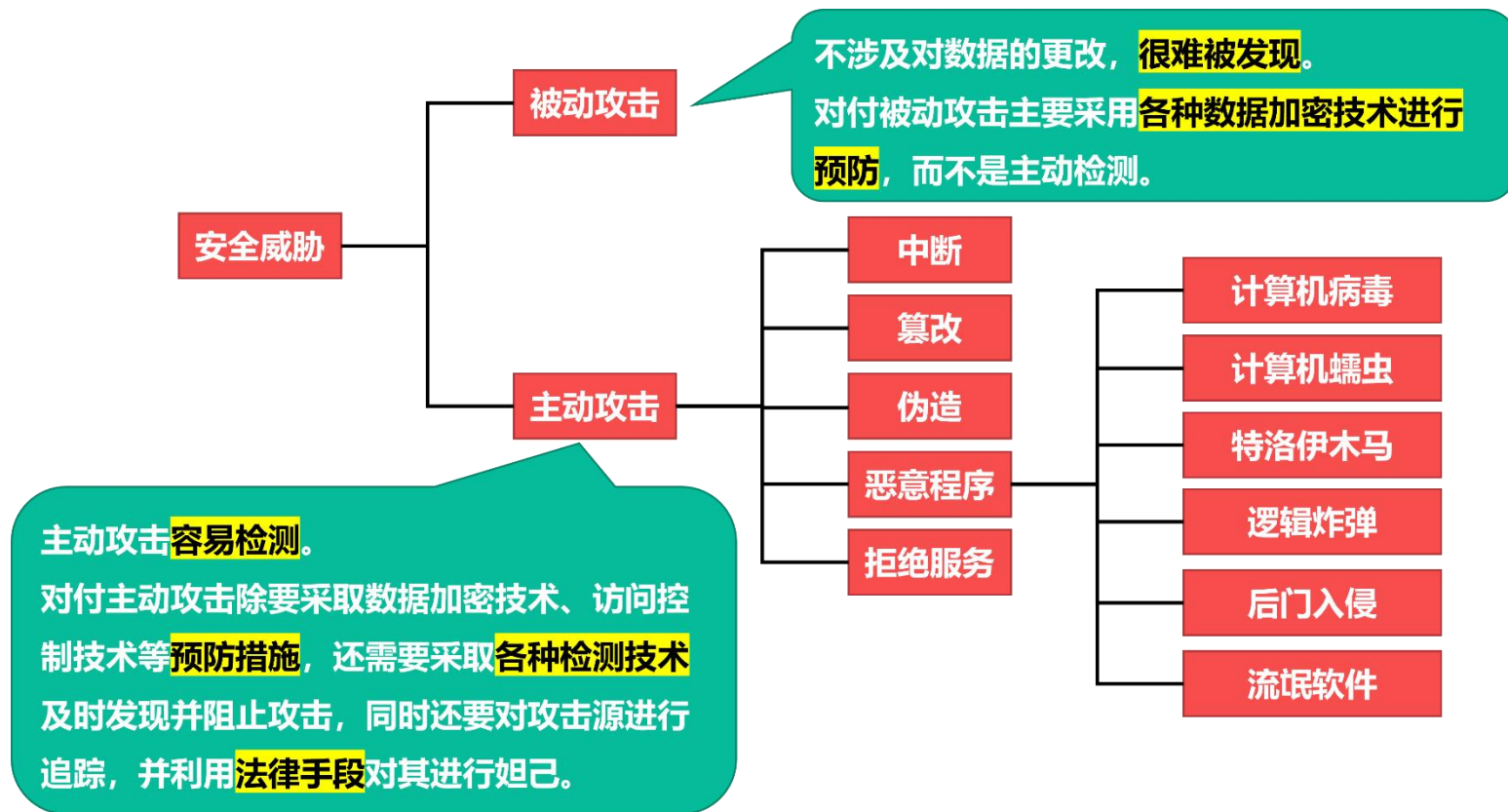
交换机中毒



01 安全威胁



01 安全威胁



为了防止上述各种安全威胁，一个安全的计算机网络应设法提供相应的安全服务。

02 安全服务

保密性

确保网络中传输的信息只有其发送方和接收方才能懂得其含义，而信息的截获者则看不懂所截获的数据。显然，保密性是计算机网络中最基本的安全服务，也是对付被动攻击所必须具备的功能。

报文完整性

确保网络中传输的信息不被攻击者篡改或伪造，它在应对主动攻击时也是必不可少的。

实体鉴别

通信两端的实体能够相互验证对方的真实身份，确保不会与冒充者进行通信。目前频发的网络诈骗，多数情况都是由于在网络上不能鉴别出对方的真实身份。实体鉴别在对付主动攻击时是非常重要的。

不可否认性

用来防止发送方或接收方否认发送或接收过某信息。在电子商务中这是一种非常重要的安全服务。

访问控制

可以限制和控制不同实体对信息源或其他系统资源进行访问的能力。必须在鉴别实体身份的基础上对实体的访问权限进行控制。

可用性

确保授权用户能够正常访问系统信息和资源。很多攻击都会导致系统可用性的损失，拒绝服务DoS攻击就是可用性最直接的威胁。

02 安全服务

保密性	确保网络中传输的信息只有其发送方和接收方才能懂得其含义，而信息的截获者则看不懂所截获的数据。显然，保密性是计算机网络中最基本的安全服务，也是对付被动攻击所必须具备的功能。
报文完整性	确保网络中传输的信息不被攻击者篡改或伪造，它在应对主动攻击时也是必不可少的。
实体鉴别	通信两端的实体能够相互验证对方的真实身份，确保不会与冒充者进行通信。目前频发的网络诈骗，多数情况都是由于在网络上不能鉴别出对方的真实身份。实体鉴别在对付主动攻击时是非常重要的。
不可否认性	来防止发送方或接收方否认发送或接收过某信息。在电子商务中这是一种非常重要的安全服务。
访问控制	可以限制和控制不同实体对信息源或其他系统资源进行访问的能力。必须在鉴别实体身份的基础上对实体的访问权限进行控制。
可用性	是确保授权用户能够正常访问系统信息和资源。很多攻击都会导致系统可用性的损失，拒绝服务DoS攻击就是可用性最直接的威胁。

从下节课开始，我们陆续介绍实现上述安全服务的各种**安全机制**。

7.2.1 密码学相关基本概念

01

密码学相关基本概念

01 密码学相关基本概念

■ 将发送的数据变换成对任何不知道如何做逆变换的人都不可理解的形式，从而保证数据的机密性，这种变换称为**加密**（Encryption）。

☐ 加密前的数据被称为**明文**（Plaintext）。

☐ 加密后的数据被称为**密文**（Ciphertext）。

■ 通过某种逆变换将密文重新变换回明文，这种逆变换称为**解密**（Decryption）。

■ 加密和解密过程可以使用**密钥**（Key）作为参数。

☐ **密钥必须保密，但加密和解密的过程可以公开。**

☐ **只有知道密钥的人才能解密密文，否则即使知道加密或解密算法也无法解密密文。**

01 密码学相关基本概念

一旦**算法失密就必须放弃该算法**，这意味着需要频繁地修改密码算法，而**开发一个新的密码算法是非常困难的事情**。

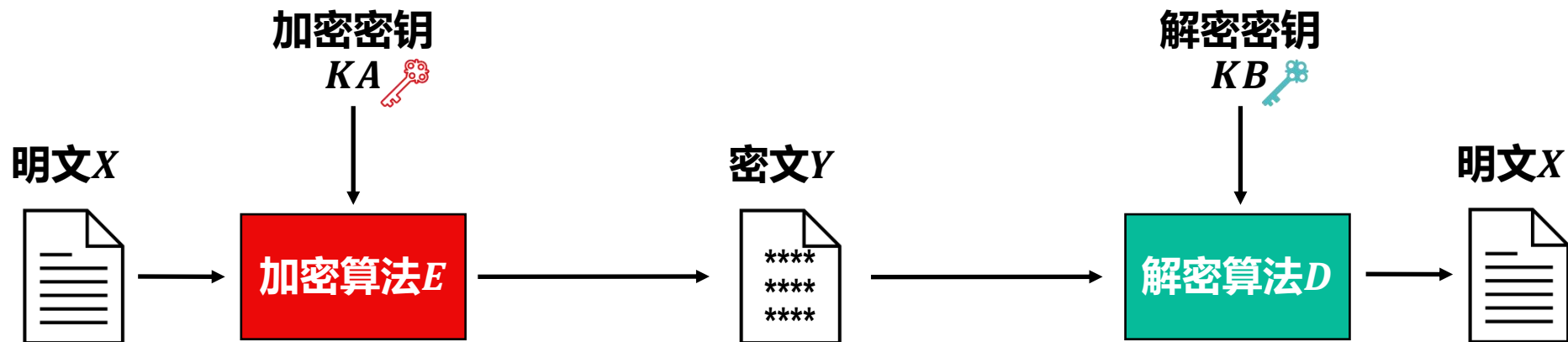
密钥空间可以很大，用密钥将密码算法参数化，同一个密码算法可以为大量用户提供加密服务。

为什么依靠密钥进行保密而不依靠密码算法进行保密呢？



01 密码学相关基本概念

数据加密的一般模型



加密过程的一般表示方式

$$Y = E_{KA}(X)$$

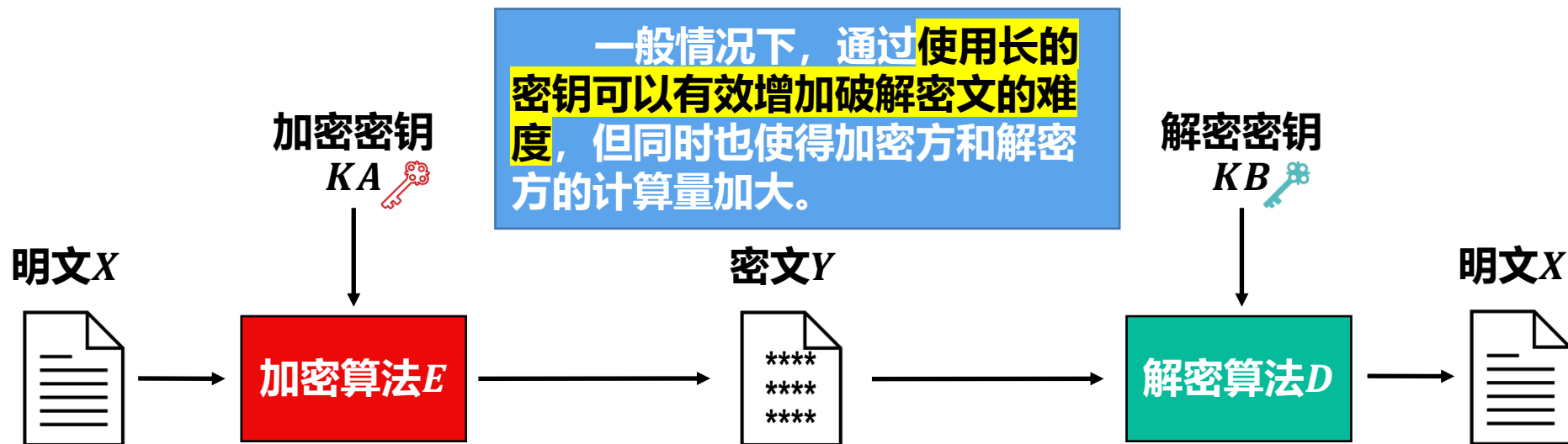
解密过程的一般表示方式

$$D_{KB}(Y) = D_{KB}(E_{KA}(X)) = X$$

加密密钥和解密密钥可以相同，也可以不同（即使不同，这两个密钥也必然有某种相关性），这取决于采用的是对称密钥密码体制还是公开密钥（公钥）密码体制。

01 密码学相关基本概念

数据加密的一般模型



如果不论攻击者截获了多少密文，在密文中都没有足够的信息来唯一地确定出对应的明文，则这一密码体制称为**无条件安全**的，或称为**理论上是不可破**的。

然而，在无任何条件限制下，目前几乎所有实用的密码体制均是可破的。因此，人们关心的是在**计算上（而不是理论上）是不可破的密码体制**。

如果一个密码体制中的密码不能在一定时间内被可以使用的计算资源破解，则这一密码体制称为在**计算上是安全**的。

7.2.2 对称密钥密码体制

01

对称密钥密码体制

02

数据加密标准DES

03

三重DES

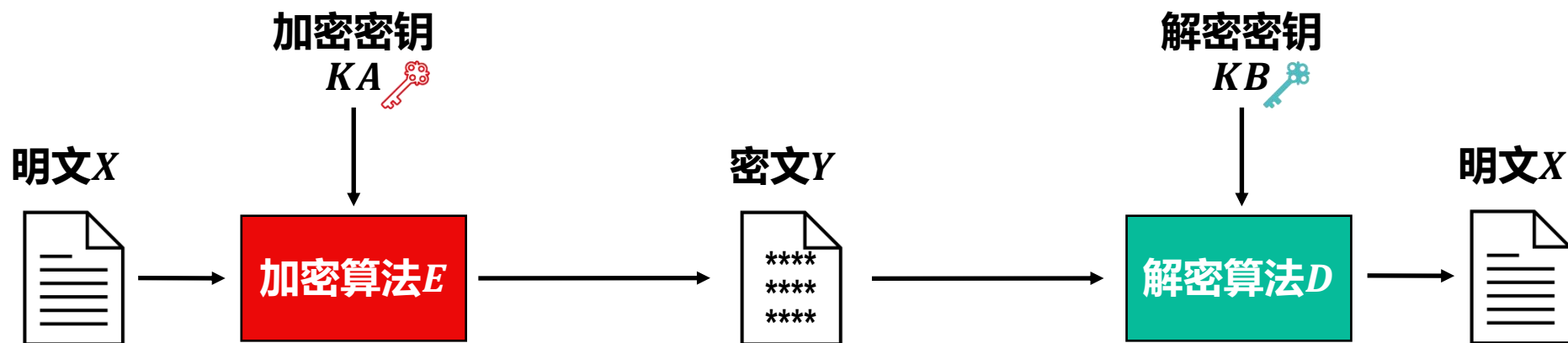
04

高级加密标准AES

01 对称密钥密码体制

■ 对称密钥密码体制是指**加密密钥与解密密钥相同的密码体制**。

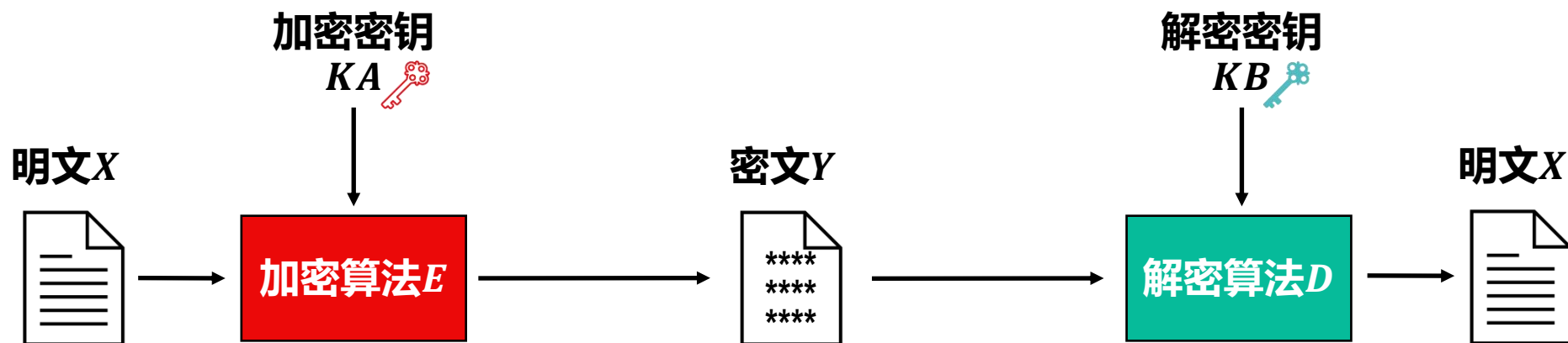
数据加密的一般模型



01 对称密钥密码体制

■ 对称密钥密码体制是指**加密密钥与解密密钥相同的密码体制**。

数据加密的一般模型

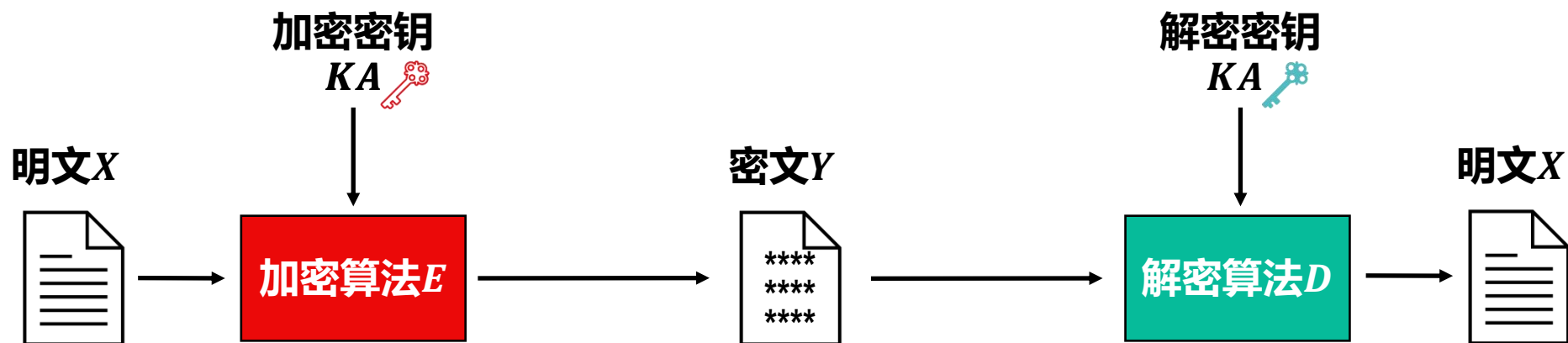


01 对称密钥密码体制

■ 对称密钥密码体制是指**加密密钥与解密密钥相同的密码体制**。

数据加密的一般模型

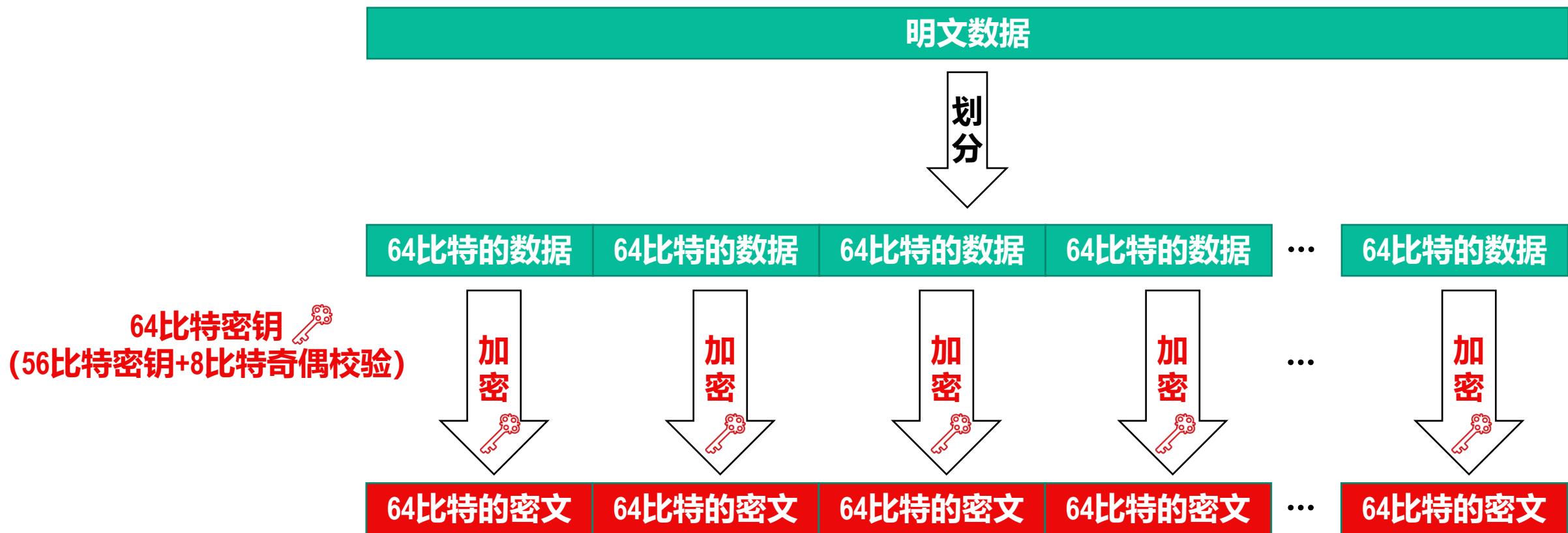
使用对称密钥



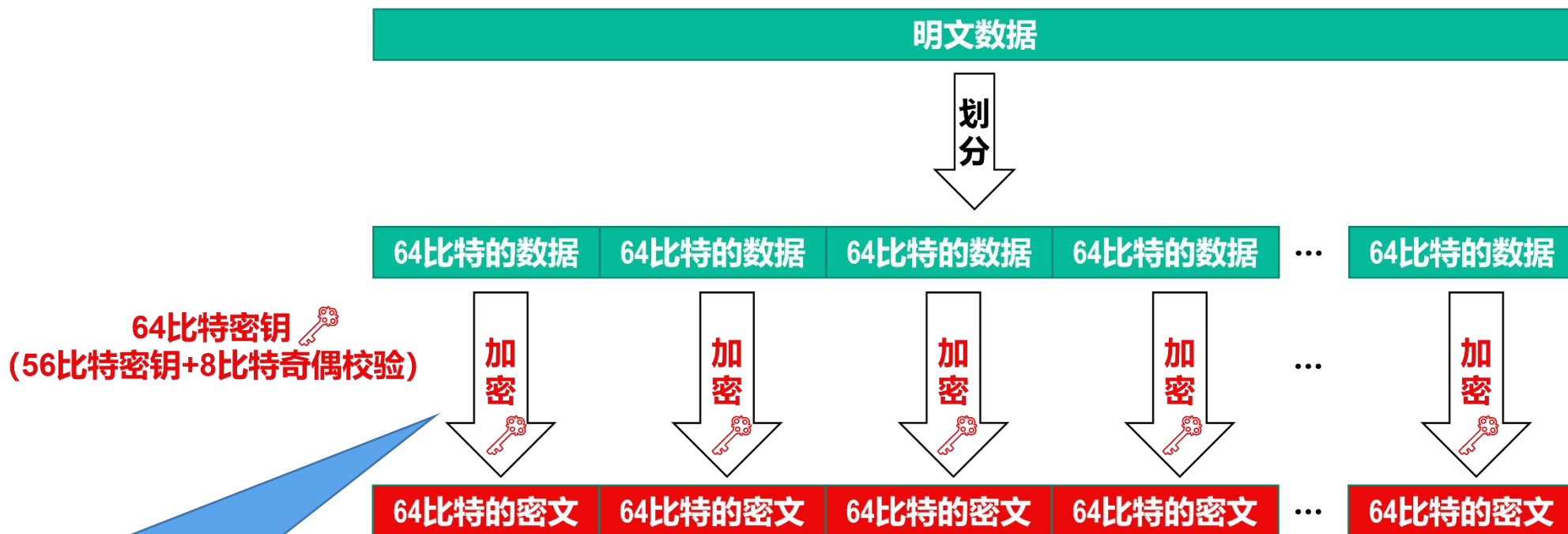
02 数据加密标准DES

■ 由IBM公司研制并于1977年被美国定为联邦信息标准的**数据加密标准**（Data Encryption Standard, **DES**），就是**对称密钥密码体制的典型代表**。国际标准化组织曾把DES作为数据加密标准。

■ DES的加密方法：



02 数据加密标准DES



本课程并不是密码学的专业课程，因此在本课程中仅介绍DES的基本概念和加密过程，对于DES的具体加密/解密算法并没有介绍，有兴趣的同学可自行查阅相关资料。

02 数据加密标准DES

DES的保密性仅取决于对密钥的保密和密钥的长度，而算法是公开的。

20世纪70年代设计的DES，经过了世界上无数优秀学者几十年的密码分析，除了其56比特密钥长度太短，没有发现其任何大的设计缺陷。

56比特长的密钥，可用密钥数量为 2^{56} （约 7.6×10^{16} ）。



1μs执行一次DES加密，平均只需要搜索密钥空间的一半即可找到密码，则破译DES要超过1000年。



1999年，使用一台不到25万美元的专用计算机，22小时多一点的时间破译。

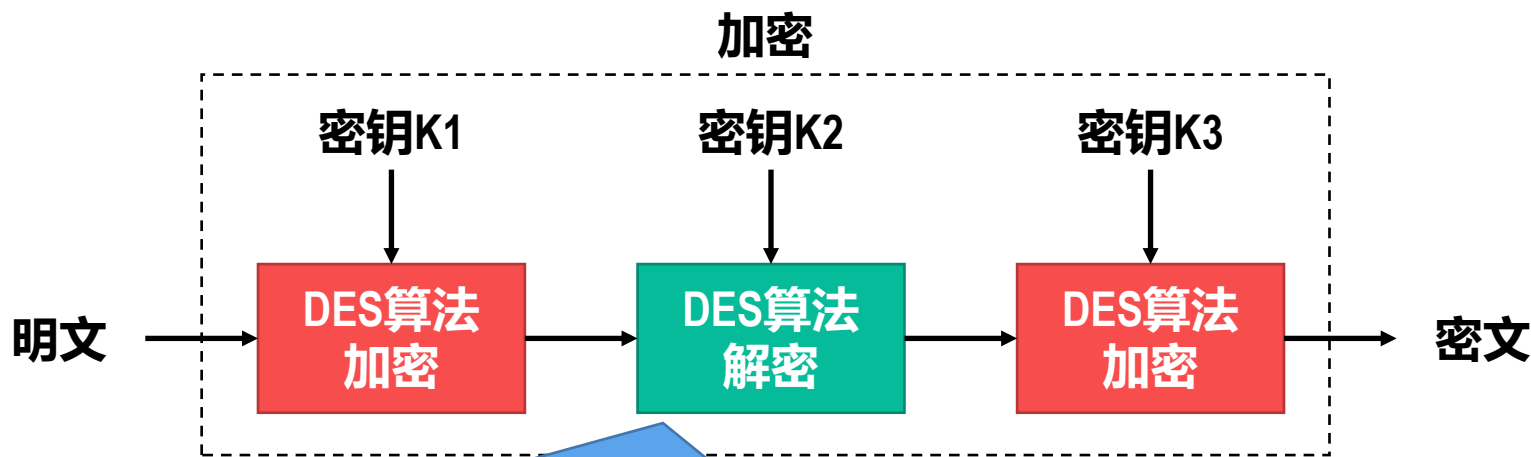
用价格为100万美元和1000万美元的机器，则预期的搜索时间分别为3.5小时和21分钟。

现在对于56比特的DES密钥的搜索已成常态，56比特DES已不再被认为是安全的。

03 三重DES

为了解决56比特DES密钥太短的问题，学者们提出了三重DES（Triple DES，3DES）。3DES在1985年成为美国的一个商用加密标准[RFC 2420]。

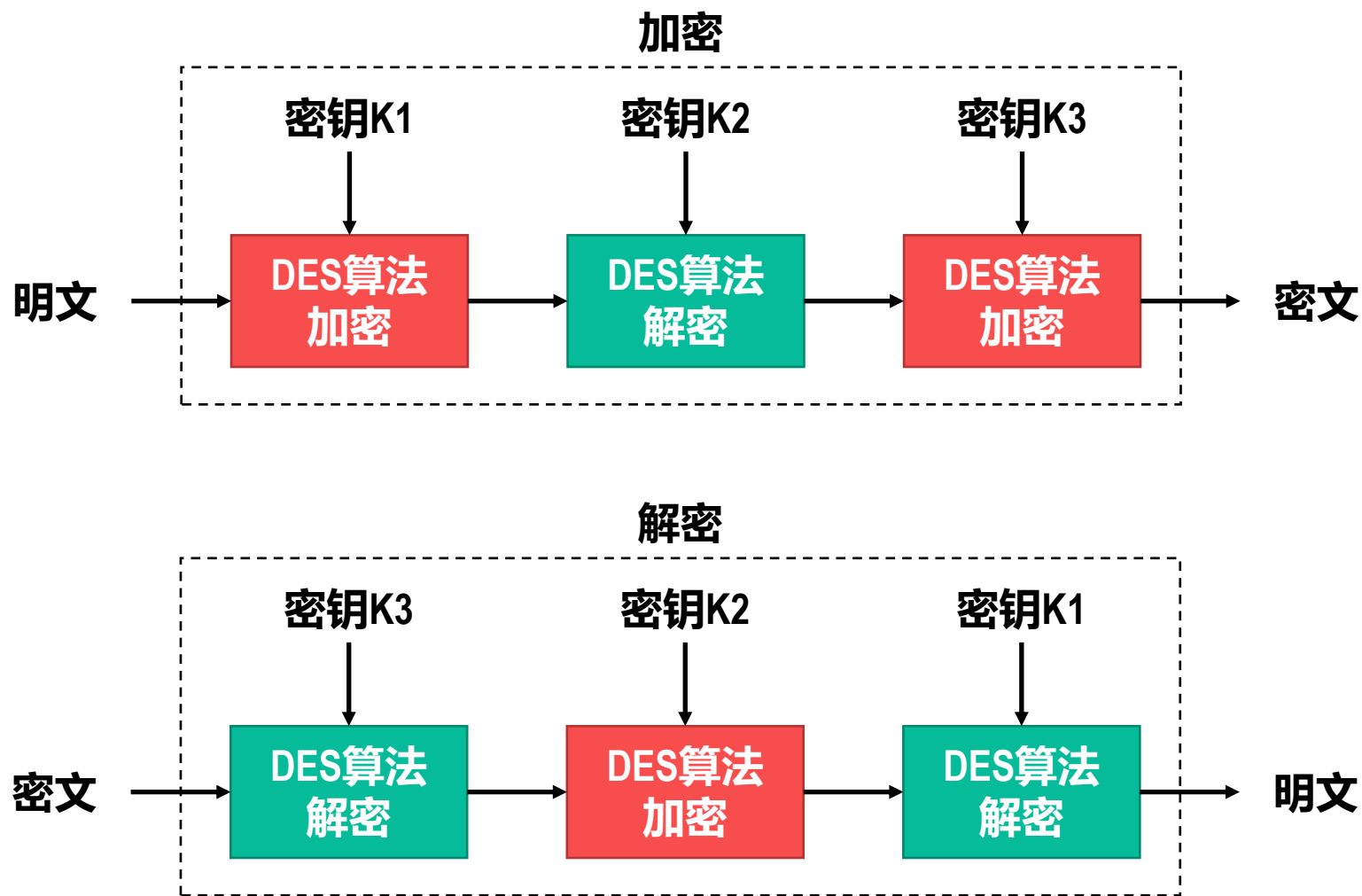
3DES使用3个密钥执行三次DES算法。



3DES仍使用原有的DES算法，当三个密钥K1、K2和K3都相同时，等效于DES。这样有利于将DES逐步推广为3DES。

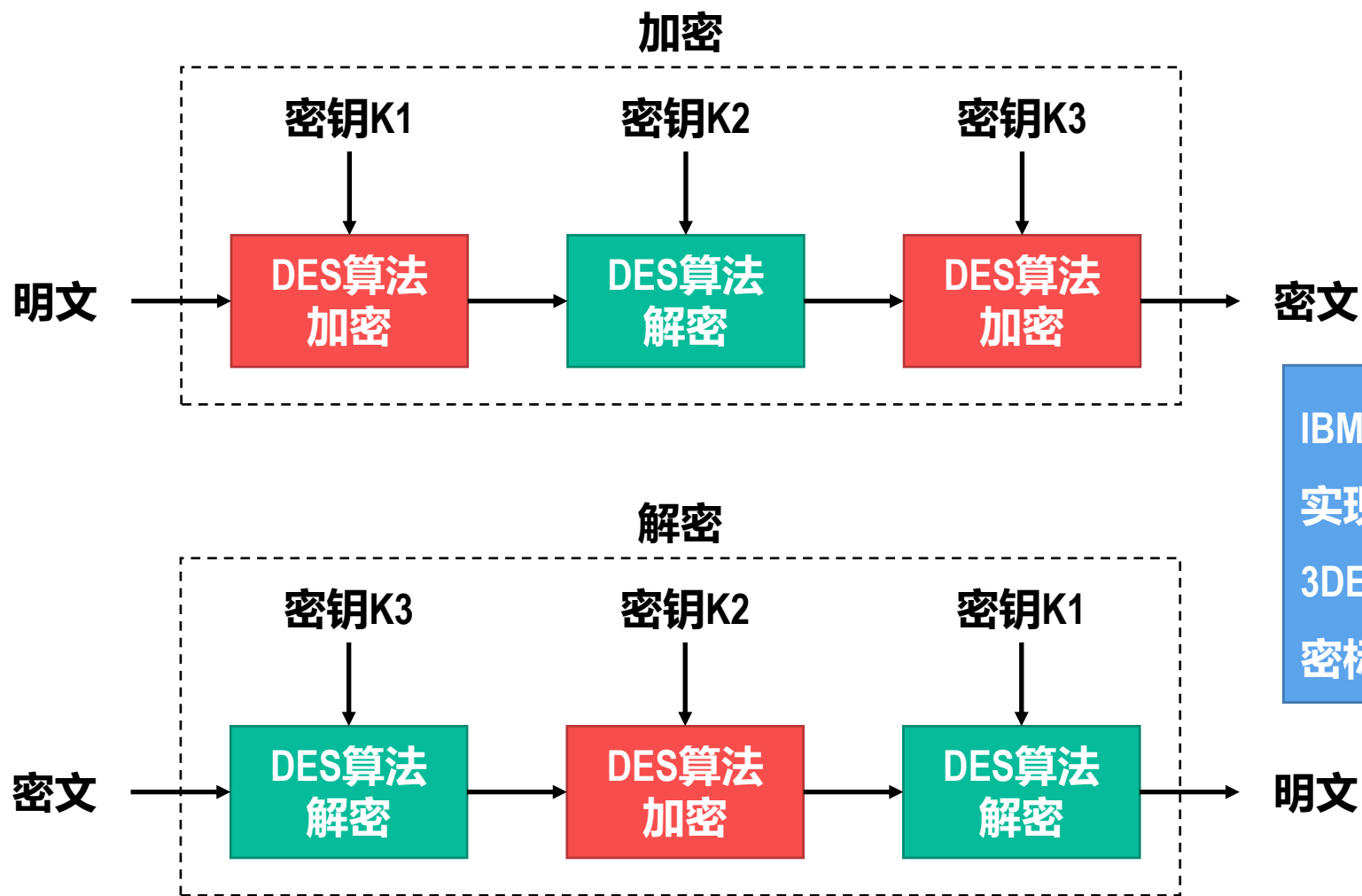
03 三重DES

3DES使用3个密钥执行三次DES算法。



03 三重DES

3DES使用3个密钥执行三次DES算法。



IBM最初设计DES时主要考虑用硬件来实现，因此DES/3DES的软件实现较慢。3DES目前正在被2001年发布的高级加密标准AES所替代。

04 高级加密标准AES

- **高级加密标准**（Advanced Encryption Standard, **AES**）支持128比特、192比特和256比特的密钥长度，**用硬件和软件都可以快速实现**。
- AES不需要太多内存，因此**适用于小型移动设备**。
- 据美国国家标准与技术研究院NIST估计，如果用1秒即可破解56比特密钥长度的DES的计算机，来破解128比特密钥长度的AES密钥，要用大约149万亿年的时间才有可能完成破解。

7.2.3 公钥密码体制

01

公钥密码体制的产生原因

02

公钥密码体制

01 公钥密码体制的产生原因

■ 在**对称密钥**密码体制中，**加解密双方要共享同一个密钥**。



给密钥的管理和更换带来极大的不便

容易想到的两种方法：

- 双方事先约定同一密钥。
- 使用信使来传送密钥。

对于高度自动化的大型计算机网络，使用信使来传送密钥显然是不合适的。

■ 尽管使用复杂但高度安全的**密钥分配中心**（Key Distribution Center, KDC）可以解决该问题，但是采用**公钥密码体制**可以比较容易地解决该问题。

02 公钥密码体制

■ **公钥密码体制使用不同的加密密钥和解密密钥**，其概念是由Stanford大学的研究人员Diffie和Hellman于1976年提出的。

☐ **加密密钥**是向公众**公开**的，称为**公钥**（Public Key, **PK**）。

☐ **解密密钥**是需要**保密**的，称为**私钥或密钥**（Secret Key, **SK**）。

☐ **加密算法****E**和**解密算法****D**都是**公开**的。

请同学们注意：
尽管SK由PK决定，但却不能
根据PK计算出SK。

■ 公钥密码体制的加密/解密过程的一般表示式： $D_{SK}(E_{PK}(X)) = X$ （X为明文）

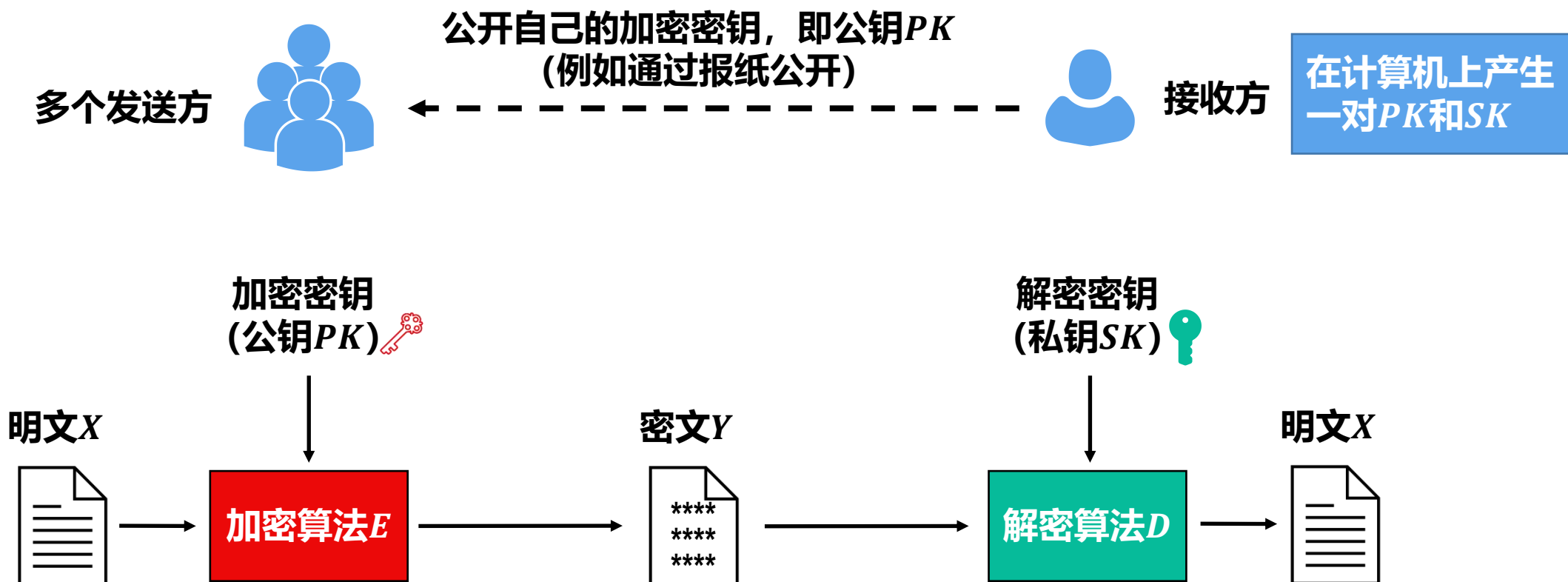
■ 加密和解密运算可以对调： $E_{PK}(D_{SK}(X)) = X$

■ PK只能用来加密，而不能用来解密： $D_{PK}(E_{PK}(X)) \neq X$

02 公钥密码体制

■ 由于从公钥 PK 不能推导出私钥 SK ，并且 PK 不能用来解密，因此 PK 可以是公开的。

■ 显然，采用公钥密码体制更易解决密钥分发的问题。



02 公钥密码体制

■ 公钥密码体制提出不久，研究人员就找到了三种公钥密码算法。1976年由美国三位科学家Rivest、Shamir和Adleman提出，并在1978年正式发表的**RSA**（**R**ivest、**S**hamir and **A**dleman）算法，就是目前最著名的公钥密码算法，它是基于数论中大数分解问题的算法。

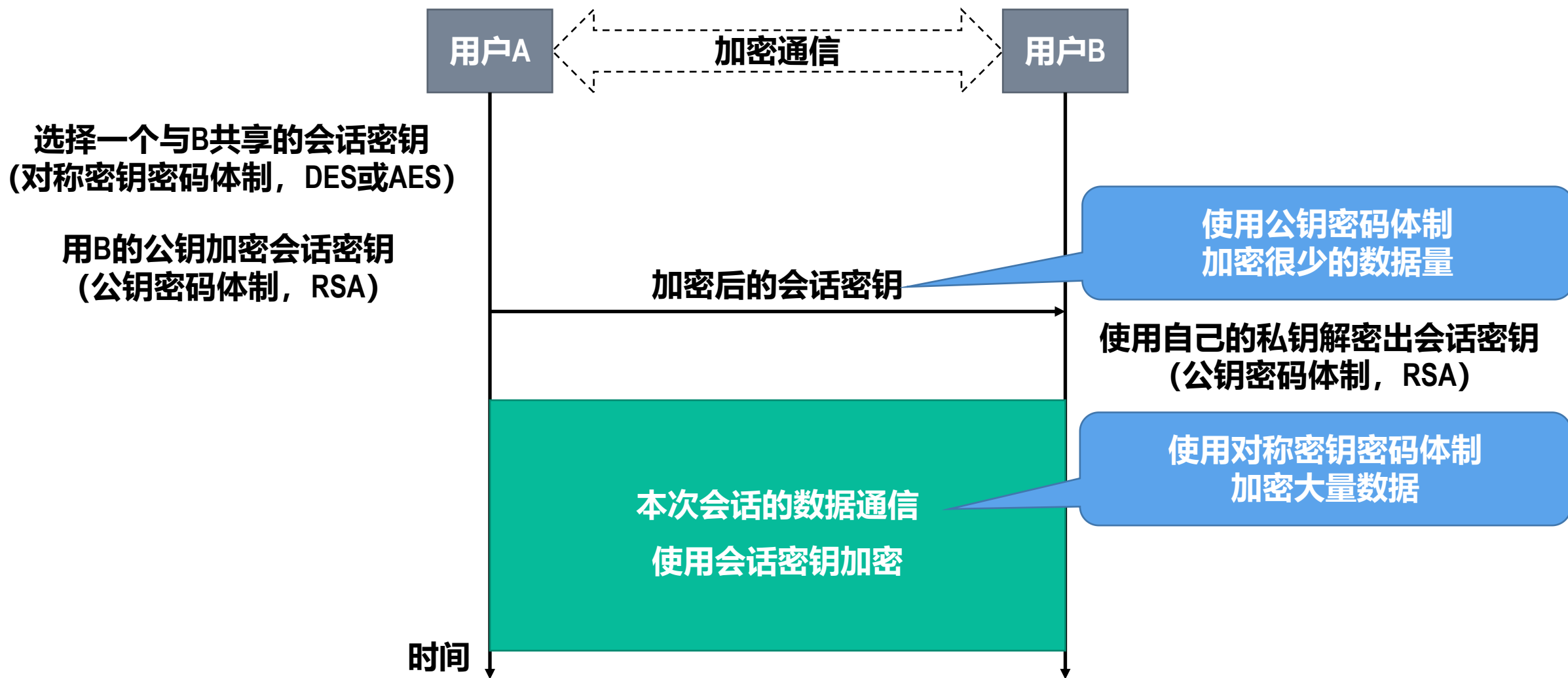
■ 公钥密码体制不仅用于加密，还可以很方便地用于**鉴别**和**数字签名**。

■ 目前的公钥密码算法比对称密钥密码算法慢好几个数量级。

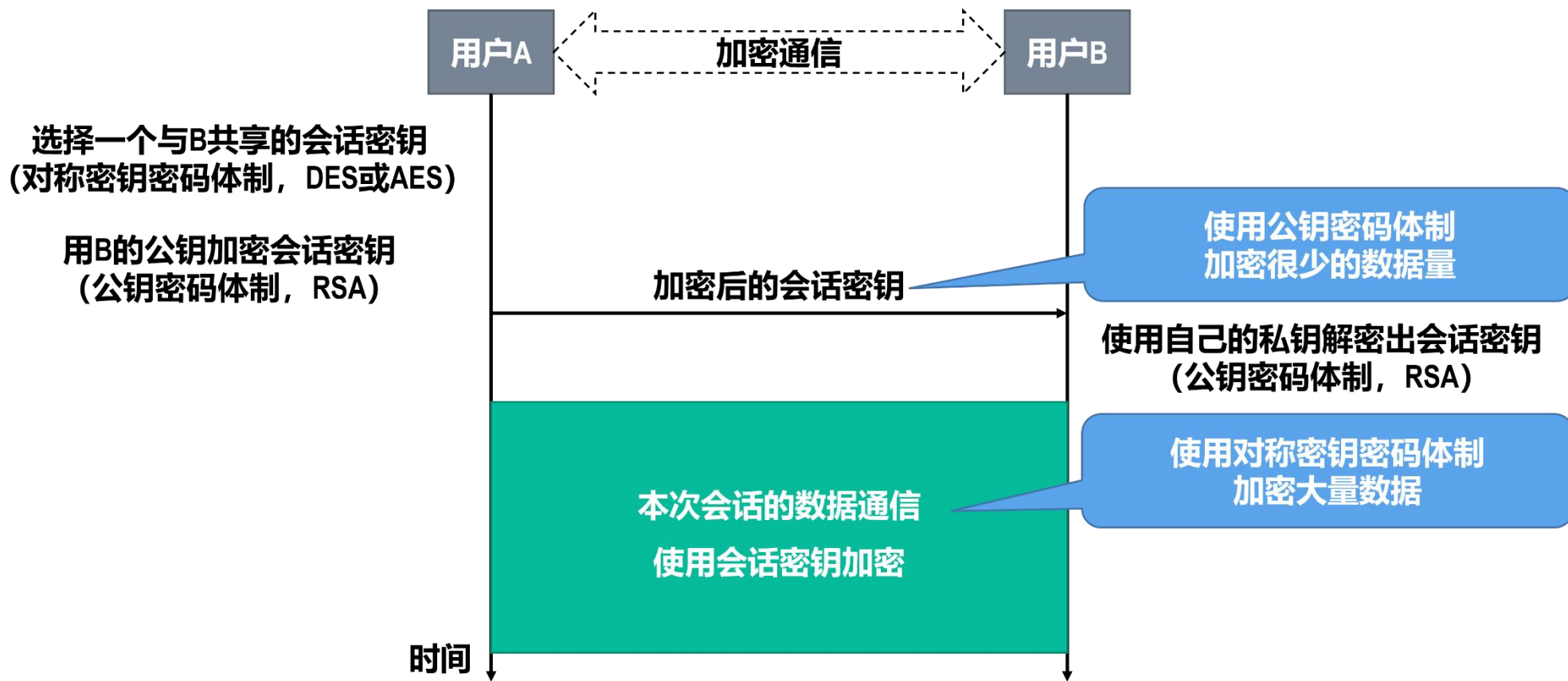
☐ 公钥密码体制通常用于**会话密钥**的建立；

☐ 对称密钥密码体制被用于其他大多数情况下的加密。

02 公钥密码体制



02 公钥密码体制



请同学们注意：

任何加密方法的安全性取决于密钥的长度和攻破密文所需的计算量，而不是简单地取决于加密体制。因此不能简单地判断，对称密钥密码体制与公钥密码体制相比，哪个密码体制的安全性更好。

7.3.1 报文摘要和报文鉴别码

01

报文完整性与鉴别的概念

02

报文摘要和报文鉴别码

03

密码散列函数

04

实用的报文摘要算法

05

散列报文鉴别码

01 报文完整性与鉴别的概念

■ 如果报文被攻击者篡改或伪造，则报文就不具备**完整性**。

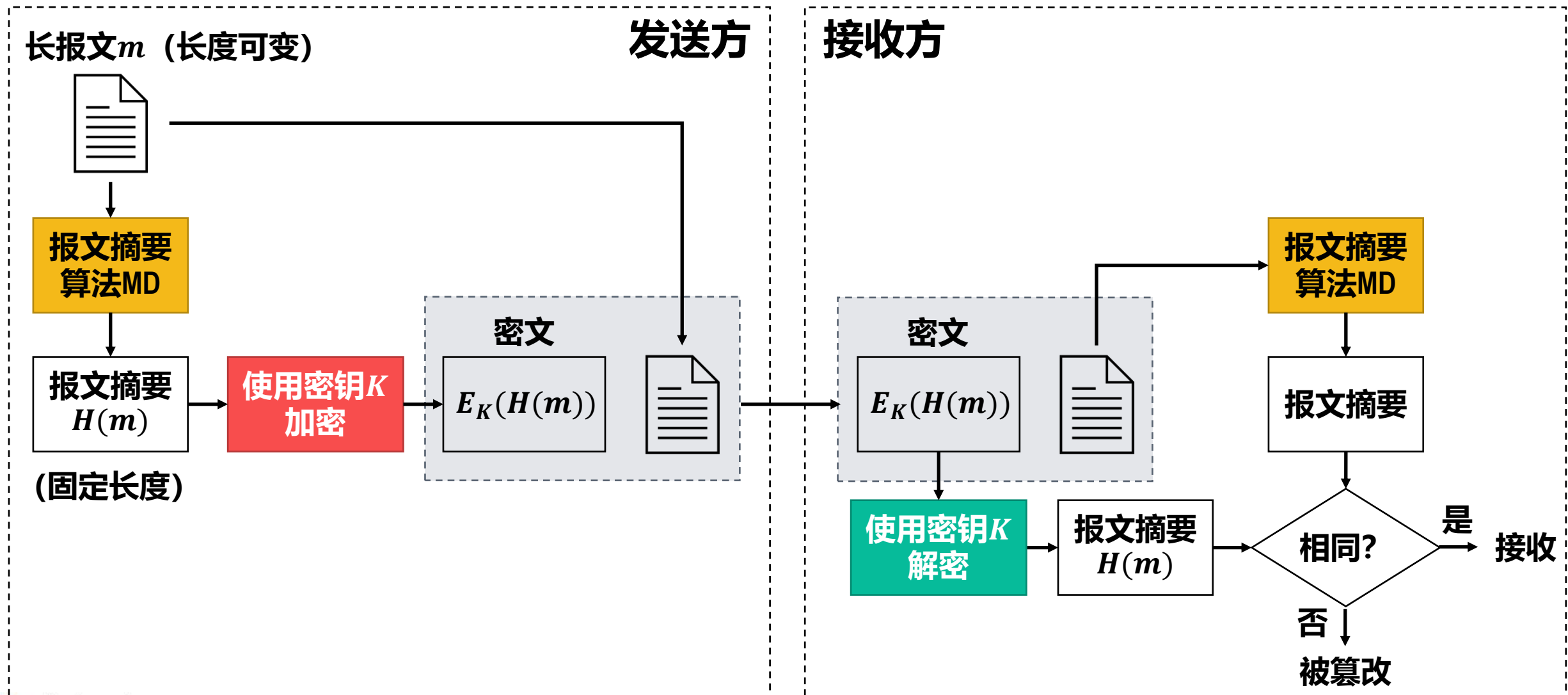
■ **对报文进行完整性验证就是进行报文鉴别**，也就是鉴别报文的真伪。

■ **使用加密技术通常就可以达到报文鉴别的目的**，因为被篡改的报文解密后一般不能得到可理解的内容。

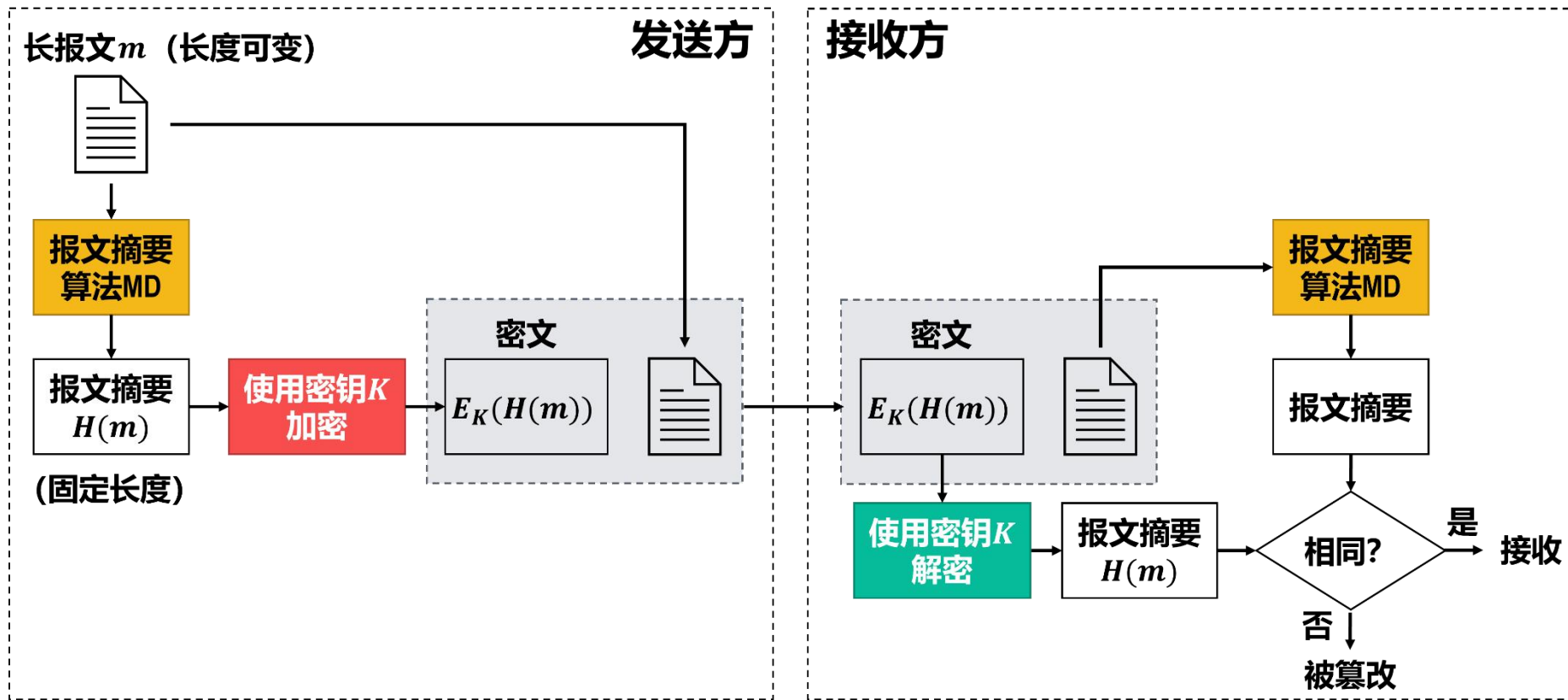
□ 然而，**对于不需要保密而只需要报文鉴别的网络应用**（例如从因特网的某个网站下载一个应用软件，用户只关心该软件是否与官方发布的一致），**对整个报文进行加密和解密，会使计算机花费相当多的CPU时间。**

□ **使用报文摘要（Message Digest, MD）进行报文鉴别是一种更有效的方法。**

02 报文摘要和报文鉴别码

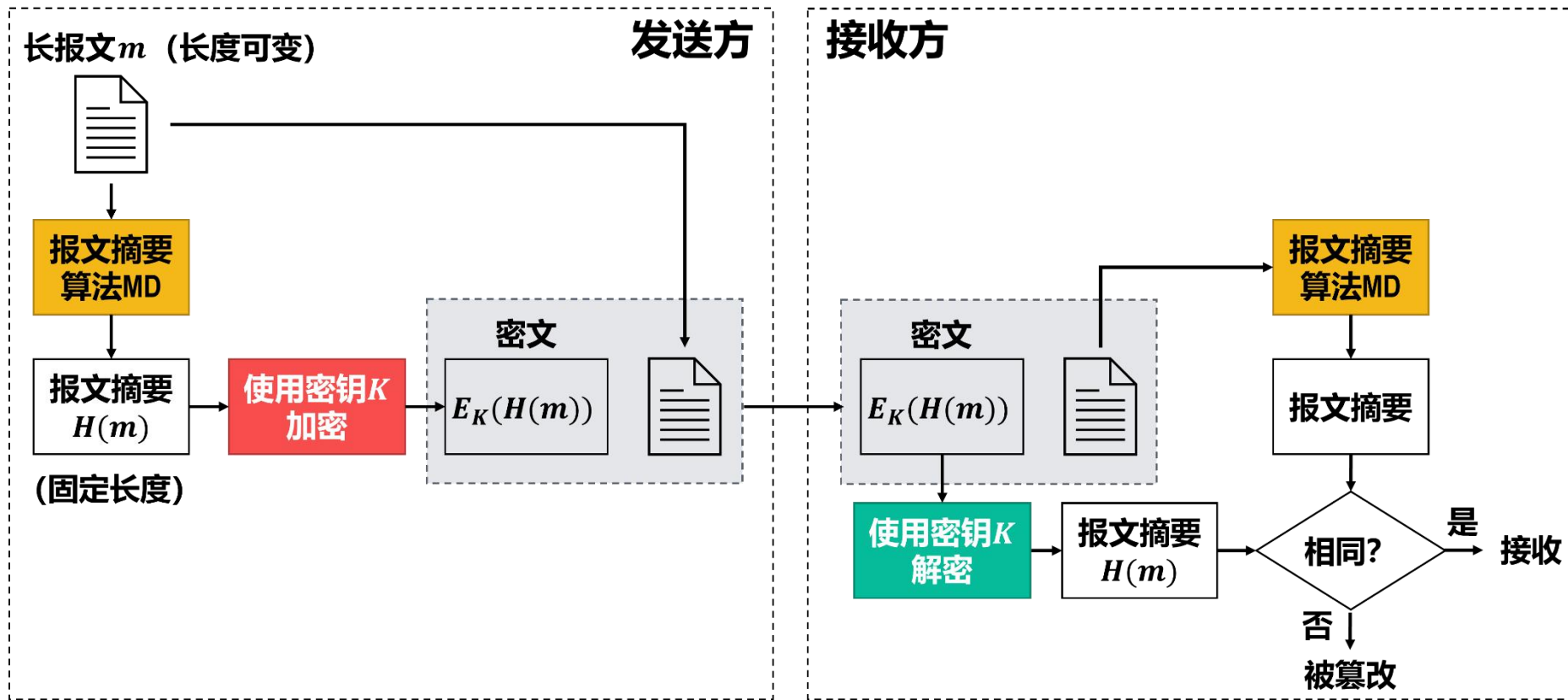


02 报文摘要和报文鉴别码



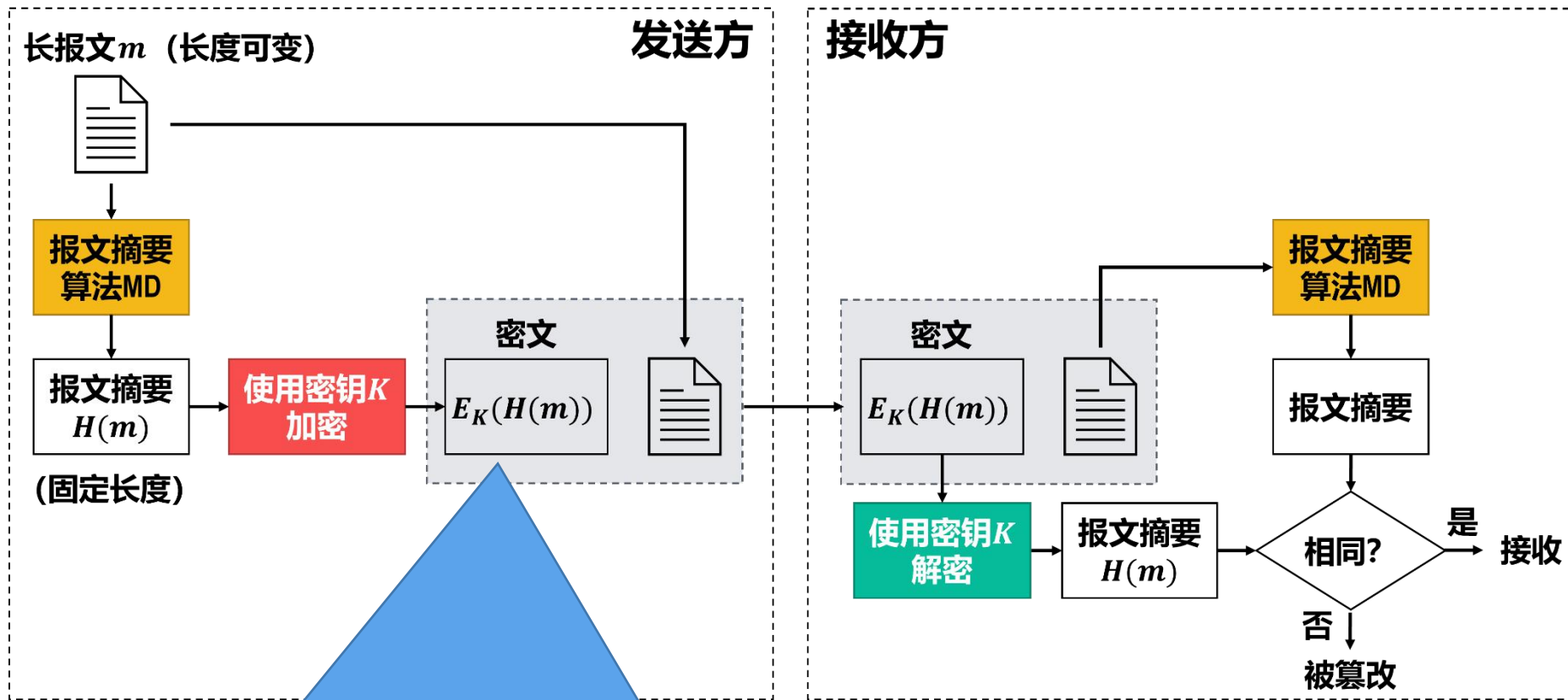
使用报文摘要对报文进行鉴别的好处是：只对长度固定且比整个报文长度短得多的报文摘要 $H(m)$ 进行加密，比对整个报文 m 进行加密要简单得多。

02 报文摘要和报文鉴别码



密钥 K 仅在通信双方之间共享，没有第三方能用伪造报文产生出使用密钥 K 加密的伪造报文摘要。

02 报文摘要和报文鉴别码



附加在报文后面用于报文鉴别的码串（即加密后的报文摘要），称为**报文鉴别码**（**Message Authentication Code, MAC**）。

03 密码散列函数

■ 报文摘要MD实际上与之前介绍过的帧检验序列（第3章）、首部检验和（第4章）等都是**散列函数**（Hash Function）的一种应用，用于接收方对收到的数据进行检查以便发现是否有误码。

■ 散列函数具有以下两个特点：

- (1) 散列函数的**输入长度是可变的，并且可以很长，但其输出长度是固定的，并且较短**。散列函数的输出称为**散列值**，也可简称为散列。
- (2) 不同的散列值对应不同的输入，但不同的输入却可能得出相同的散列值。换句话说，**散列函数的输入和输出并非一一对应，而是多对一的**。

■ 为了抵御攻击者的篡改，**报文摘要算法**必须满足以下条件：

- (1) 对于任意给定的某个报文摘要值 $H(x)$ ，若想找到一个报文 y 使得 $H(y) = H(x)$ ，**在计算上是不可行的**。
- (2) 若想找到任意两个报文 x 和 y ，使得 $H(y) = H(x)$ ，**在计算上是不可行的**。

满足上述两个条件表明：对于发送方产生的报文 x 和其相应的报文摘要 $H(x)$ ，攻击者不可能伪造出另一个报文 y ，使得 y 与 x 具有同样的报文摘要。

03 密码散列函数

■ 为了抵御攻击者的篡改，**报文摘要算法**必须满足以下条件：

- (1) 对于任意给定的某个报文摘要值 $H(x)$ ，若想找到一个报文 y 使得 $H(y) = H(x)$ ，**在计算上是不可行的**。
- (2) 若想找到任意两个报文 x 和 y ，使得 $H(y) = H(x)$ ，**在计算上是不可行的**。

满足上述两个条件表明：对于发送方产生的报文 x 和其相应的报文摘要 $H(x)$ ，攻击者不可能伪造出另一个报文 y ，使得 y 与 x 具有同样的报文摘要。

■ 满足上述条件的散列函数就称为**密码散列函数**或**安全散列函数**。密码散列函数实际上是一种**单向函数**，由于无法通过报文摘要还原出原文，因此**可把密码散列函数运算看作没有密钥的加密运算**。

04 实用的报文摘要算法

最有名的**报文摘要算法**（或称密码散列函数或散列算法）有**MD5**（Message Digest, MD-5）和**安全散列算法1**（Secure Hash Algorithm, SHA-1）。

MD5是Rivest于1991年提出并获得了广泛应用的报文摘要算法[RFC 1321]。

☐ MD5输出128比特的摘要。

☐ MD5希望达到的设计目标：根据给定的MD5报文摘要，想要找出一个与原报文具有相同报文摘要的另一个报文，其难度在计算上几乎是不可能的。



2004年，我国学者王小云发表了轰动世界的密码学论文，证明了可以用系统的方法找出一对报文，这对报文具有相同的MD5报文摘要，而这仅需要15分钟至不到1小时的时间。这使得“密码散列函数的逆变换是不可能的”这一传统观念受到了颠覆性的动摇。

之后，又有许多学者开发了对MD5的实际攻击方法，这导致MD5最终被安全散列算法SHA-1所替代。

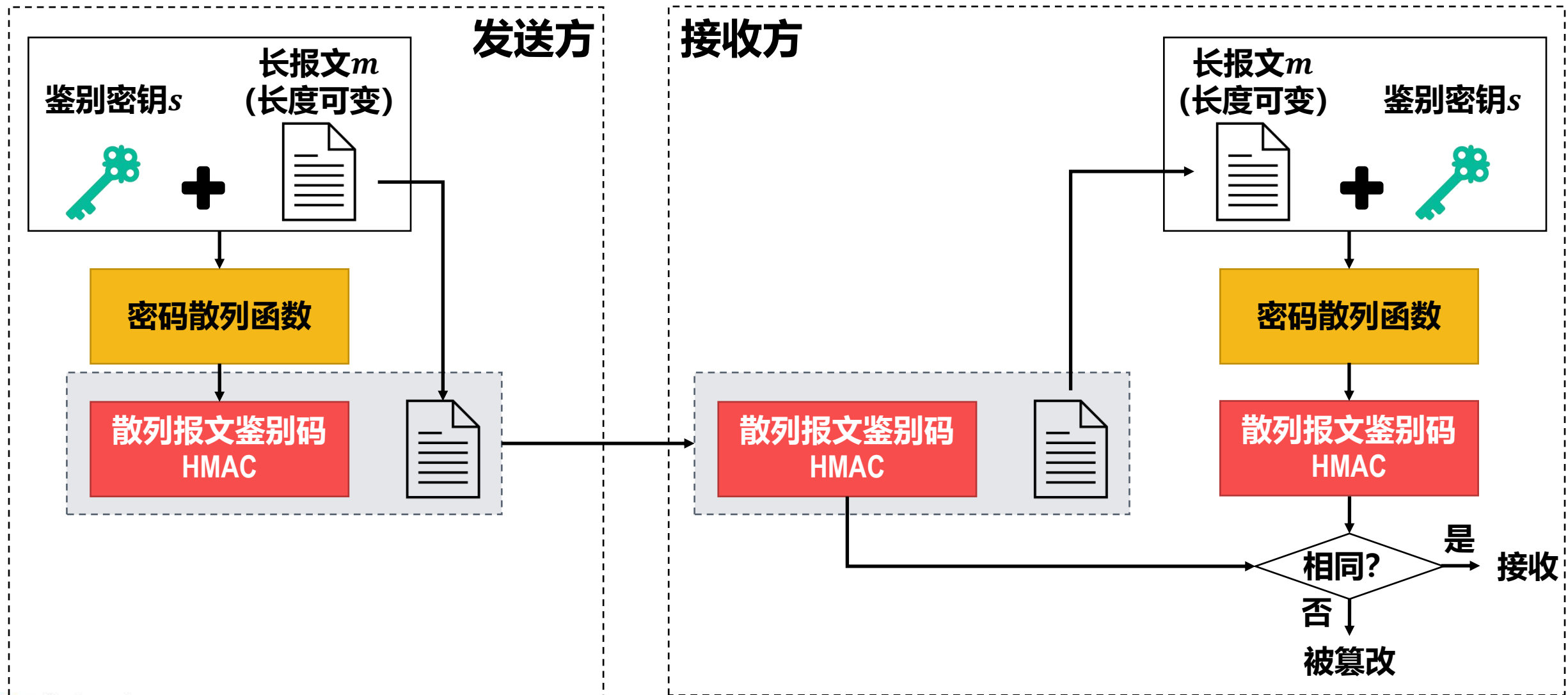
04 实用的报文摘要算法

- **SHA**是由美国标准与技术研究院NIST提出的一个散列算法系列。1995年发布的新版本SHA-1[RFC 3174]比MD5在安全性方面有了很大的提高。
 - ☐ SHA-1输出160比特的报文摘要，但计算要比MD5慢一些。
- 尽管SHA-1比MD5安全，但后来也被证明其实际安全性并未达到设计目标，并且**也曾被王小云教授的研究团队攻破**。
- 尽管现在SHA-1仍在使用，但很快就会被SHA-2和SHA-3所替代。
 - ☐ 微软已于2017年1月1日起停止支持SHA-1证书，而以前签发的SHA-1证书也必须更换为SHA-2证书。
 - ☐ 谷歌也宣布将在Chrome浏览器中逐渐降低SHA-1证书的安全指示。

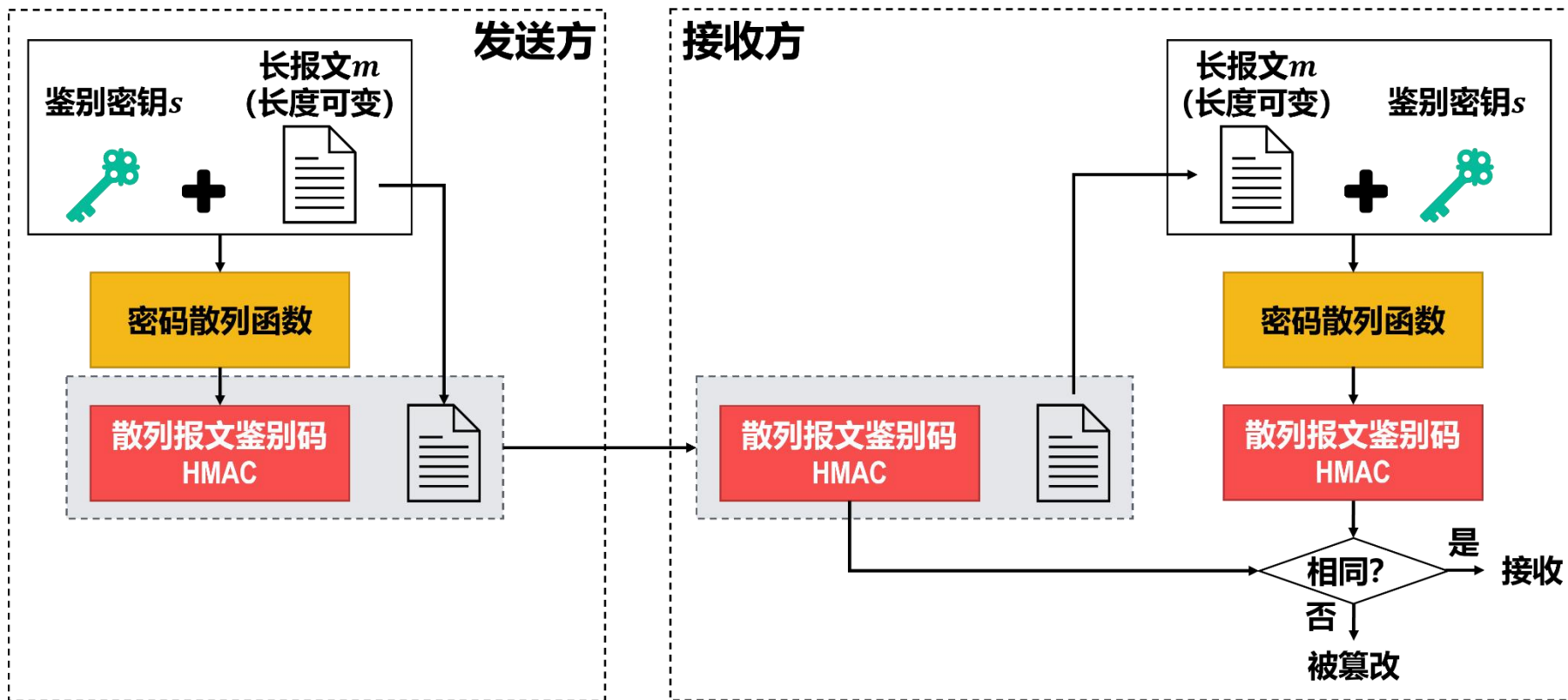
05 散列报文鉴别码

- 利用密码散列函数的特殊性质，可以设计出**无需对报文摘要进行加密的报文鉴别方法**，只要通信双方共享一个称为**鉴别密钥**的秘密比特串 s 即可。
- 直接使用密码散列函数实现报文鉴别的技术又称为**散列报文鉴别码**（Hashed MAC, HMAC）。

05 散列报文鉴别码



05 散列报文鉴别码



攻击者不知道仅由通信双方共享的鉴别密钥 s ，也不能从截获的散列报文鉴别码HMAC中计算出 s ，因此不能伪造报文 m' 产生 $(m' + s)$ 的HMAC。

7.3.2 数字签名

01

数字签名概述

02

数字签名的实现

03

具有保密性的数字签名

01 数字签名概述

■ 我们日常生活中的书信或文件可以依据亲笔签名或印章来证明其真实来源。

■ 类似地，在计算机网络中传送的报文可以使用**数字签名**（Digital Signature）来**证明其真实来源**。

■ 数字签名必须保证以下三点：

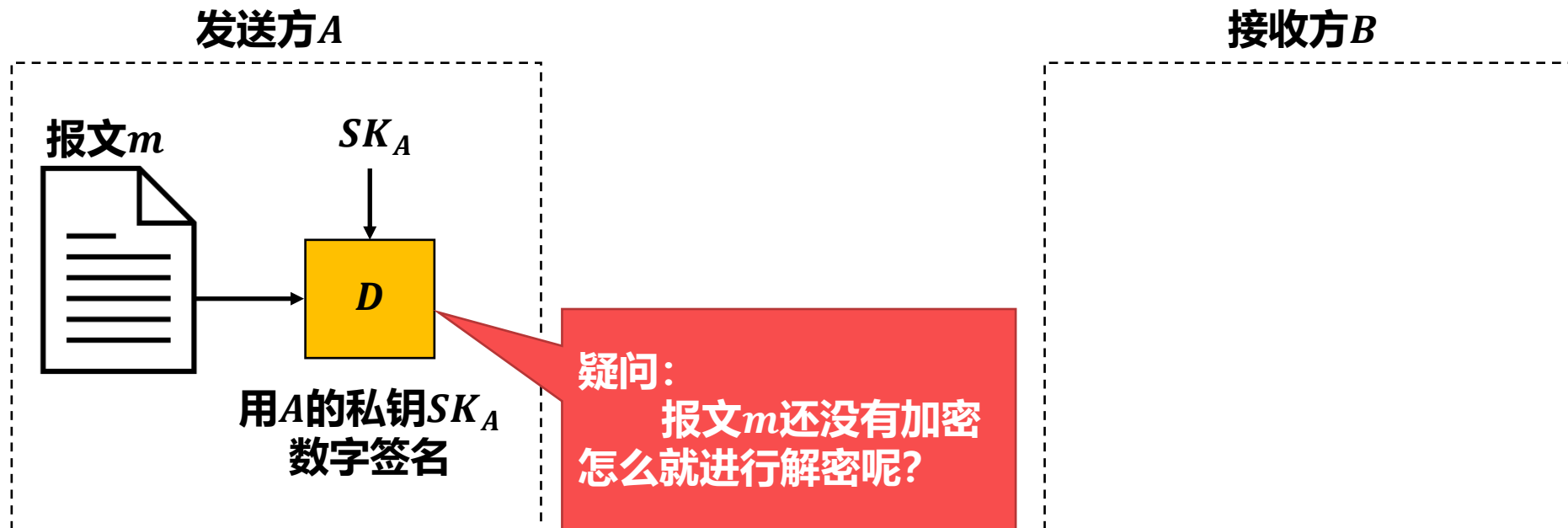
(1) 接收方能够**核实**发送方对报文的数字签名。

(2) 包括接收方在内的任何人都**不能伪造**对报文的数字签名。

(3) 发送方事后**不能抵赖**对报文的数字签名。

02 数字签名的实现

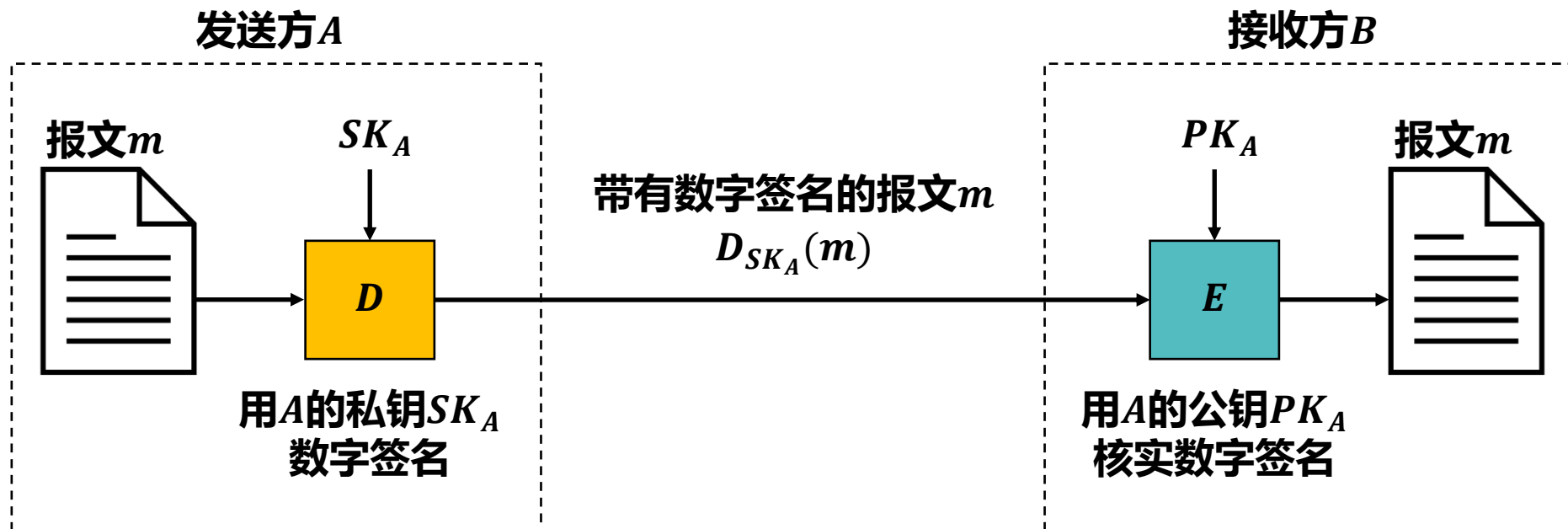
■ 现在已有多种实现数字签名的方法。采用公钥密码算法比采用对称密钥密码算法更容易实现数字签名。



其实这并没有什么关系。因为解密运算 D 仅仅是一个数学运算，运算结果只是将报文 m 变成了某种不可读的密文。此时的运算并非想将报文 m 加密而是为了数字签名。

02 数字签名的实现

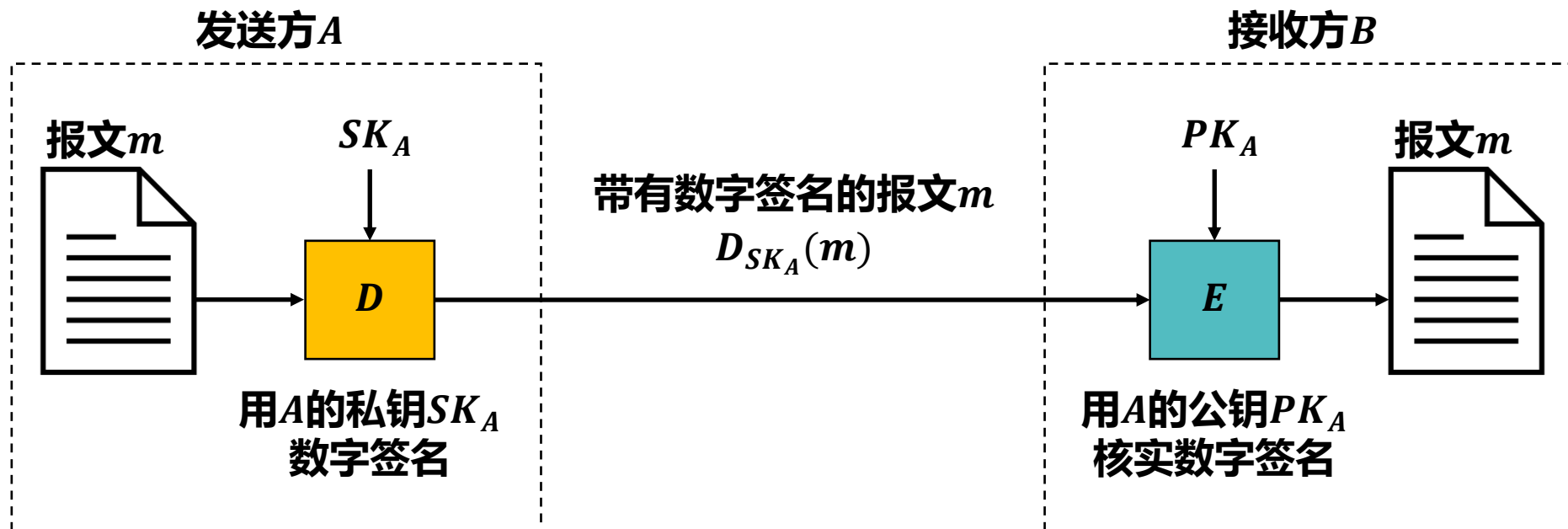
■ 现在已有多种实现数字签名的方法。采用公钥密码算法比采用对称密钥密码算法更容易实现数字签名。



由于除A外的其他任何人都没有A的私钥 SK_A ，所以除A外没有任何人能产生带有数字签名的报文 $D_{SK_A}(m)$ ，而任何伪造的报文经过 E_{PK_A} 运算后都不会得到可理解的内容。因此，B就通过这种方式核实了报文 m 的确是A签名发送的。

02 数字签名的实现

■ 现在已有多种实现数字签名的方法。采用公钥密码算法比采用对称密钥密码算法更容易实现数字签名。

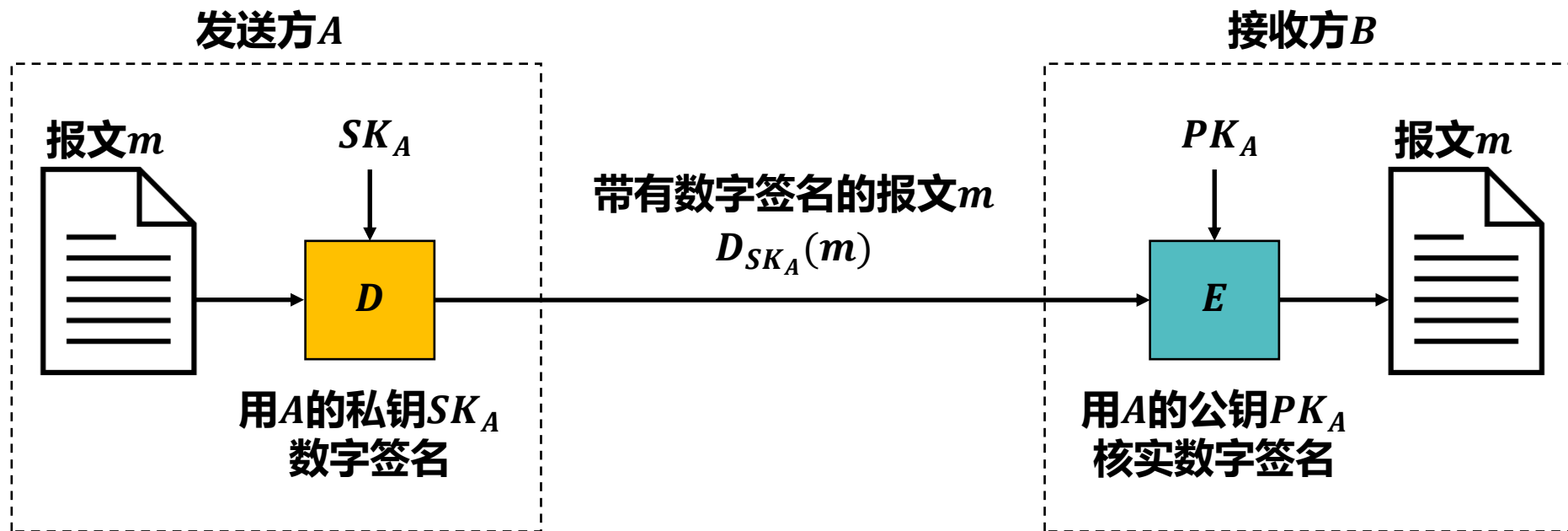


如果A要抵赖曾发送报文 m 给B，B可以把报文 m 和带有数字签名的报文 $D_{SK_A}(m)$ 出具给第三方。第三方很容易用A的公钥 PK_A 去证实A确实发送过报文 m 给B。

反之，若B把报文 m 伪造成 m' ，则B不能在第三方前出示带有数字签名的报文 $D_{SK_A}(m')$ ，因为B不可能具有A的私钥 SK_A 。这样就证明B伪造了报文。

02 数字签名的实现

■ 现在已有多种实现数字签名的方法。采用公钥密码算法比采用对称密钥密码算法更容易实现数字签名。



如果 A 要抵赖曾发送报文 m 给 B , B 可以把报文 m 和带有数字签名的报文 $D_{SK_A}(m)$ 出具给第三方。第三方很容易用 A 的公钥 PK_A 去证实 A 确实发送过报文 m 给 B 。

反之, 若 B 把报文 m 伪造成 m' , 则 B 不能在第三方前出示带有数字签名的报文 $D_{SK_A}(m')$, 因为 B 不可能具有 A 的私钥 SK_A 。这样就证明 B 伪造了报文。

很显然, 数字签名实现了对报文来源的鉴别。

02 数字签名的实现

■ 现在已有多种实现数字签名的方法。采用公钥密码算法比采用对称密钥密码算法更容易实现数字签名。



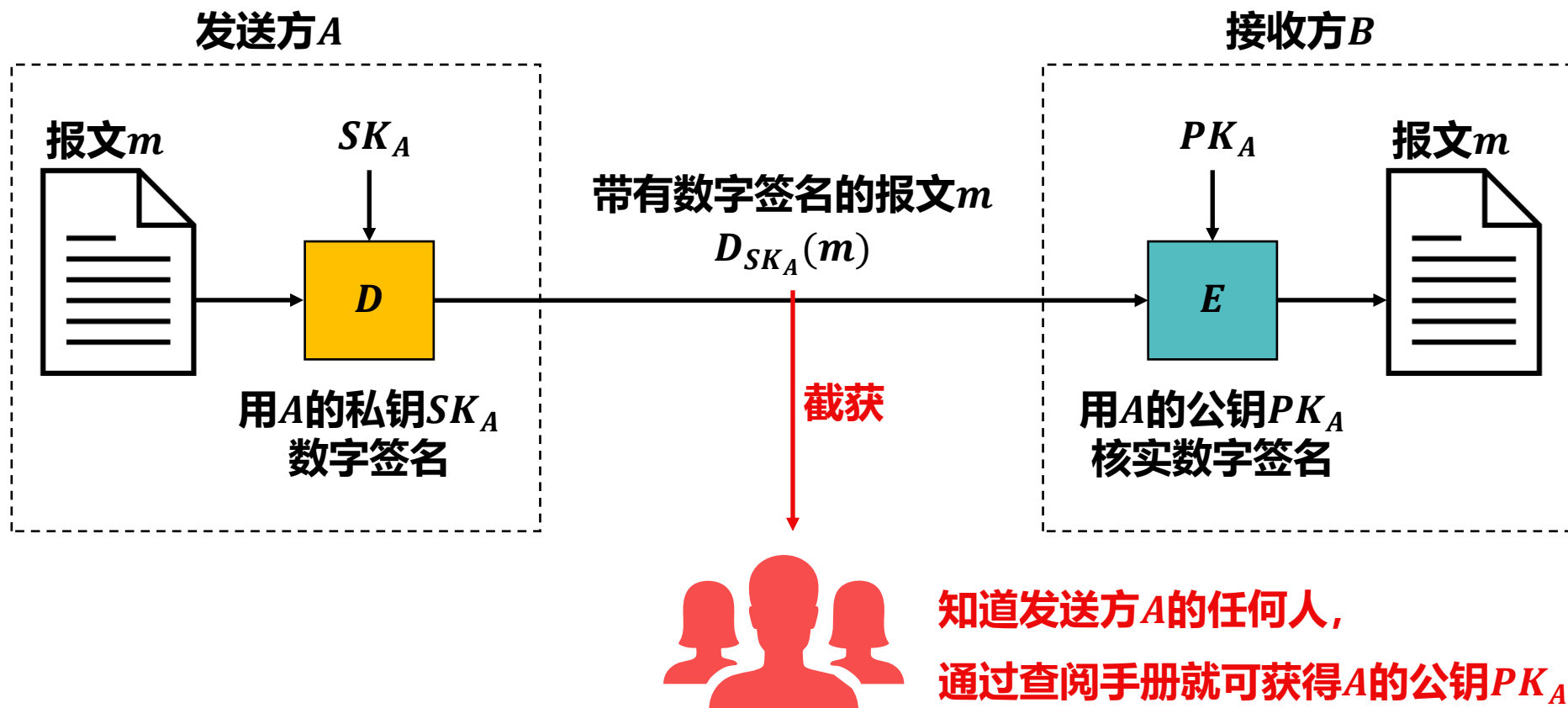
如果A要抵赖曾发送报文 m 给B，B可以把报文 m 和带有数字签名的报文 $D_{SK_A}(m)$ 出具给第三方。第三方很容易用A的公钥 PK_A 去证实A确实发送过报文 m 给B。

反之，若B把报文 m 伪造成 m' ，则B不能在第三方前出示带有数字签名的报文 $D_{SK_A}(m')$ ，因为B不可能具有A的私钥 SK_A 。这样就证明B伪造了报文。

很显然，数字签名实现了对报文来源的鉴别。

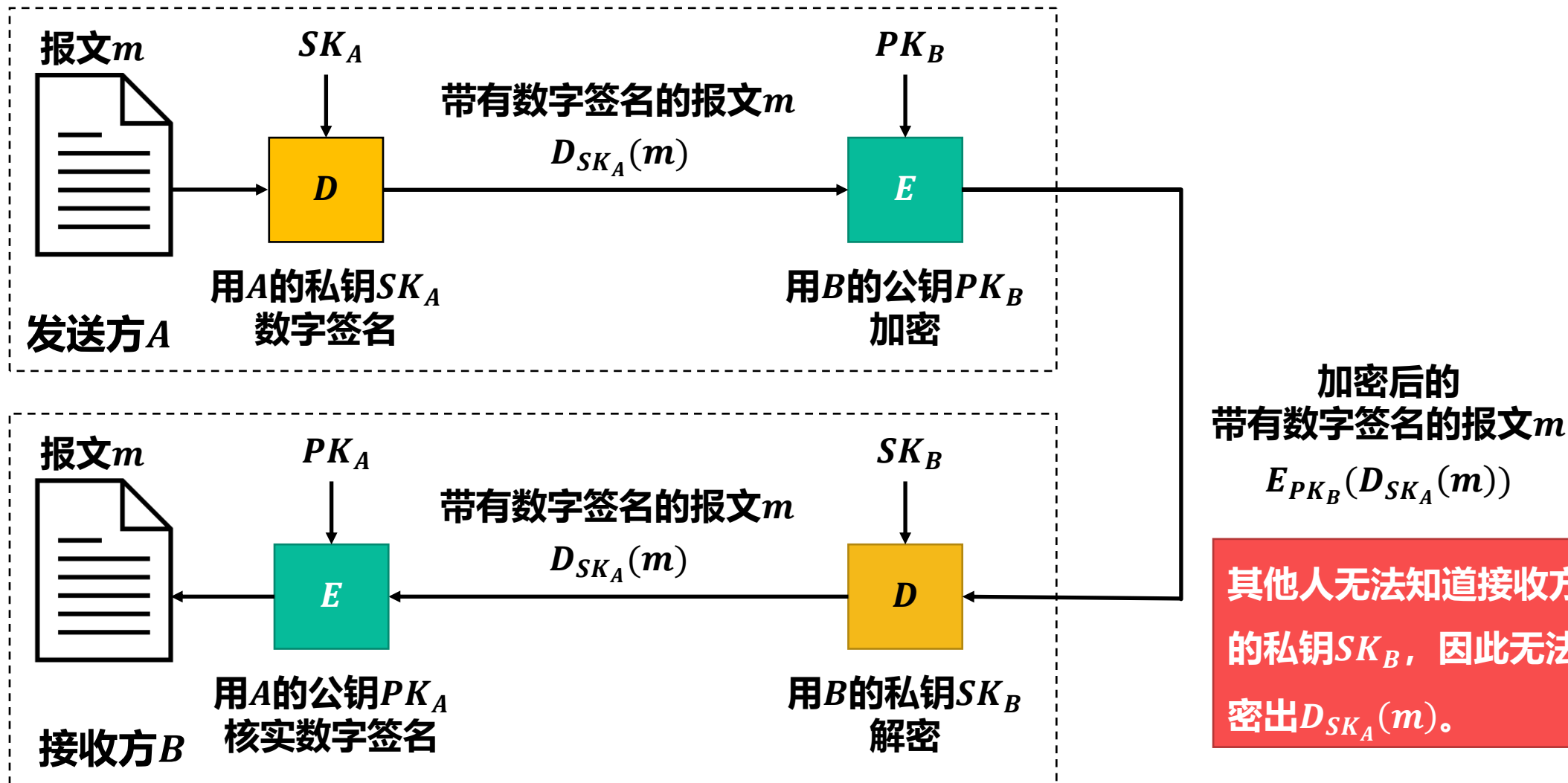
需要说明的是，由于公钥密码算法的计算代价非常高，对整个报文进行数字签名是一件非常耗时的事情，更有效的方法是仅对报文摘要进行数字签名。

03 具有保密性的数字签名



$$E_{PK_A}(D_{SK_A}(m)) = m$$

03 具有保密性的数字签名



7.4 实体鉴别

01

实体鉴别

01 实体鉴别

■ 实体鉴别就是**通信双方的一方验证另一方身份的技术**，常简称为鉴别。

☐ 实体可以是人、客户进程或服务器进程。

■ 下面仅介绍如何鉴别通信对端实体的身份，也就是**验证通信的对方**确实是所要通信的实体，而**不是其他伪装者**。

■ **通信实体的鉴别**通常是两个通信实体之间传输实际数据之前或进行访问控制之前的**必要过程**，这是很多安全协议的重要组成部分。

■ 实体鉴别的最简单方法就是使用用户名和口令。为了应对用户名和口令被攻击者截获的安全威胁，需要对用户名和口令进行加密。



01 实体鉴别

■ 实体鉴别就是**通信双方的一方验证另一方身份的技术**，常简称为鉴别。

□ 实体可以是人、客户进程或服务器进程。

■ 下面仅介绍如何鉴别通信对端实体的身份，也就是**验证通信的对方**确实是所要通信的实体，而**不是其他伪装者**。

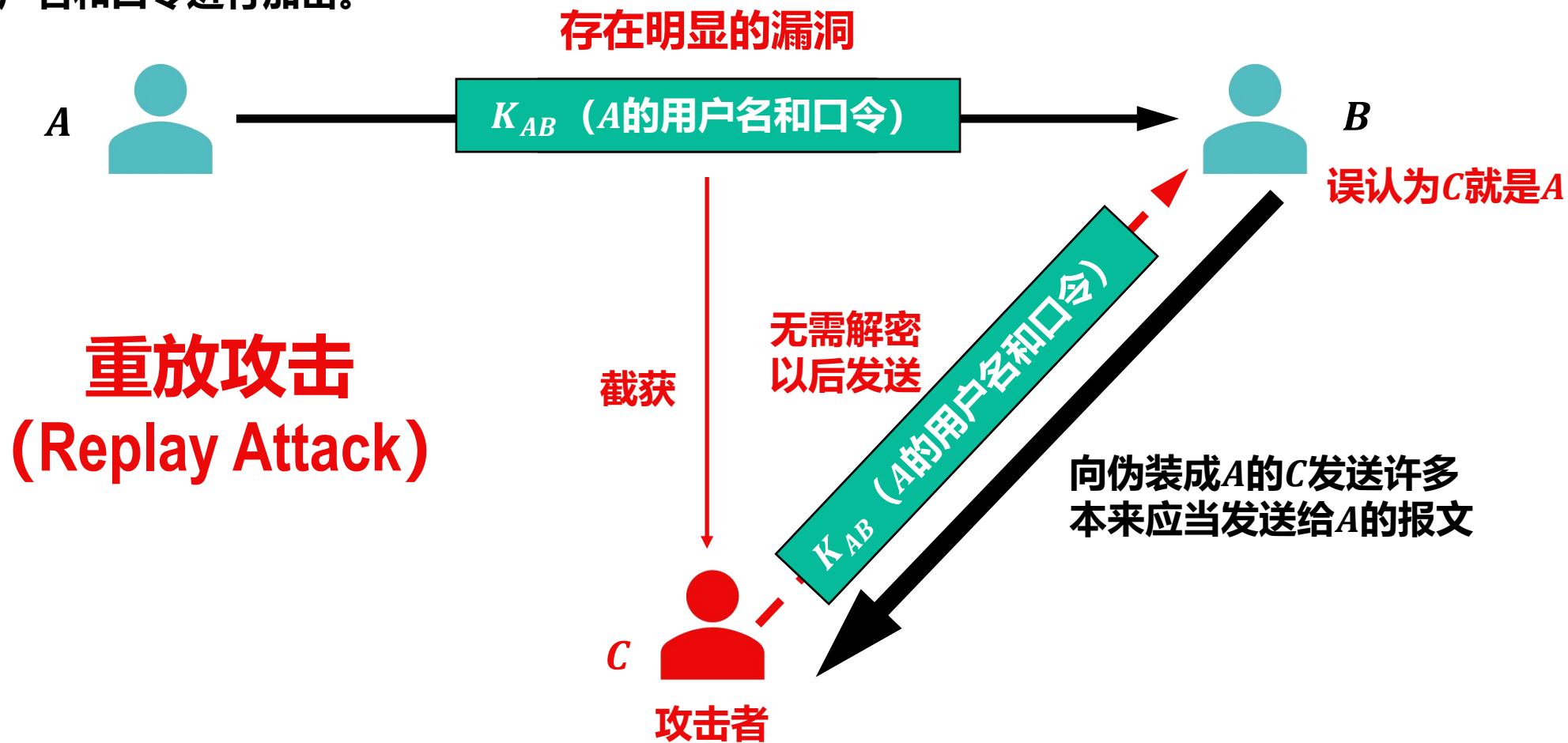
■ **通信实体的鉴别**通常是两个通信实体之间传输实际数据之前或进行访问控制之前的**必要过程**，这是很多安全协议的重要组成部分。

■ 实体鉴别的最简单方法就是使用用户名和口令。为了应对用户名和口令被攻击者截获的安全威胁，需要对用户名和口令进行加密。



01 实体鉴别

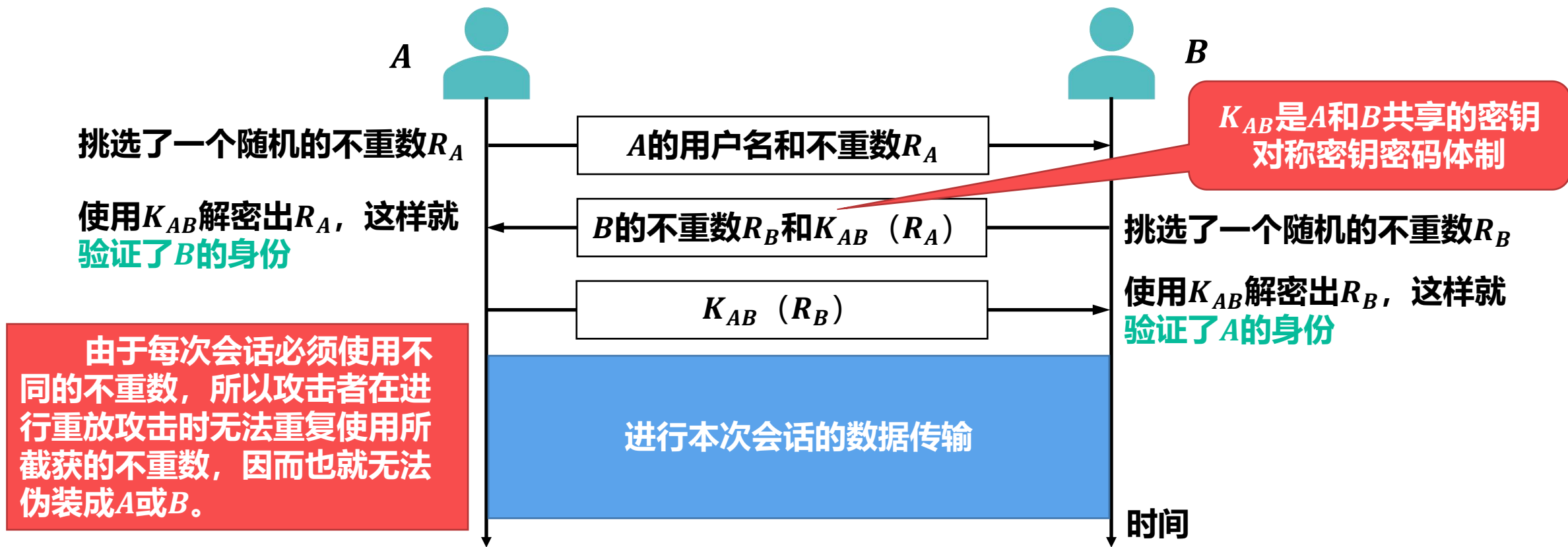
■ 实体鉴别的最简单方法就是使用用户名和口令。为了应对用户名和口令被攻击者截获的安全威胁，需要对用户名和口令进行加密。



01 实体鉴别

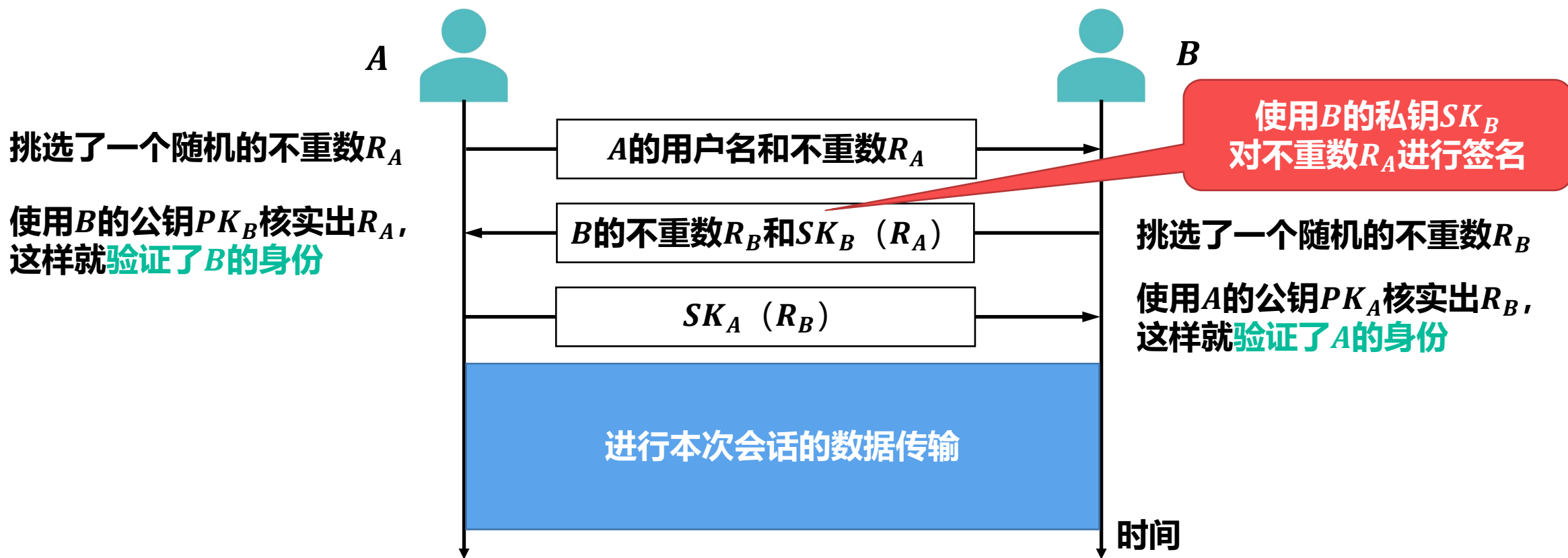
为了应对重放攻击，可以使用**不重数**（nonce）。所谓“不重数”，就是指一个不重复使用的大随机数。

在实体鉴别过程中，**不重数**可以使用户把重复的实体鉴别请求和新的实体鉴别请求区分开。



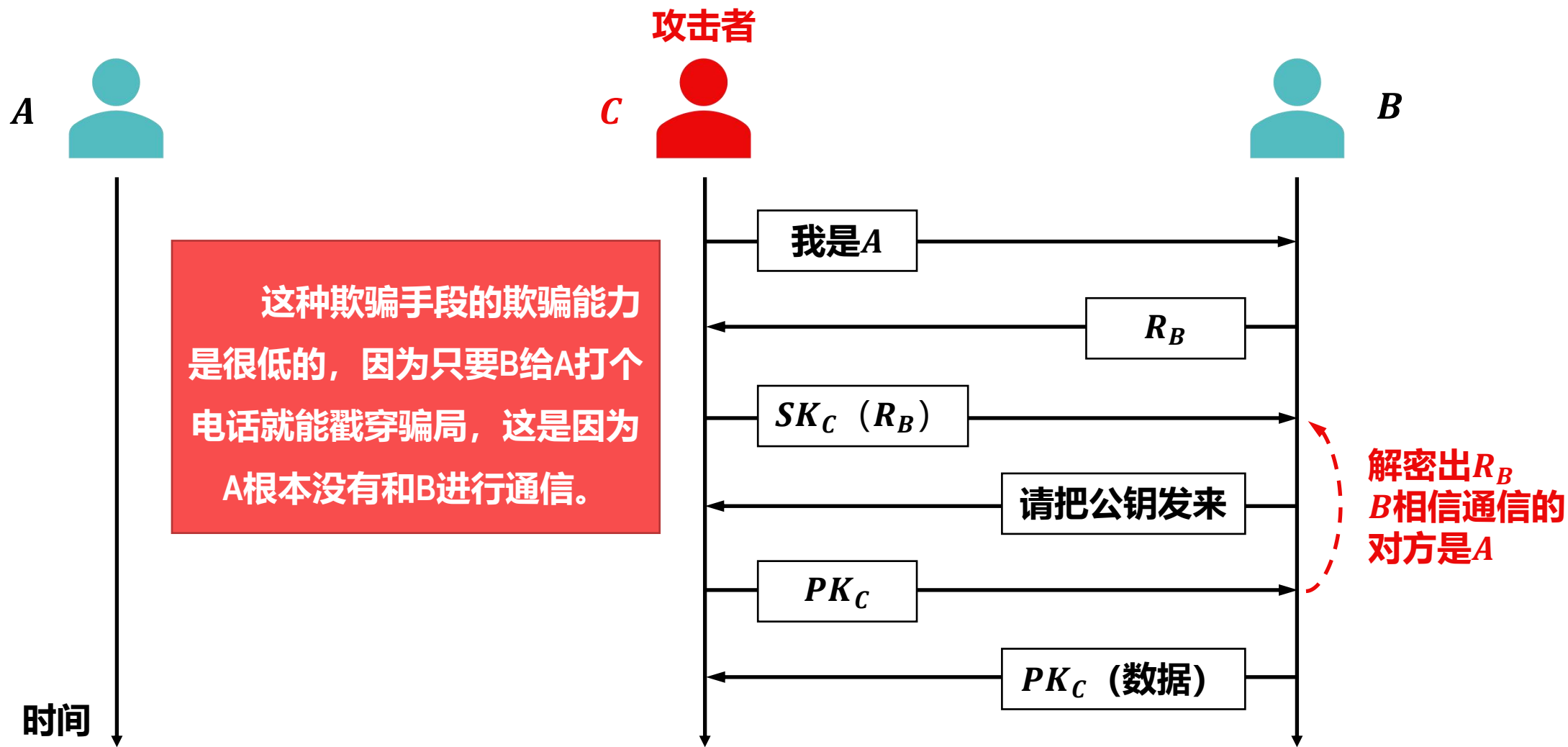
01 实体鉴别

■ 使用公钥密码体制也可以实现实体鉴别。



01 实体鉴别

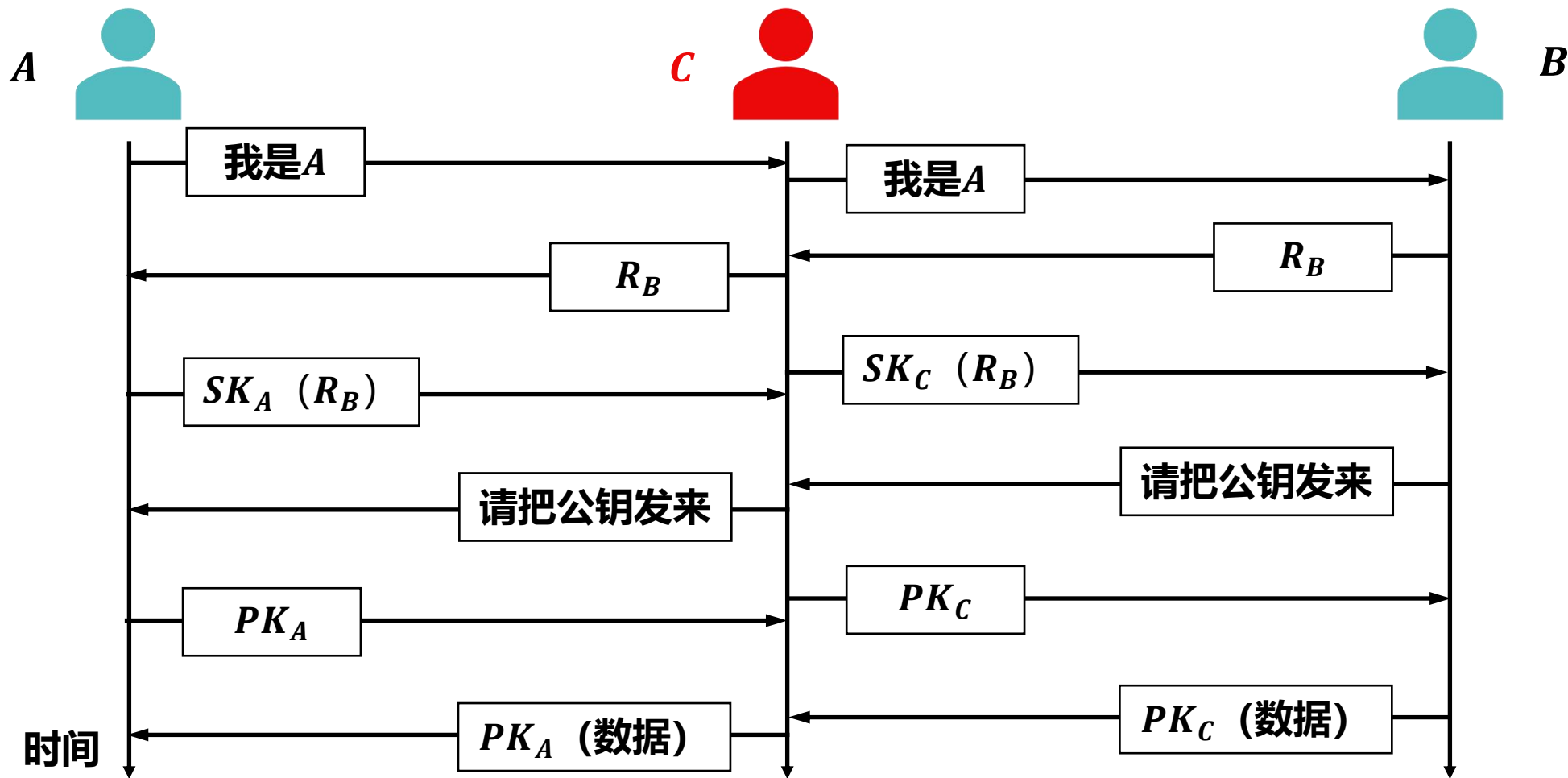
使用公钥密码体制在实现实体鉴别时，仍有受到攻击的可能。



01 实体鉴别

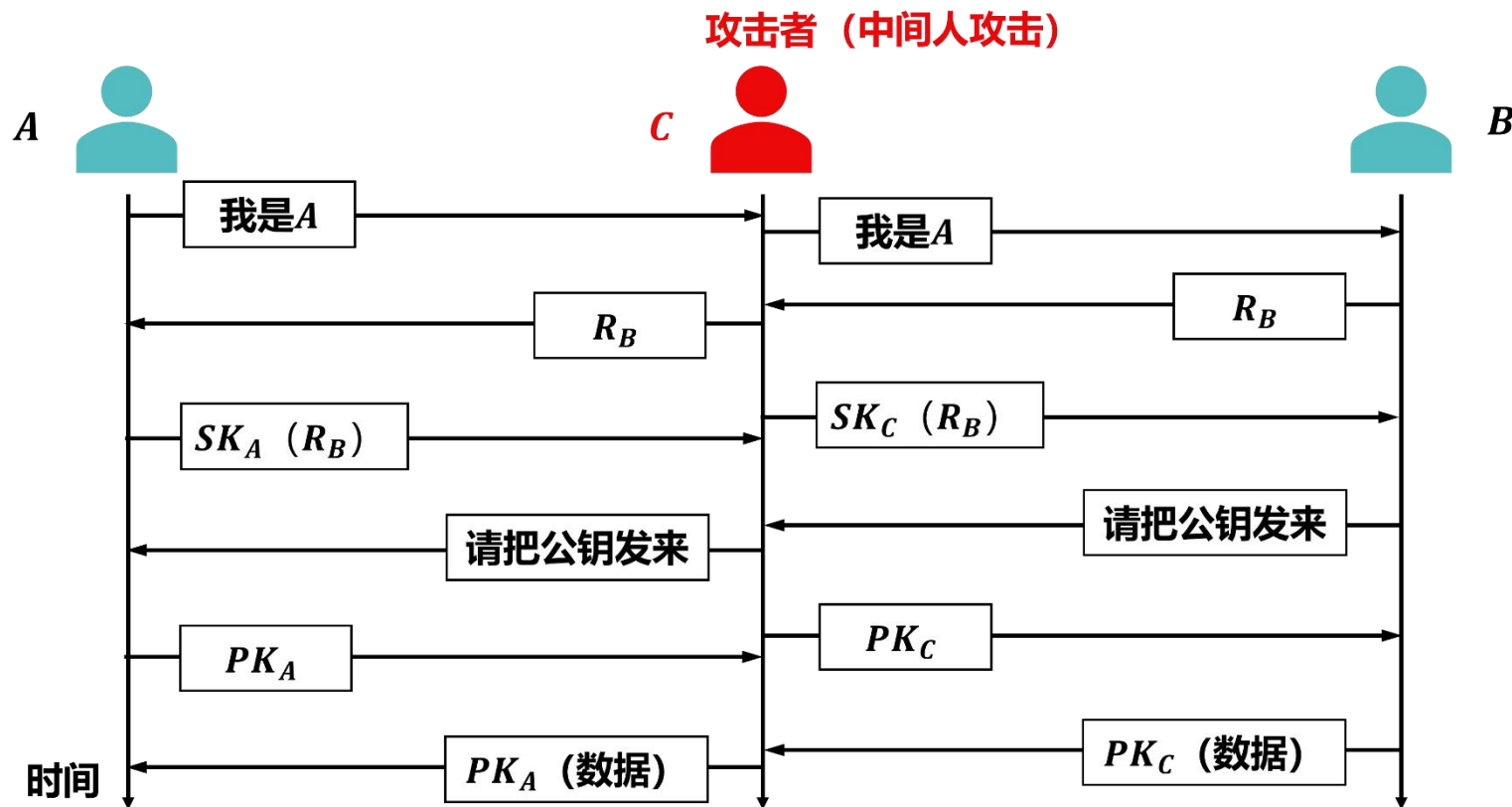
使用公钥密码体制在实现实体鉴别时，仍有受到攻击的可能。

攻击者（中间人攻击）



01 实体鉴别

使用公钥密码体制在实现实体鉴别时，仍有受到攻击的可能。



通过本例可以看出，公钥的分发以及公钥真实性的认证也是一个非常重要的问题。

7.5 密钥分发

01

密钥分发的相关概念

02

对称密钥的分发

03

公钥的分发

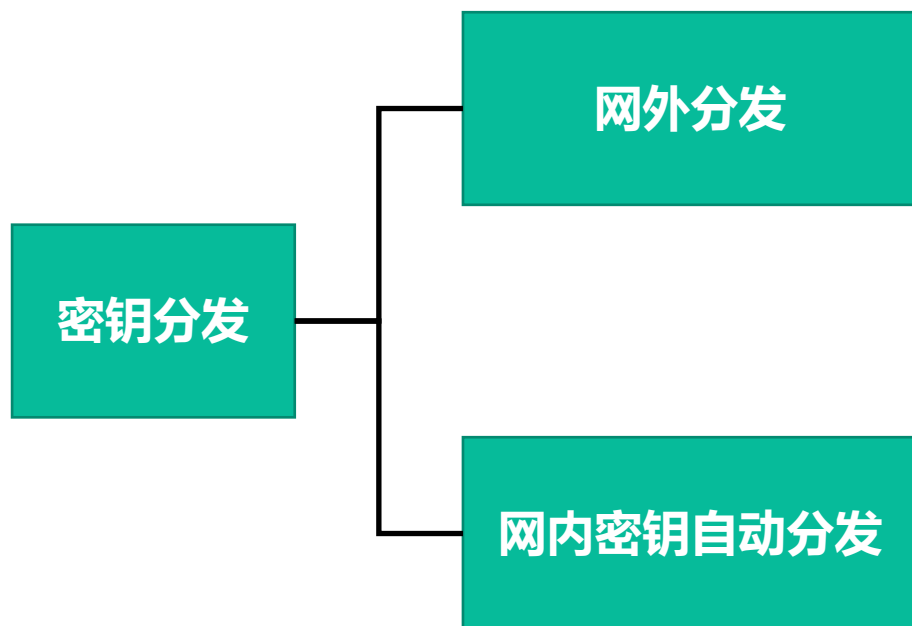
01 密钥分发的相关概念

■ 在**对称密钥密码体制**中，**通信双方共享的密钥是需要保密的**。

■ 在**公钥密码体制**中，公钥是公开的，但**私钥仍然需要保密**。

■ **密钥分发**是密钥系统中一个非常重要的问题。密钥必须通过安全的通路进行分发。

密钥系统的安全性完全依赖于
对密钥的安全保护！



可以通过非常可靠的信使携带密钥分发给相互通信的各用户。
密钥必须定期更换才能确保可靠。
随着网络用户的增多，这种分发密钥的方法不再适用。

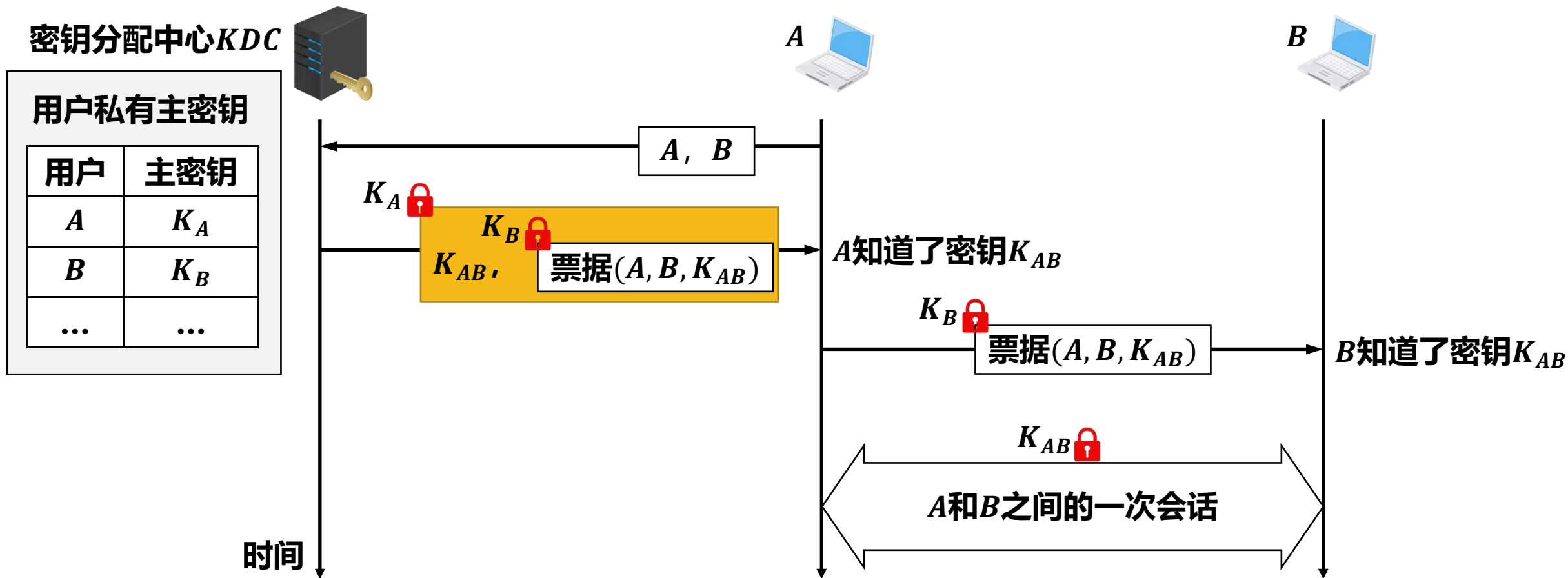
通过网络自动分发密钥。

02 对称密钥的分发

- 对于对称密钥密码体制，目前常用的密钥分发方式是建立**密钥分配中心**（Key Distribution Center, **KDC**）。
- **KDC**是一个公众都信任的机构，其**任务就是给需要进行秘密通信的用户临时分配一个会话密钥**。

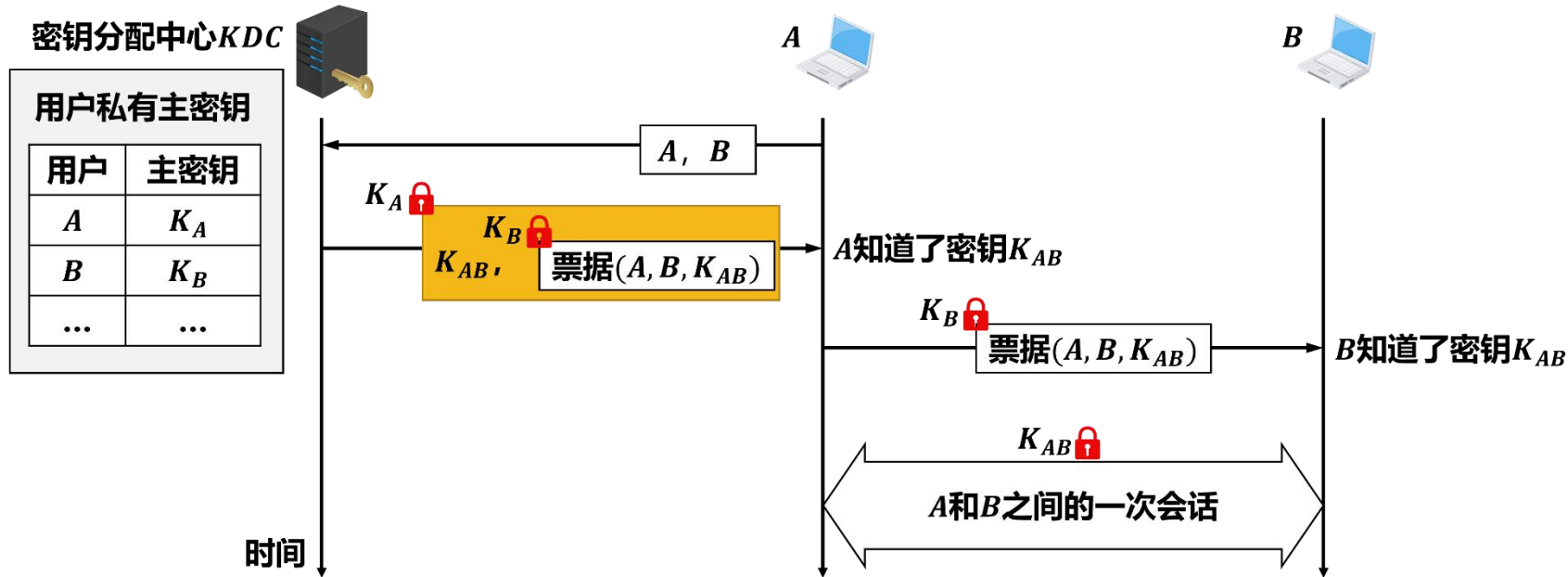
02 对称密钥的分发

【举例】假设用户A和B都是KDC的登记用户，他们在KDC登记时就分别拥有了与KDC通信的主密钥 K_A 和 K_B 。用户A和B通过KDC安全获得他们之间共享的、用于一次会话的密钥 K_{AB} 的过程如下。



02 对称密钥的分发

【举例】假设用户A和B都是KDC的登记用户，他们在KDC登记时就分别拥有了与KDC通信的主密钥 K_A 和 K_B 。用户A和B通过KDC安全获得他们之间共享的、用于一次会话的密钥 K_{AB} 的过程如下。

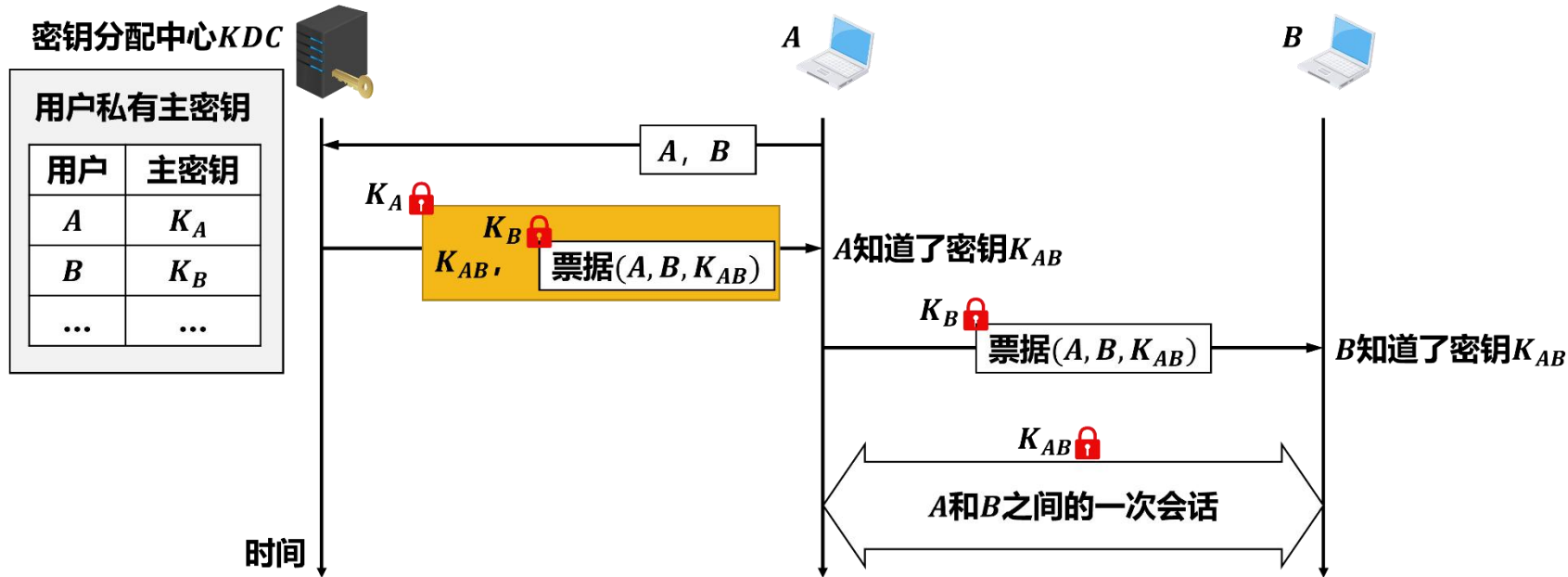


请同学们注意：

- ① 在网络上传送的密钥都是用于加密的密钥，并且需要加密后才能传送。解密用的密钥都不在网上传送。
- ② KDC分配给用户的主密钥（例如上述例子中的 K_A 和 K_B ）应当定期更换以减少攻击者破译密钥的机会。
- ③ KDC可以在报文中加入时间戳，以防止报文的截获者利用之前已记录下的报文进行重放攻击。

02 对称密钥的分发

【举例】假设用户A和B都是KDC的登记用户，他们在KDC登记时就分别拥有了与KDC通信的主密钥 K_A 和 K_B 。用户A和B通过KDC安全获得他们之间共享的、用于一次会话的密钥 K_{AB} 的过程如下。



由美国麻省理工学院MIT开发出的Kerberos，是目前最出名的密钥分发协议[RFC 1510]。有兴趣的同学可自行查阅。

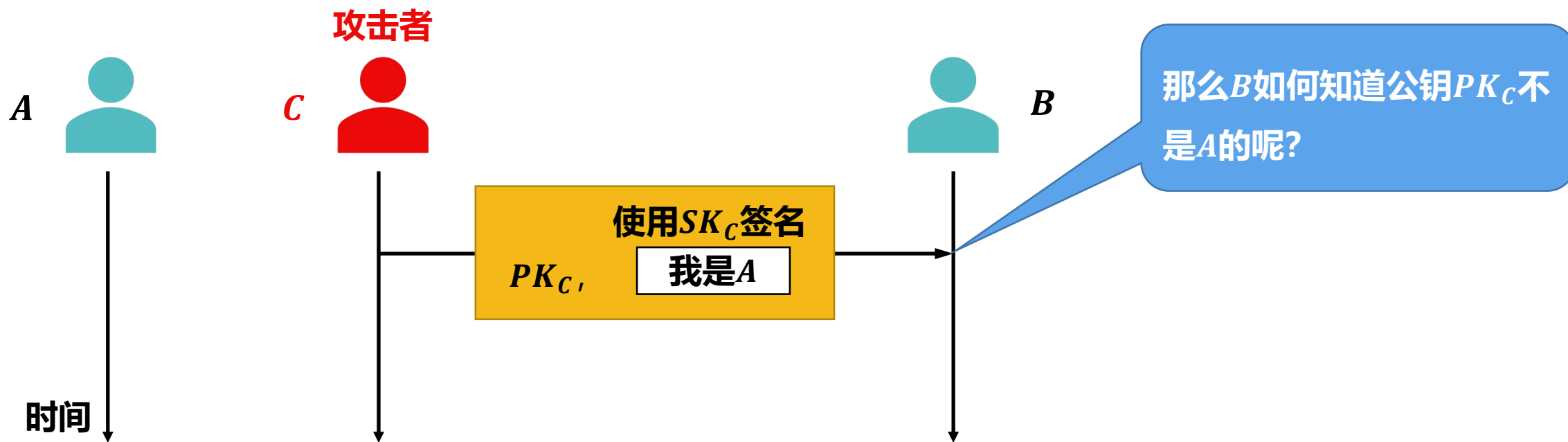
03 公钥的分发

■ 公钥密码体制中的**公钥是公开的**，而**私钥是用户私有的**（保密的）。

■ 如果每个用户都知道其他用户的公钥，用户之间就可以实现安全通信。

□ 然而，如果通过网络来随意公布用户的公钥，会面临极大的安全风险。

【举例】



03 公钥的分发

- 公钥密码体制中的**公钥是公开的**，而**私钥是用户私有的**（保密的）。
- 如果每个用户都知道其他用户的公钥，用户之间就可以实现安全通信。
 - ☐ 然而，如果通过网络来随意公布用户的公钥，会面临极大的安全风险。
 - ☐ 因此，需要有一个值得信赖的机构**将公钥与其对应的实体（人或机器）进行绑定**（binding）。这种机构被称为**认证中心**（Certification Authority, CA），一般由政府出资建立。
- 需要发布公钥的用户可以让CA为其公钥签发一个**证书**（Certification），证书中**包含有公钥及其拥有者的身份标识信息**（人名、公司名或IP地址等）。

03 公钥的分发

■ CA签发证书的过程如下：

- ① CA必须核实用户真实身份；
- ② CA为用户产生公钥-私钥对，并生成证书；
- ③ CA用自己的私钥对证书进行数字签名。
- ④ 该证书就可以通过网络发送给任何希望与该证书拥有者通信的实体，也可将该证书存放在服务器由其他用户自由下载。

请同学们注意：

- ① CA为用户产生的公钥-私钥对中的私钥，必须由证书拥有者自己秘密保存。
- ② 任何人都可从可信的地方（例如代表政府的报纸）获取CA自身的公钥，并用这个公钥来验证某个证书是否是该CA签发的真实证书。一旦证书被鉴别是真实的，则可以相信证书中的公钥确实属于证书中声称的用户。

03 公钥的分发

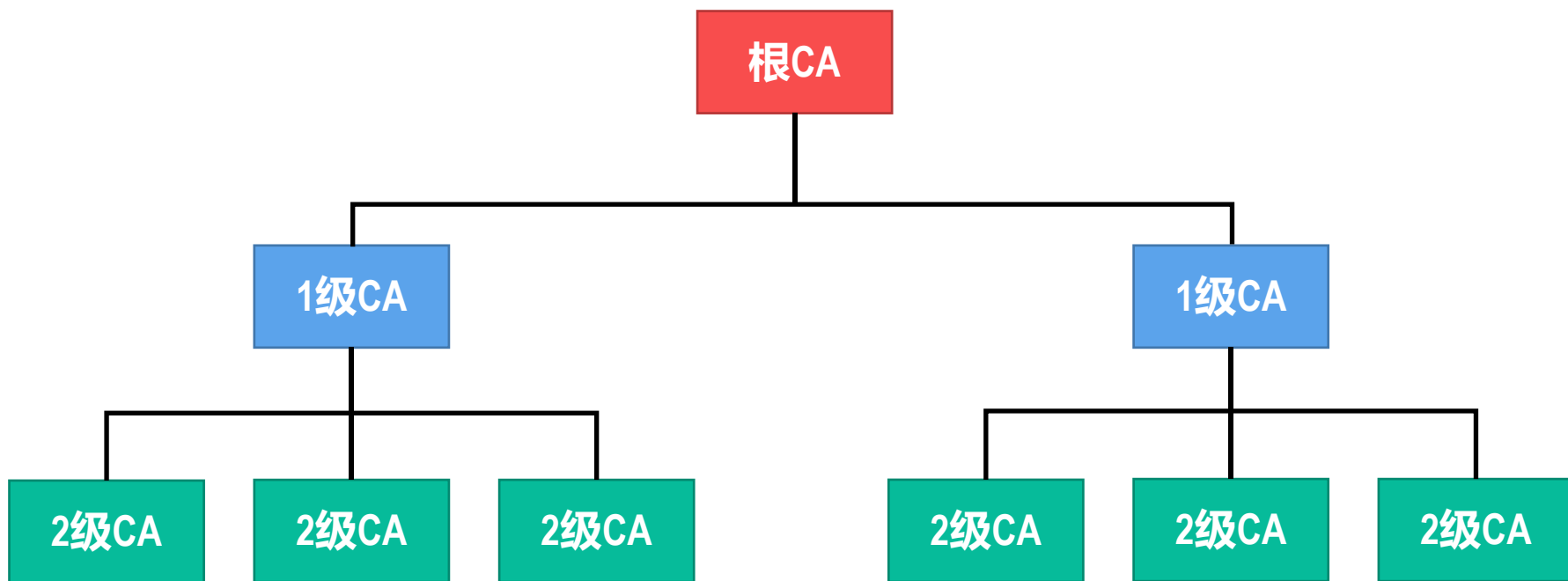


**请同学们在自己电脑系统中查看都安装
有哪些证书，它们的发证机构信息是什么？**

03 公钥的分发

■ 如果全世界**仅使用一个CA来签发证书**，则会出现**负载过重**和**单点故障**等问题。

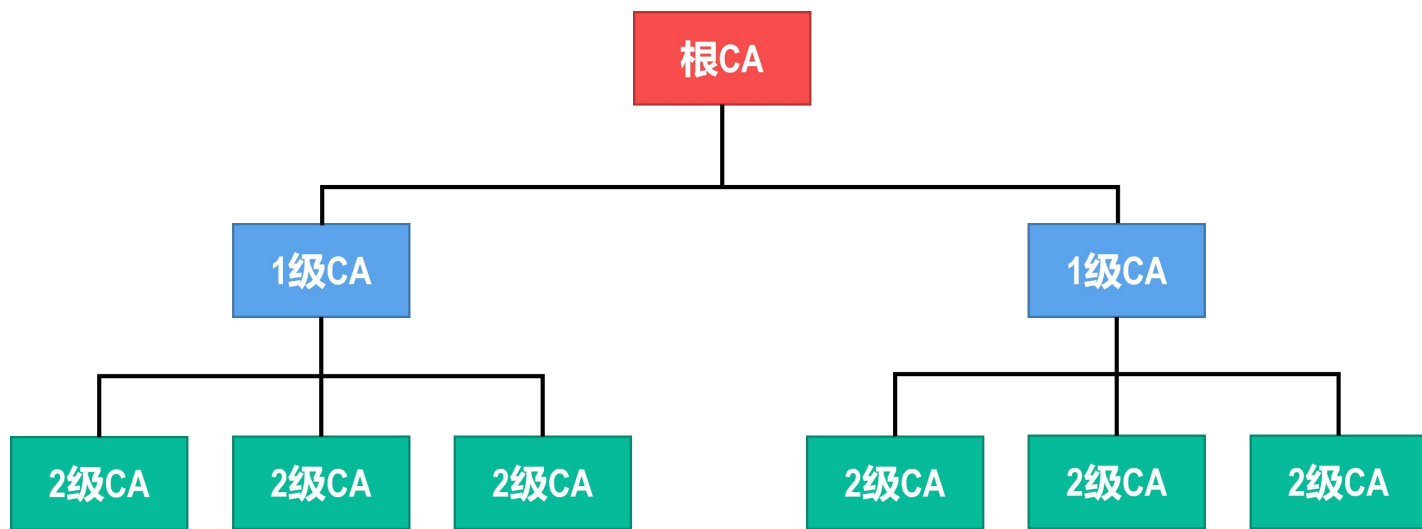
■ 因特网采用的是[RFC 5280]（现在是建议标准）给出的、在全球范围内为所有因特网用户提供证书签发与认证服务的**公钥基础结构**（Public Key Infrastructure, **PKI**）。



03 公钥的分发

■ 因特网采用的是[RFC 5280]（现在是建议标准）给出的、在全球范围内为所有因特网用户提供证书签发与认证服务的**公钥基础结构**（Public Key Infrastructure, PKI）。

- ☐ 下级CA的证书由上级CA签发和认证。
- ☐ 所有用户都信任顶级的根CA，但可以信任也可以不信任中间的CA。
- ☐ 用户可以在自己信任的CA获取个人证书，当要验证来自不信任CA签发的证书时，需要到上一级CA验证该证书的真伪，如果上一级CA也不可信则需要到更上一级CA进行验证，一直追溯到可信任的一级CA，这一过程最终有可能会追溯到顶级的根CA。



7.6 访问控制

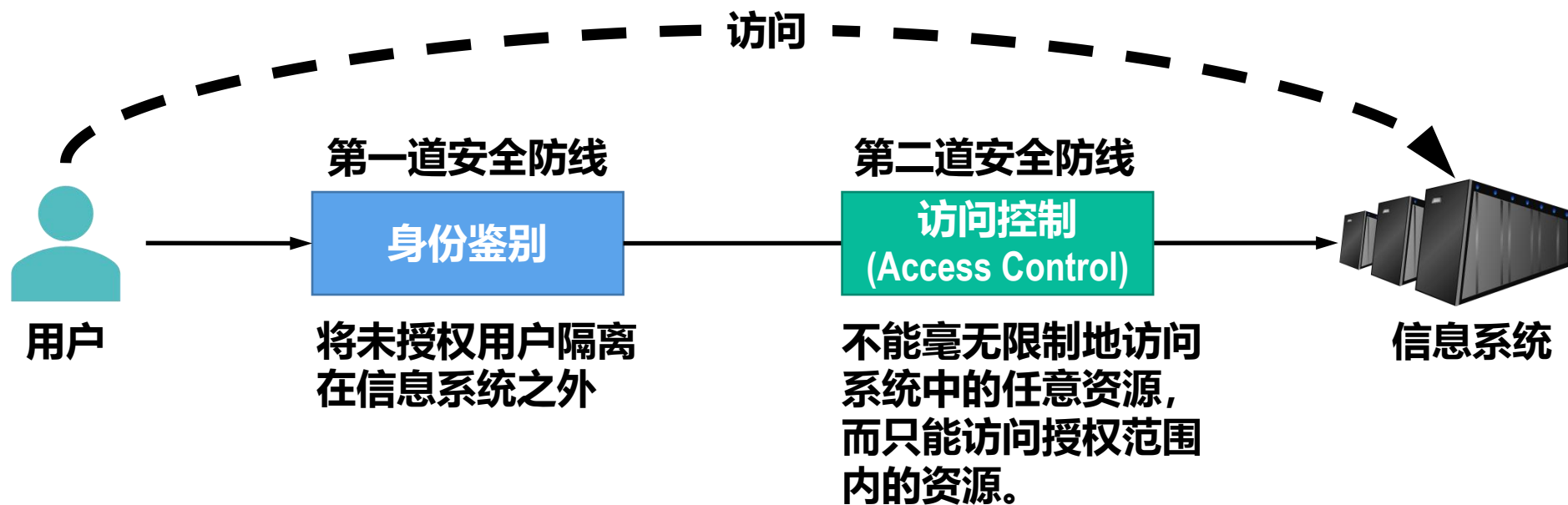
01

访问控制的基本概念

02

三类典型的访问控制策略

01 访问控制的基本概念



■ 对合法用户访问权限的授予一般遵循**最小特权原则**。

- ☐ 最小特权是指能够满足用户完成工作所需的权限，**用户不会被赋予超出其实际需求的权限。**
- ☐ 最小特权原则可以**有效防范合法用户滥用权限所带来的安全风险。**

01 访问控制的基本概念

访问控制包含以下基本要素：

主体

访问活动的发起者，可以是某个用户，也可以是代表用户执行操作的进程、服务和设备等。

客体

访问活动中被访问的对象，凡是可以被操作的信息、文件、设备、服务等资源都可以认为是客体。

访问

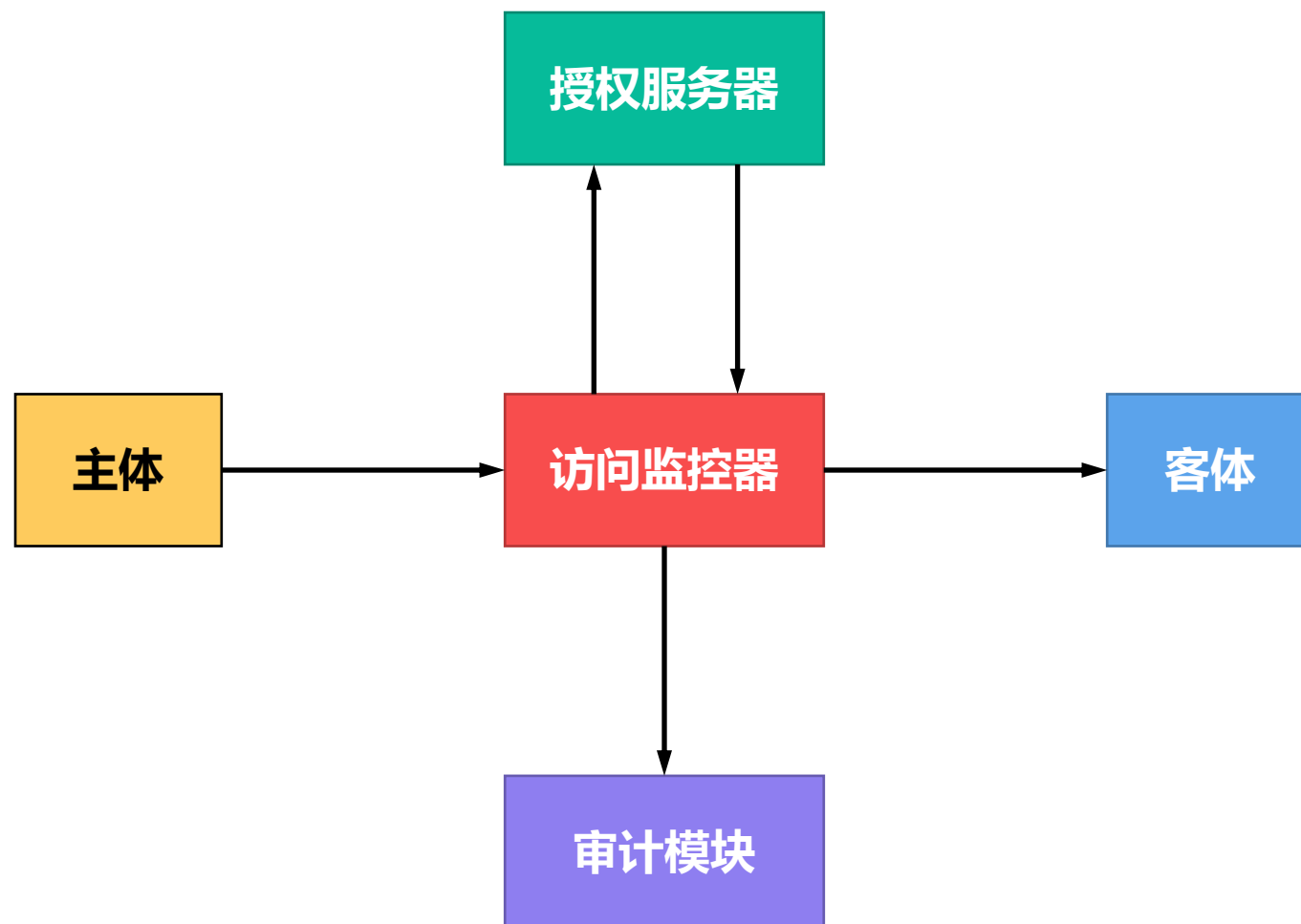
主体对客体的各种操作类型。例如创建、读取、修改、删除、执行、发送、接收等操作。不同的系统有不同的访问类型。

访问策略

访问控制的核心，访问控制根据访问策略限制主体对客体的访问。访问控制策略可用三元组（S、O、P）来描述，其中S表示主体，O表示客体，P表示许可（Permission）。许可P明确了允许主体S对客体O所进行的访问类型。访问策略通常存储在系统的授权服务器中。

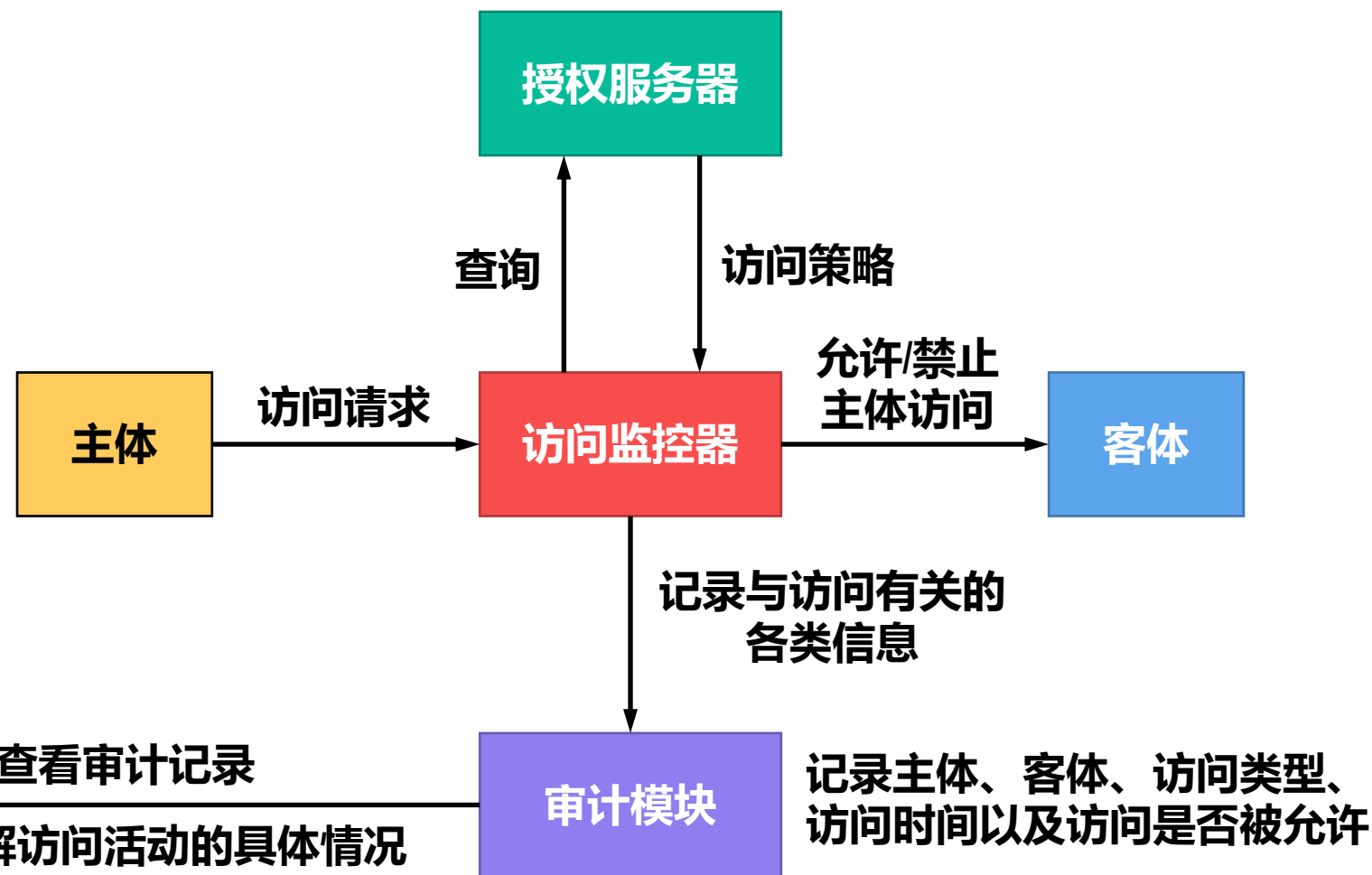
01 访问控制的基本概念

著名的访问监控器（Reference Monitor）模型



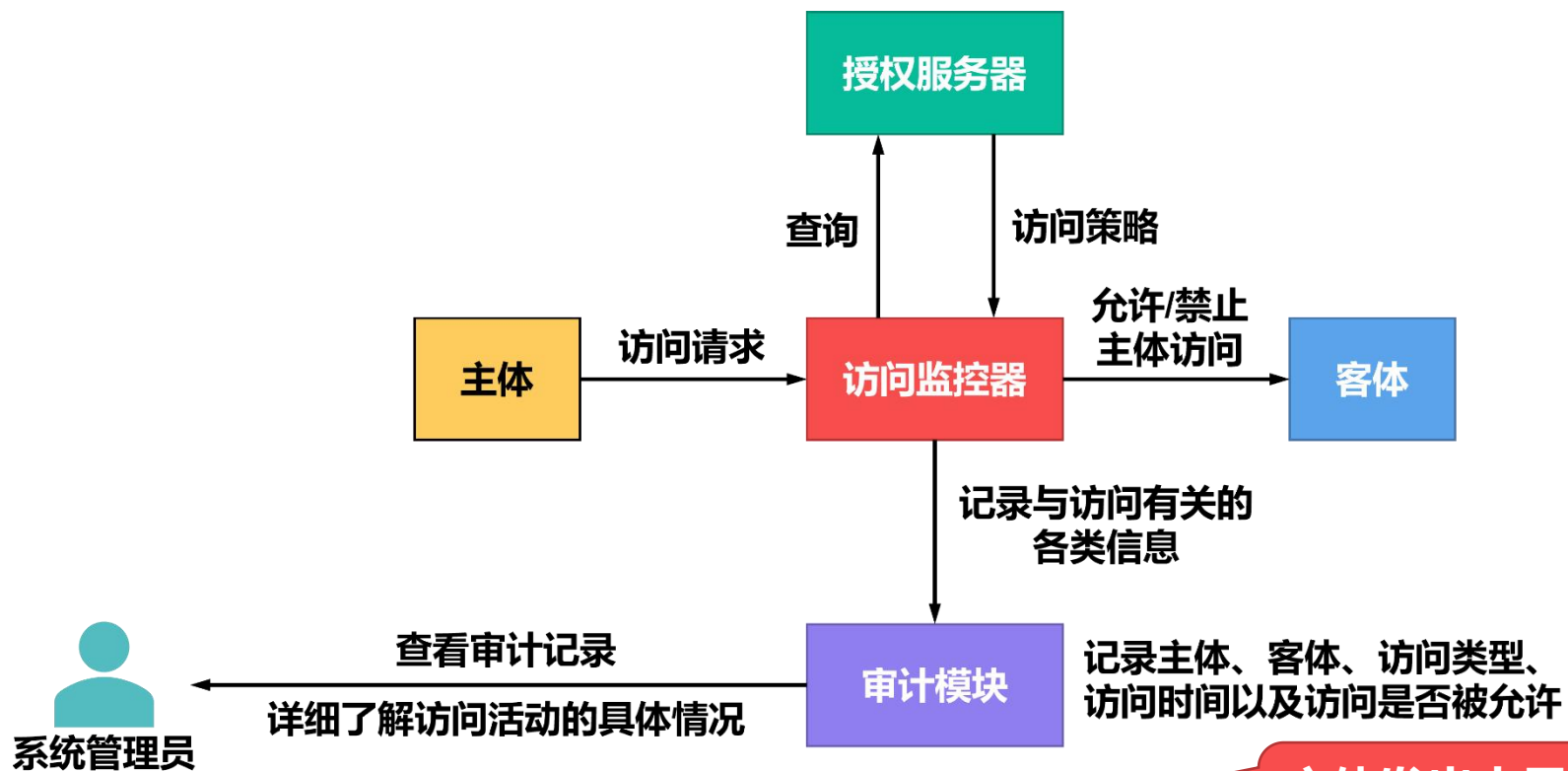
01 访问控制的基本概念

著名的访问监控器（Reference Monitor）模型



01 访问控制的基本概念

著名的访问监控器（Reference Monitor）模型

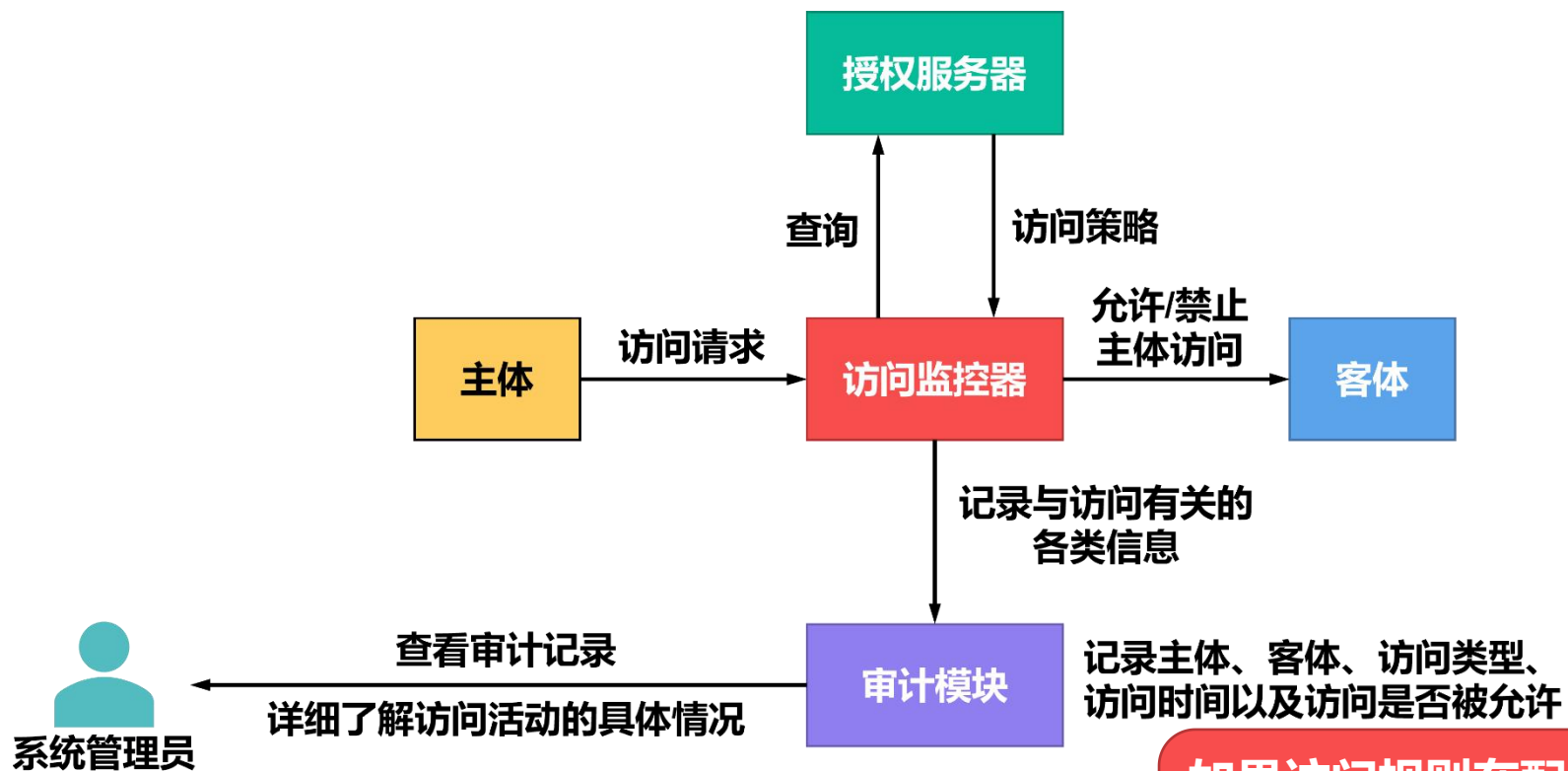


- 哪些主体对哪些资源的访问请求被拒绝。
- 访问策略是否得到了严格执行。
- 提供访问活动的证据，为事后追查和追责提供依据。

主体发出大量违规的访问请求，这往往是攻击和破坏活动的征兆，需要引起特别的关注。

01 访问控制的基本概念

著名的访问监控器（Reference Monitor）模型



- 哪些主体对哪些资源的访问请求被拒绝。
- 访问策略是否得到了严格执行。
- 提供访问活动的证据，为事后追查和追责提供依据。

如果访问规则在配置或执行过程中存在失误，一些违反访问策略的访问请求可能被许可。通过查看审计记录可以发现此类情况，以便及时修正。

02 三类典型的访问控制策略

自主访问控制策略
(Discretionary Access Control, DAC)

强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

02 三类典型的访问控制策略

自主访问控制策略
(Discretionary Access Control, DAC)

强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

■ DAC策略中“自主”的意思是**客体的拥有者可以自主地决定其他主体对其拥有的客体所进行访问的权限。**

☐ 优点：具有很强的灵活性

☐ 缺点：权限管理过于分散，容易出现漏洞，并且无法有效地控制被攻击主体破坏系统安全性的行为。

■ 木马程序利用自主访问控制策略的上述缺点，可以很容易地破坏系统的安全性。

02 三类典型的访问控制策略

自主访问控制策略
(Discretionary Access Control, DAC)

强制访问控制策略
(Mandatory Access Control, MAC)

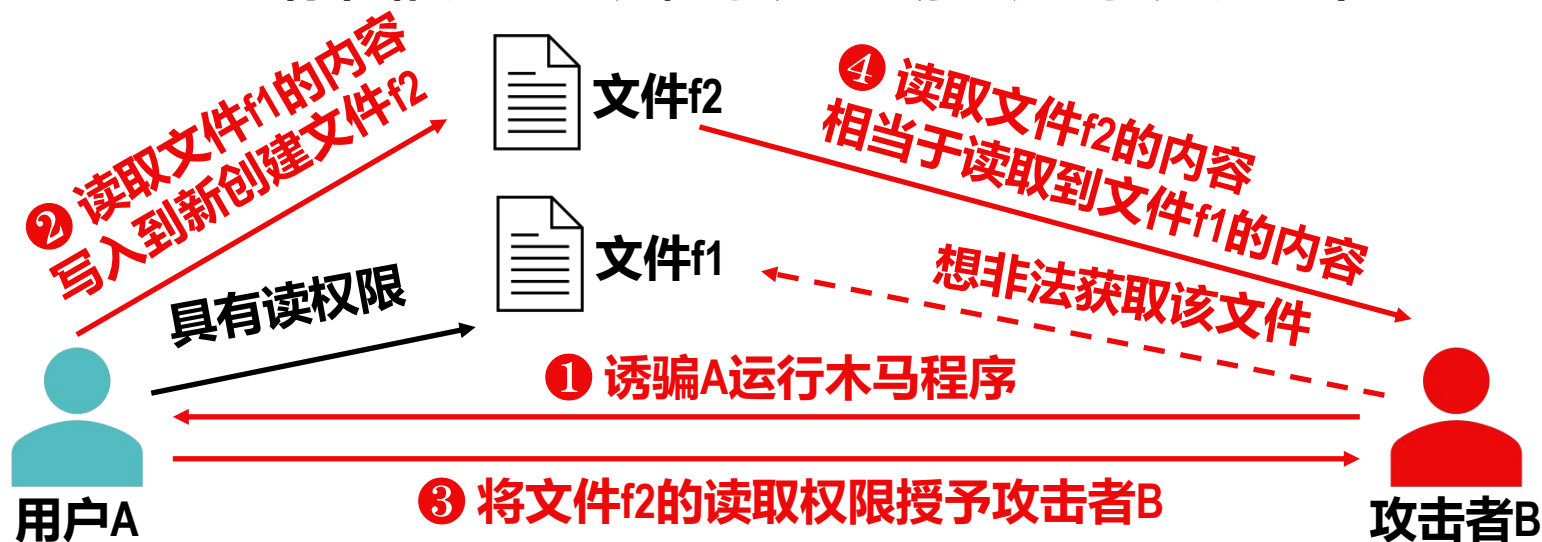
基于角色的访问控制策略
(Role Based Access Control, RBAC)

■ DAC策略中“自主”的意思是**客体的拥有者可以自主地决定其他主体对其拥有的客体所进行访问的权限。**

□ 优点：具有很强的灵活性

□ 缺点：权限管理过于分散，容易出现漏洞，并且无法有效地控制被攻击主体破坏系统安全性的行为。

■ 木马程序利用自主访问控制策略的上述缺点，可以很容易地破坏系统的安全性。



02 三类典型的访问控制策略

自主访问控制策略
(Discretionary Access Control, DAC)

强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

■ DAC策略中“自主”的意思是**客体的拥有者可以自主地决定其他主体对其拥有的客体所进行访问的权限。**

☐ 优点：具有很强的灵活性

☐ 缺点：权限管理过于分散，容易出现漏洞，并且无法有效地控制被攻击主体破坏系统安全性的行为。

■ 木马程序利用自主访问控制策略的上述缺点，可以很容易地破坏系统的安全性。

■ **自主访问控制策略**的最大特点是“自主”，也就是资源的拥有者对资源的访问策略具有决策权，因此是一种**限制比较弱的访问控制策略**。这种访问控制策略**给用户带来灵活性的同时，也带来了安全隐患。**

02 三类典型的访问控制策略

自主访问控制策略
(Discretionary Access Control, DAC)

强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

■ 强制访问控制策略与自主访问控制策略不同，它不允许一般的主体进行访问权限的设置。

■ 在强制访问控制策略中，主体和客体被赋予一定的安全级别。通常只有系统的安全管理员可以进行安全级别的设定，而普通用户不能改变自己或任何客体的安全级别。

☐ 系统通过比较主体和客体的安全级别来决定某个主体是否能够访问某个客体。

02 三类典型的访问控制策略

自主访问控制策略
(Discretionary Access Control, DAC)

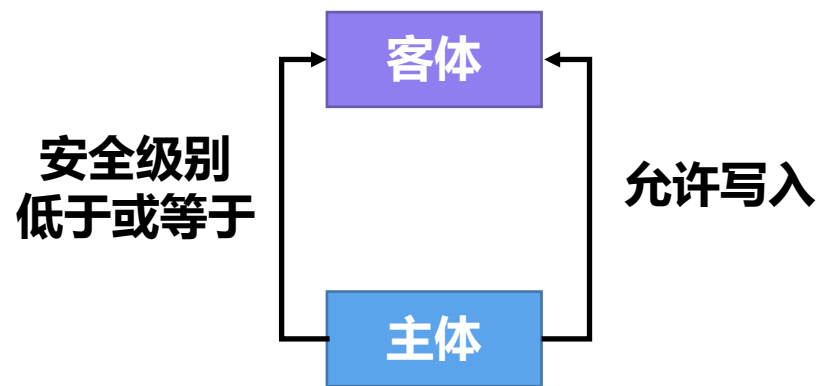
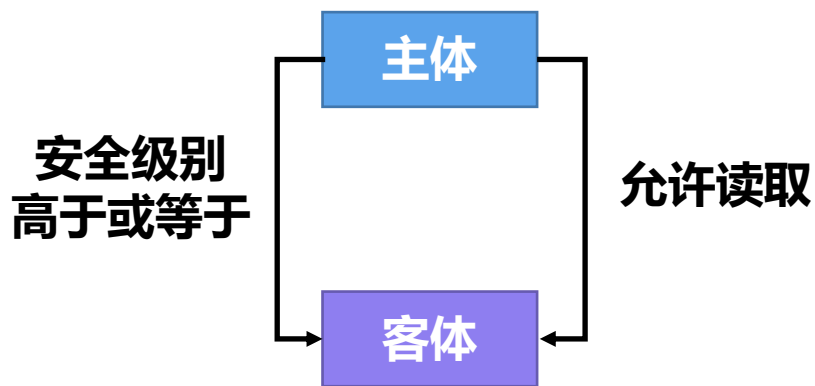
强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

在强制访问控制策略中广泛使用以下两项原则：

☐ “下读” 原则

☐ “上写” 原则



“下读”和“上写”原则限制了信息只能由低级别的对象流向高级别或同级别的对象，这样能够有效防止木马等恶意程序的窃密攻击。

02 三类典型的访问控制策略

自主访问控制策略
(Discretionary Access Control, DAC)

强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

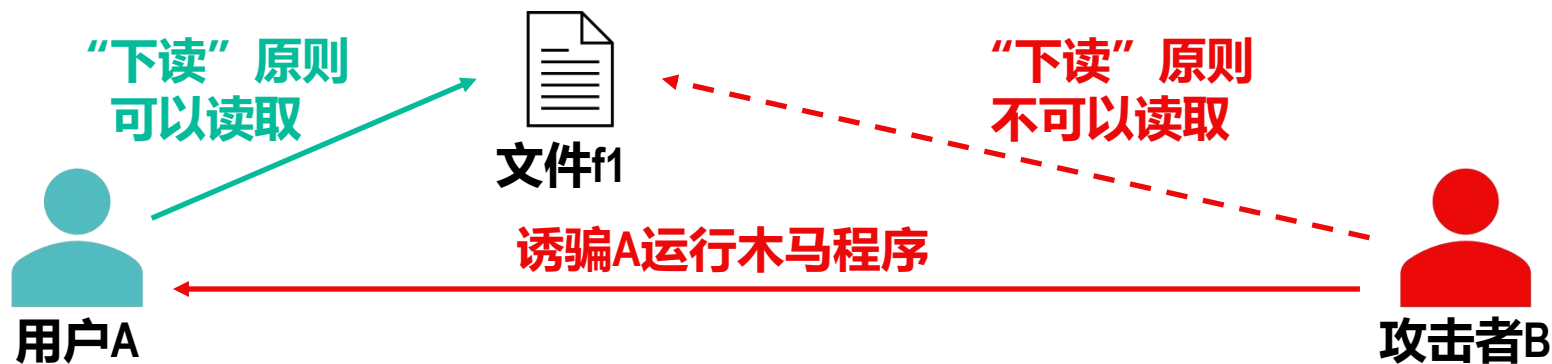
“下读”和“上写”原则限制了信息只能由低级别的对象流向高级别或同级别的对象，这样能够有效防止木马等恶意程序的窃密攻击。

木马程序具有与A同样的安全级别

- 木马程序可以读取文件f1，却不能将f1的安全级别修改成B可读的安全级别（“上写”原则）。
- 木马程序也无法将f1的内容写入到安全级别比A低的文件中（“上写”原则）。

因此，B无法通过木马程序读取到f1中的信息。

攻击者B安全级别 < 安全级别 < 用户A的安全级别



02 三类典型的访问控制策略

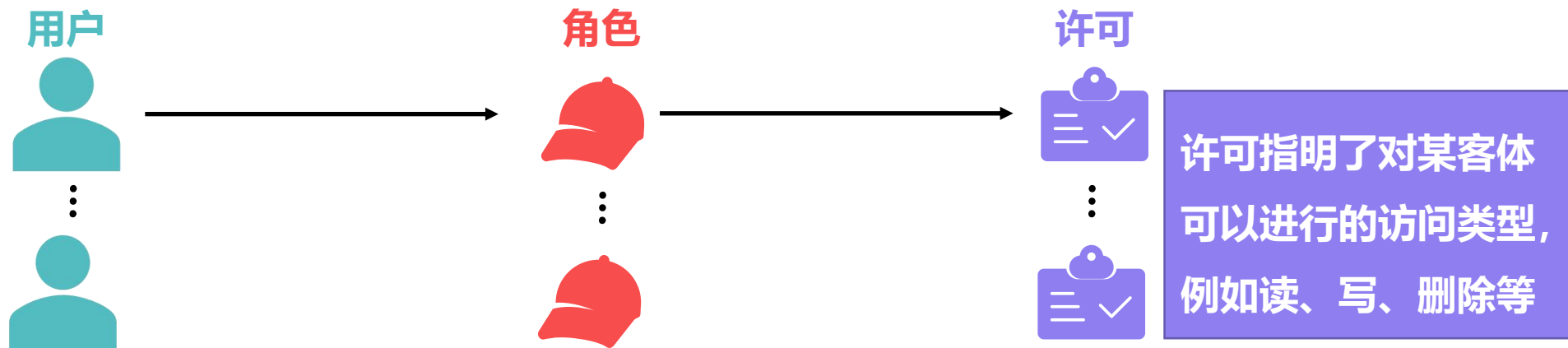
自主访问控制策略
(Discretionary Access Control, DAC)

强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

■ 基于角色的访问控制策略的核心思想是：**根据安全策略划分不同的角色，用户不再直接与许可关联，而是通过角色与许可关联。**

- ☐ 一个用户可以拥有多个角色，一个角色也可以赋予多个用户；
- ☐ 一个角色可以拥有多种许可，一种许可也可以分配给多个角色。



02 三类典型的访问控制策略

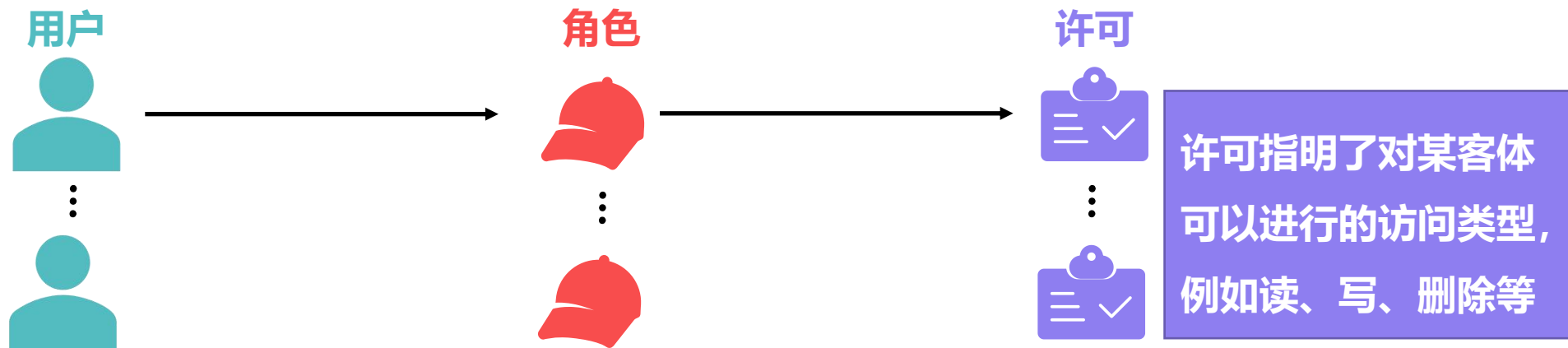
自主访问控制策略
(Discretionary Access Control, DAC)

强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

■ 基于角色的访问控制策略通过角色将用户和访问权限进行了逻辑隔离。

- 给角色配置许可的工作一般比较复杂，需要一定的专业知识，可以由专门的技术人员来完成。
- 为用户赋予角色则较为简单，可以由一般的系统管理员来完成。



02 三类典型的访问控制策略

自主访问控制策略
(Discretionary Access Control, DAC)

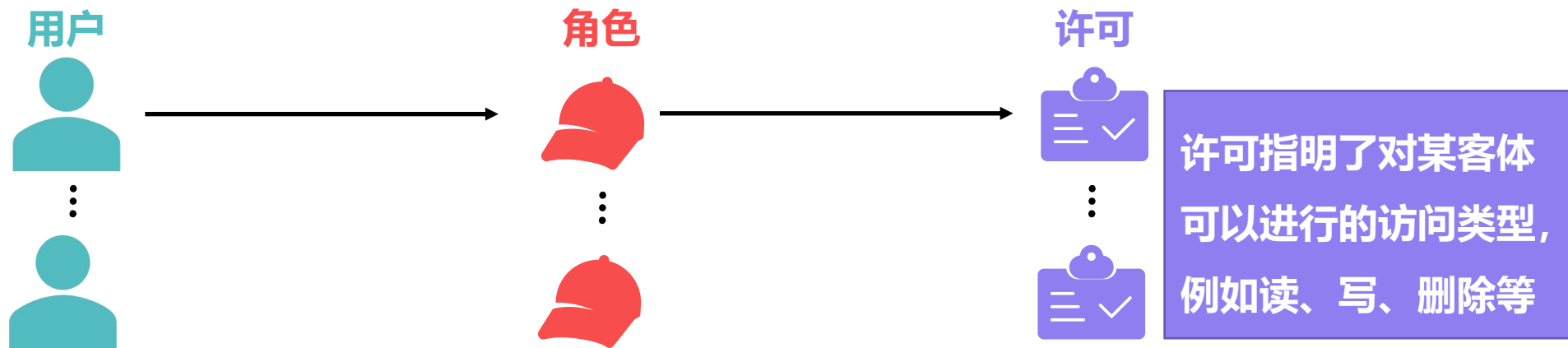
强制访问控制策略
(Mandatory Access Control, MAC)

基于角色的访问控制策略
(Role Based Access Control, RBAC)

■ 角色与许可之间的关系比角色与用户的关系要更加稳定。

□ 当一个用户的职责发生变化或需要为一个新的用户授权时，只要修改或设置用户的角色即可。

■ 很显然，将用户和访问权限通过角色进行逻辑隔离能够减小授权的复杂性、增强权限的可管理性、减少因授权失误导致安全漏洞的风险。



7.7 (1) 网络体系结构各层采取的安全措施——物理层和数据链路层

01

物理层安全实例：信道加密

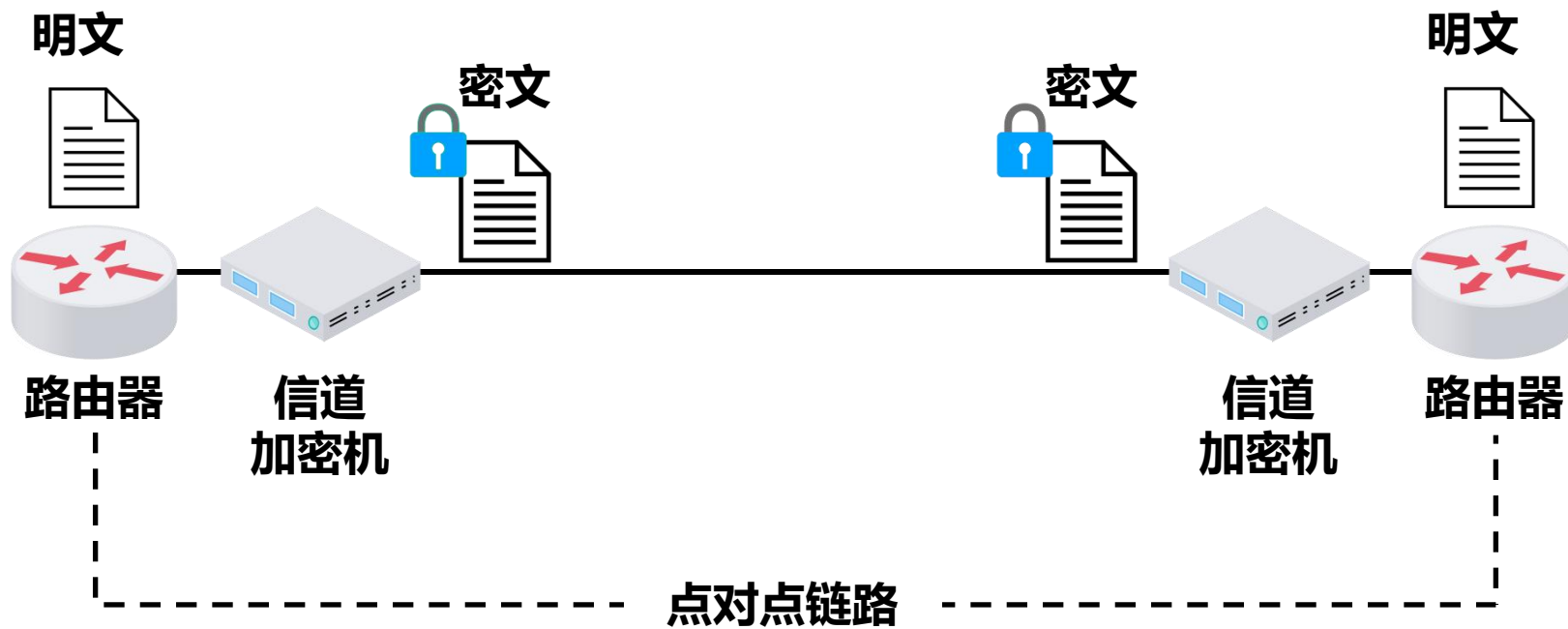
02

数据链路层安全实例：802.11i

01 物理层安全实例：信道加密

■ 在物理层实现通信数据的保密性和完整性的方法是**对信道进行加密**。

□ 对信道进行加密需要使用**信道加密机**。



01 物理层安全实例：信道加密

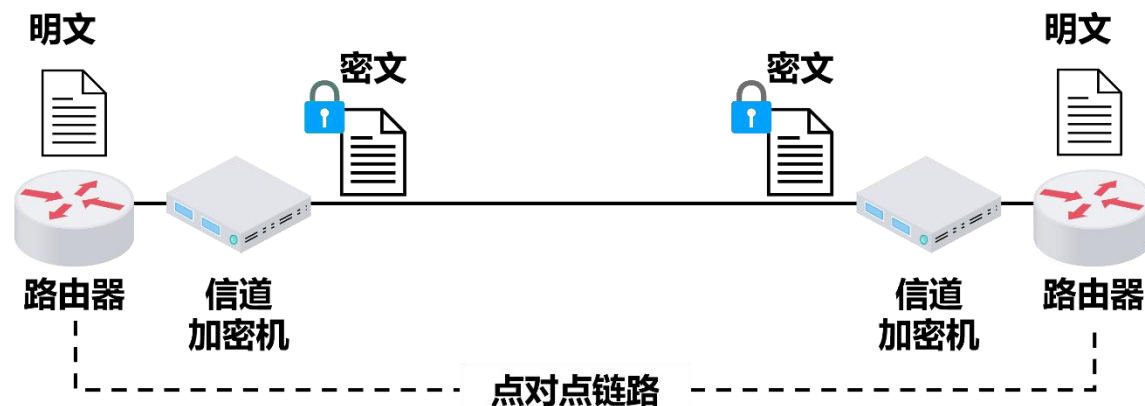
在物理层实现通信数据的保密性和完整性的方法是**对信道进行加密**。

☐ 对信道进行加密需要使用**信道加密机**。

使用信道加密技术可为通过链路的所有数据提供安全保护，并且对上层协议几乎没有任何影响，也就是具有**很好的透明性**。

☐ 由于链路上传送的各种协议数据单元PDU的首部和数据载荷都被加密了，PDU的截获者无法从PDU中提取源地址和目的地址，因此可以**防止各种形式的流量分析**。

由于**信道加密机**完全使用**硬件加密技术**，因此**加密和解密速度快**，并且**无须传送额外的数据**，采用该技术**不会减少网络的有效带宽**。



01 物理层安全实例：信道加密

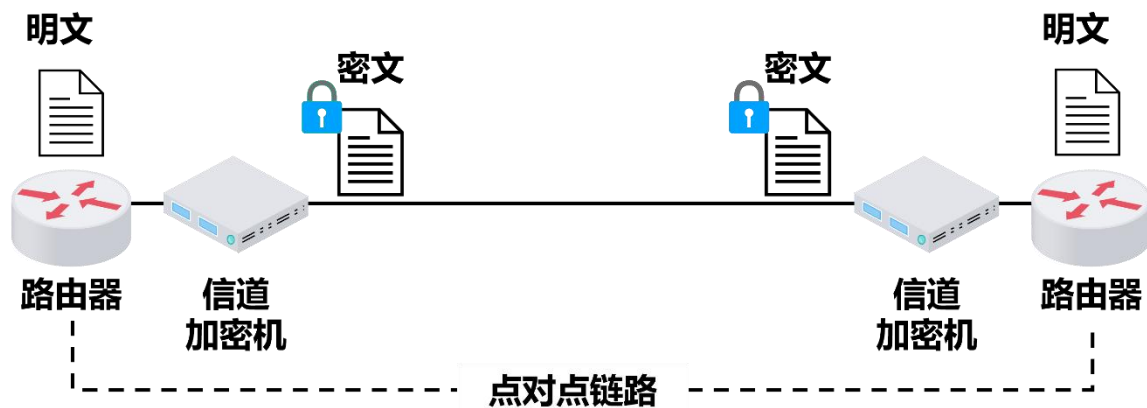
在物理层实现通信数据的保密性和完整性的方法是**对信道进行加密**。

☐ 对信道进行加密需要使用**信道加密机**。

使用信道加密技术可为通过链路的所有数据提供安全保护，并且对上层协议几乎没有任何影响，也就是具有**很好的透明性**。

☐ 由于链路上传送的各种协议数据单元PDU的首部和数据载荷都被加密了，PDU的截获者无法从PDU中提取源地址和目的地址，因此可以**防止各种形式的流量分析**。

由于**信道加密机**完全使用**硬件加密技术**，因此**加密和解密速度快**，并且**无须传送额外的数据**，采用该技术**不会减少网络的有效带宽**。



在网络互连的情况下，信道加密这种仅用于保护网络局部链路通信安全的技术不能确保端到端通信的安全。

在实际应用中，通常只在**容易被窃听的无线链路**（例如卫星链路）上，或**军用网络**等专用网络的**通信链路所在不安全区域**的部分使用信道加密技术。

02 数据链路层安全实例：802.11i

- 随着**802.11无线局域网**（Wi-Fi）的广泛应用，其**安全问题**越来越受到关注。
- 在无线通信方式下，电磁波在自由空间辐射传播，**任何无线终端都可在无线接入点的信号覆盖范围内接收其无线信号**。
 - ☐ 若不采取相应安全措施，任何无线终端都可以接入到网络中，进而窃听网络通信或非法使用网络资源。
- 因此802.11无线局域网的安全问题就显得尤为重要。**802.11无线局域网主要在数据链路层为用户提供安全服务**。
- 早期802.11无线局域网所采取的安全机制比较简单：

SSID匹配机制

MAC地址过滤机制

有线等效保密WEP机制

02 数据链路层安全实例：802.11i

早期802.11无线局域网所采取的安全机制比较简单：

SSID匹配机制

MAC地址过滤机制

有线等效保密WEP机制

这种SSID匹配机制仅是一种简单的不加密的口令鉴别，不能防止窃听和冒充，它仅提供了一种非常弱的访问控制功能。

与AP的SSID相同

可以加入AP形成的网络



不能加入AP形成的网络

02 数据链路层安全实例：802.11i

早期802.11无线局域网所采取的安全机制比较简单：

SSID匹配机制

MAC地址过滤机制

有线等效保密WEP机制

允许接入网络的
MAC地址列表

MAC地址A
MAC地址B
⋮

接入点AP

这种MAC地址过滤机制与SSID匹配机制一样，也只能提供非常弱的访问控制功能。

截获有效的
MAC地址

将自己的无线局域网网卡的MAC地址也设置为截获的有效的MAC地址，这样攻击者就可以接入到网络中。

所发送的帧被AP接收和转发

02 数据链路层安全实例：802.11i

早期802.11无线局域网所采取的安全机制比较简单：

SSID匹配机制

MAC地址过滤机制

有线等效保密WEP机制

网络管理员在AP上配置由AP和用户的无线终端共享的WEP密钥

接入点AP

WEP加密算法

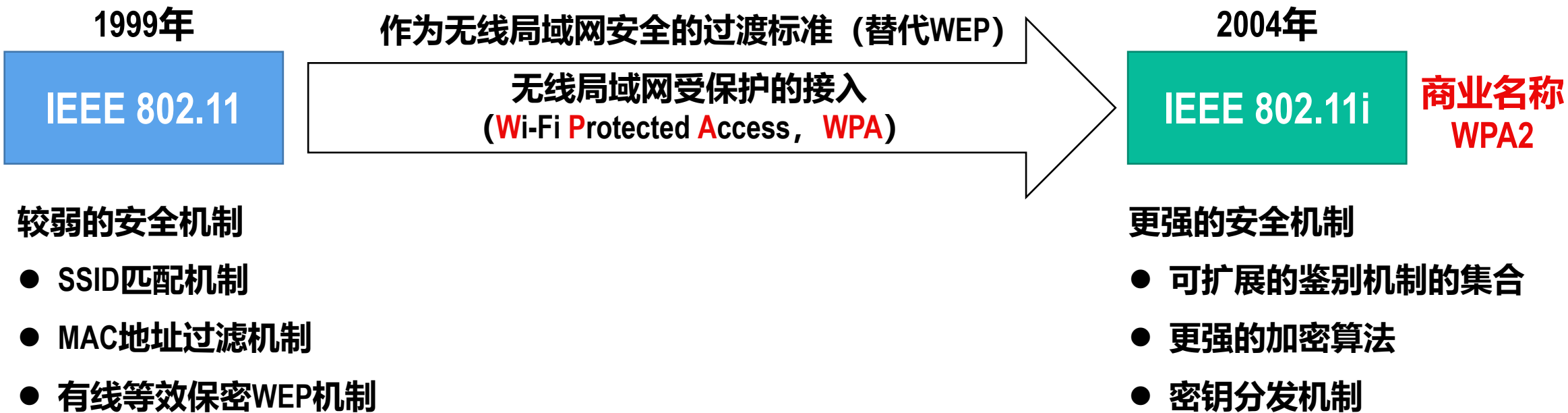
实体鉴别
数据通信

网络管理员告知用户该WEP密钥
由用户在自己的无线终端上设置



WEP并没有密钥分发机制，在鉴别过程和其后的数据通信过程中的所有通信都使用同一个共享密钥，并且所有接入到同一802.11无线局域网的无线终端都使用这同一个密钥。

另外，WEP采用的加密算法的强度较低。国内外众多研究人员已从理论和实际上都证明了WEP加密存在严重的安全隐患。

02 数据链路层安全实例：802.11i

目前大多数802.11无线局域网都支持WPA和WPA2，但建议用户尽量使用WPA2。

02 数据链路层安全实例：802.11i

鉴别服务器AS



接入点AP



无线终端

时间
↓

02 数据链路层安全实例：802.11i**鉴别服务器AS**

将AS从AP分离出来的目的在于
可使一台AS服务于多台AP，集
中在一台AS中处理鉴别和接入，
可以降低AP的复杂性和成本。

接入点AP**无线终端****时间**

02 数据链路层安全实例：802.11i

鉴别服务器AS

通告所提供的
鉴别和加密方式

接入点AP

请求所期望的
鉴别和加密方式

无线终端



第1阶段：安全性能力发现

尽管在该阶段无线终端已经与AP
交换了报文，但此阶段无线终端
还没有被鉴别，也没有获得用于
数据通信的加密密钥。

时间



02 数据链路层安全实例：802.11i

仅在无线终端和AS
之间转发报文

鉴别服务器AS



接入点AP



无线终端



第1阶段：安全性能力发现

第2阶段：无线终端和AS双向鉴别，共同生成主密钥MK。

- 鉴别过程使用由扩展的鉴别协议（Extensible Authentication Protocol, EAP）[RFC 2284]所定义的一种端到端的报文格式。EAP只是一个鉴别框架，并未指定具体的鉴别协议。
- 在EAP中，AS可选择多种鉴别方式中的任何一种来执行鉴别，主要利用公钥加密技术（包括不重数加密和报文摘要）在某个无线终端和AS之间进行相互鉴别，并生成双方共享的一个主密钥（Master Key, MK）。

时间



02 数据链路层安全实例：802.11i

鉴别服务器AS



接入点AP



无线终端



第1阶段：安全性能力发现

第2阶段：无线终端和AS双向鉴别，共同生成**主密钥MK**。第3阶段：无线终端与AS生成**成对主密钥PMK**

将PMK发送给AP

使用PMK相互鉴别

时间



02 数据链路层安全实例：802.11i

鉴别服务器AS



接入点AP



无线终端



第1阶段：安全性能力发现

第2阶段：无线终端和AS双向鉴别，共同生成**主密钥MK**。第3阶段：无线终端与AS生成**成对主密钥PMK**

将PMK发送给AP

使用PMK相互鉴别

第4阶段：AP和无线终端各自用PMK生成**临时密钥TK**

数据传输（使用TK加密）

时间



02 数据链路层安全实例：802.11i

■ IEEE 802.11i提供了多种加密形式，其中包含WEP加密的强化版本**临时密钥完整性协议**（Temporal Key Integrity Protocol, TKIP）和**基于高级加密标准AES的加密方案**。

■ 考虑到不同用户和不同应用的安全需要，例如企业用户需要很高的企业级安全保护，而家庭用户往往只是使用网络来浏览网页、收发电子邮件等，对安全保护的要求相对较低。为了满足不同用户的需求，IEEE 802.11i规定了以下两种应用模式：

☐ **企业模式**：使用**鉴别服务器AS**和**复杂的安全鉴别机制**来保护无线网络的通信安全。

☐ **家庭模式**：也称**个人模式**（包括小型办公室），在AP或无线路由器上以及无线终端上配置**预设共享密钥**（Pre-Shared Key, PSK）来保护无线网络的通信安全。

7.7 （2）网络体系结构各层采取的安全措施——网络层

01

IPSec协议栈概述

02

安全关联

03

IP安全数据报的格式

04

IPSec的其他构件

01 IPSec协议族概述

■ 目前，在因特网的网际层、运输层和应用层都有相应的网络安全协议。

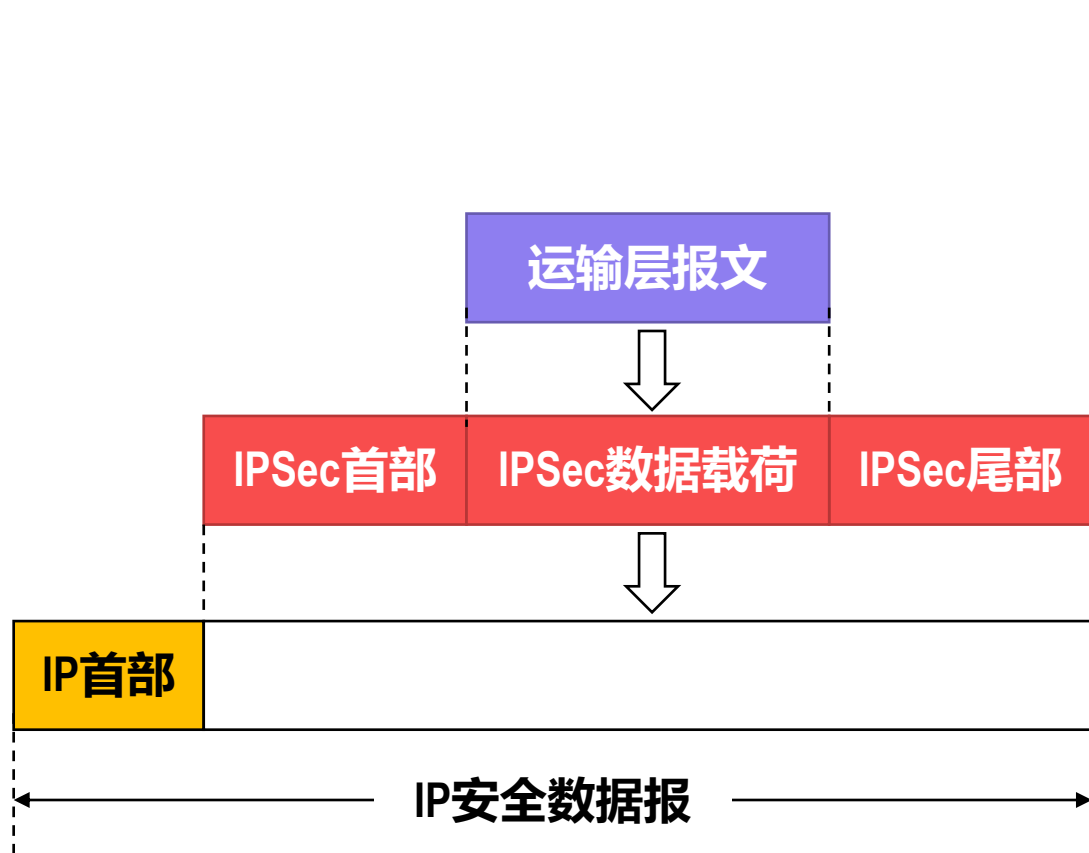
■ **IPSec**是“IP Security”（IP安全）的缩写词，它是**为因特网的网际层提供安全服务的协议族**（也有人不太严格地称其为“IPSec协议”）[RFC 4301, RFC6071]。

■ **IPSec并不限定用户使用何种特定的加密和鉴别算法**，通信双方可以选择合适的算法和参数（例如，密钥长度）。

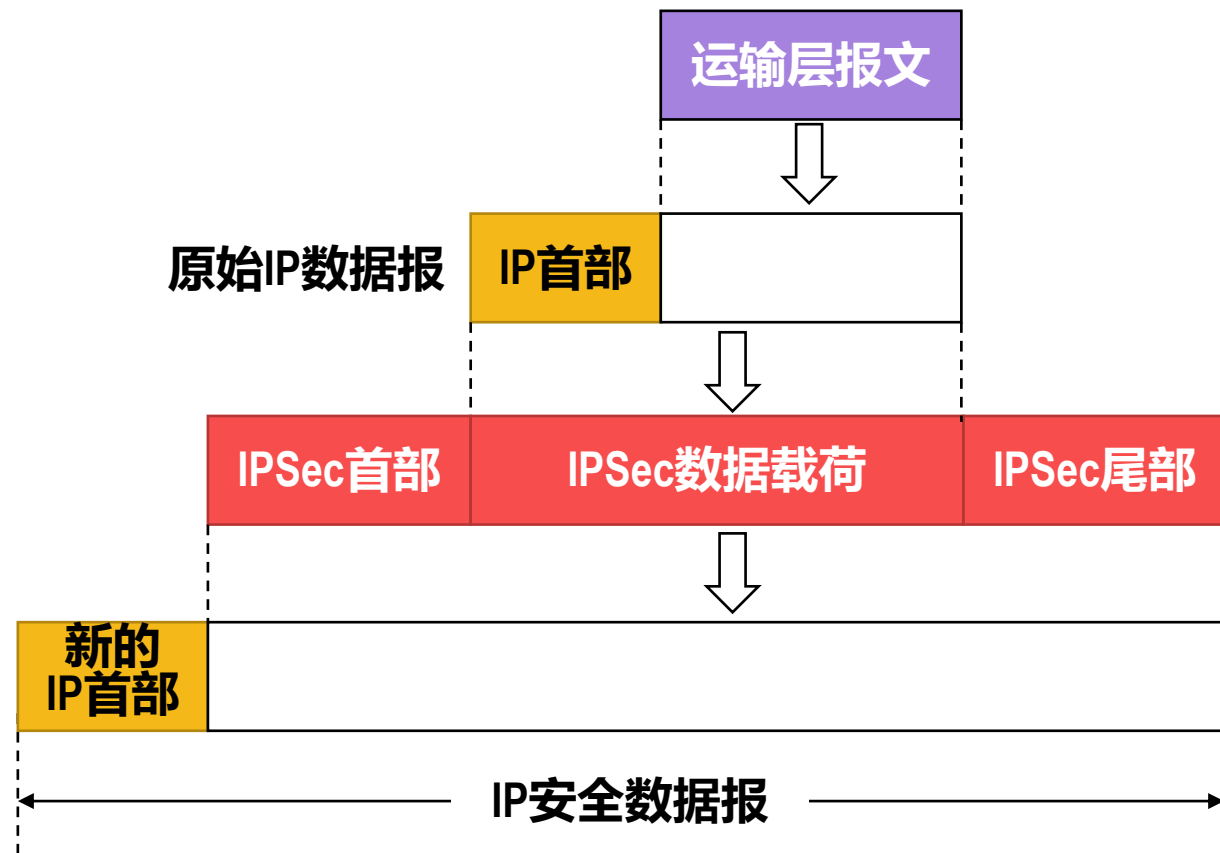
☐ 为了保证互操作性，IPSec也包含了一套加密算法，所有IPSec的实现都必须实现这套加密算法。

01 IPSec协议族概述

■ IPSec包含两种不同的工作方式：**运输方式**和**隧道方式**。



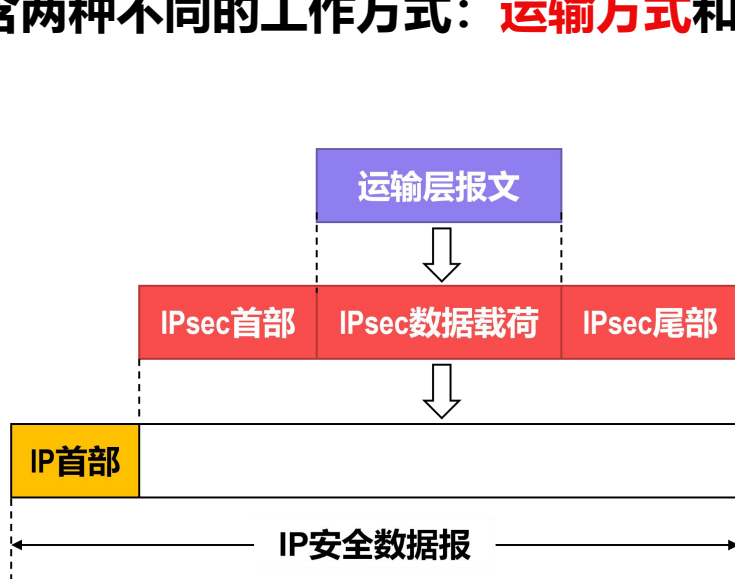
运输方式下的IP安全数据报的封装方式



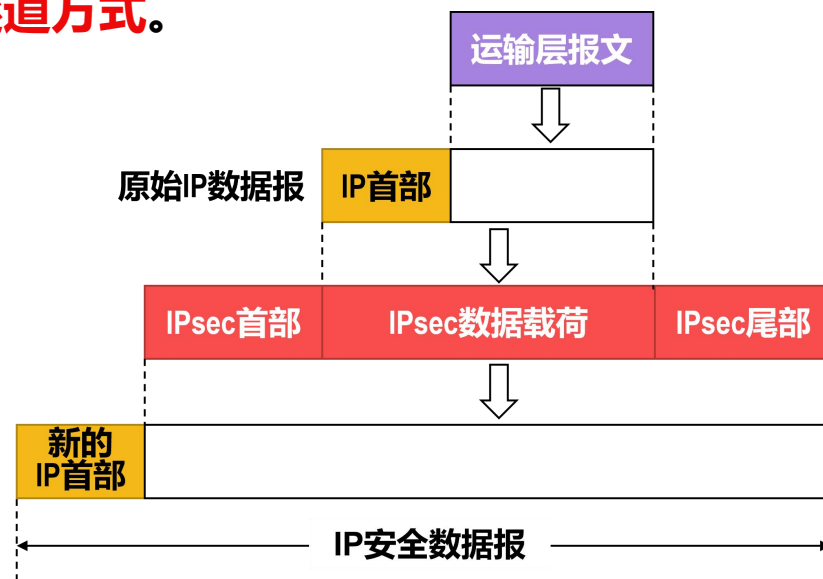
隧道方式下的IP安全数据报的封装方式

01 IPSec协议族概述

IPSec包含两种不同的工作方式：**运输方式**和**隧道方式**。



运输方式下的IP安全数据报的封装方式



隧道方式下的IP安全数据报的封装方式

目前使用最多
的是隧道方式

无论使用上述哪种方式，所封装出的**IP安全数据报的首部都是不加密的**。这是为了使因特网中的各路由器能够识别IP安全数据报首部中的相关信息，进而可以将IP安全数据报在不安全的因特网中从源点安全地转发到终点。所谓“IP安全数据报”，是指数据报的数据载荷是经过加密并能够被鉴别的。

02 安全关联

■ 在使用隧道方式传送IP安全数据报之前，应当首先为通信双方建立一条**网际层的逻辑连接**（即**安全隧道**），称为**安全关联**（Security Association, SA）。

□ 这样，**传统因特网无连接的网际层就变成了具有逻辑连接的一个层。**

■ 提供安全服务的**安全关联SA是从源点到终点的单向连接**。如果需要进行双向安全通信，则两个方向都需要建立SA。IP安全数据报就在这些SA中传送。

02 安全关联

在路由器之间建立安全关联



02 安全关联

在路由器之间建立安全关联



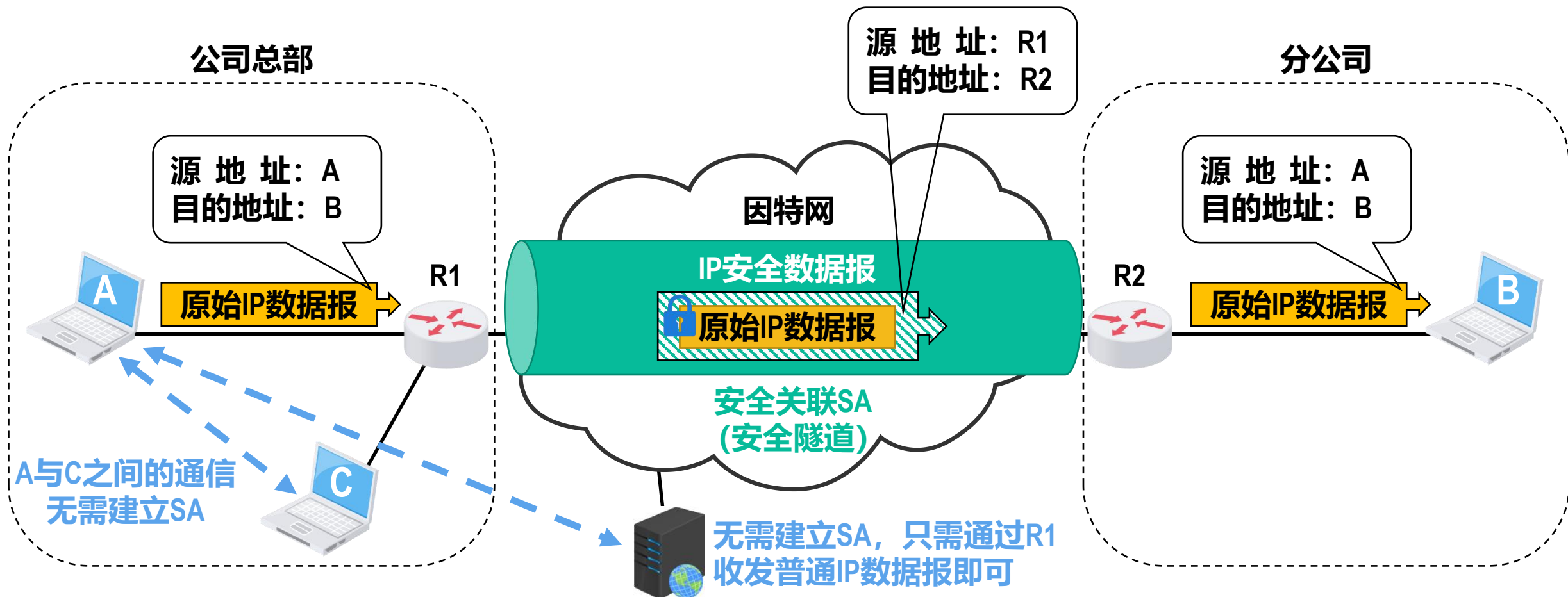
02 安全关联

在路由器之间建立安全关联



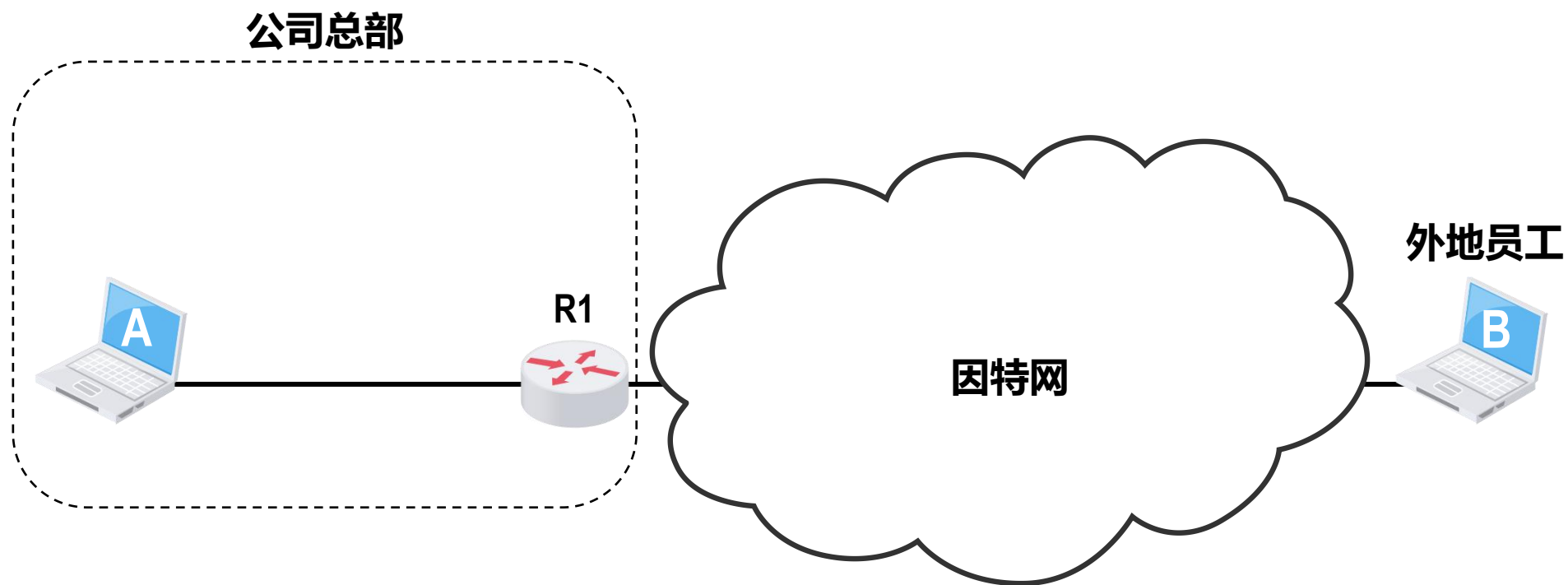
02 安全关联

在路由器之间建立安全关联



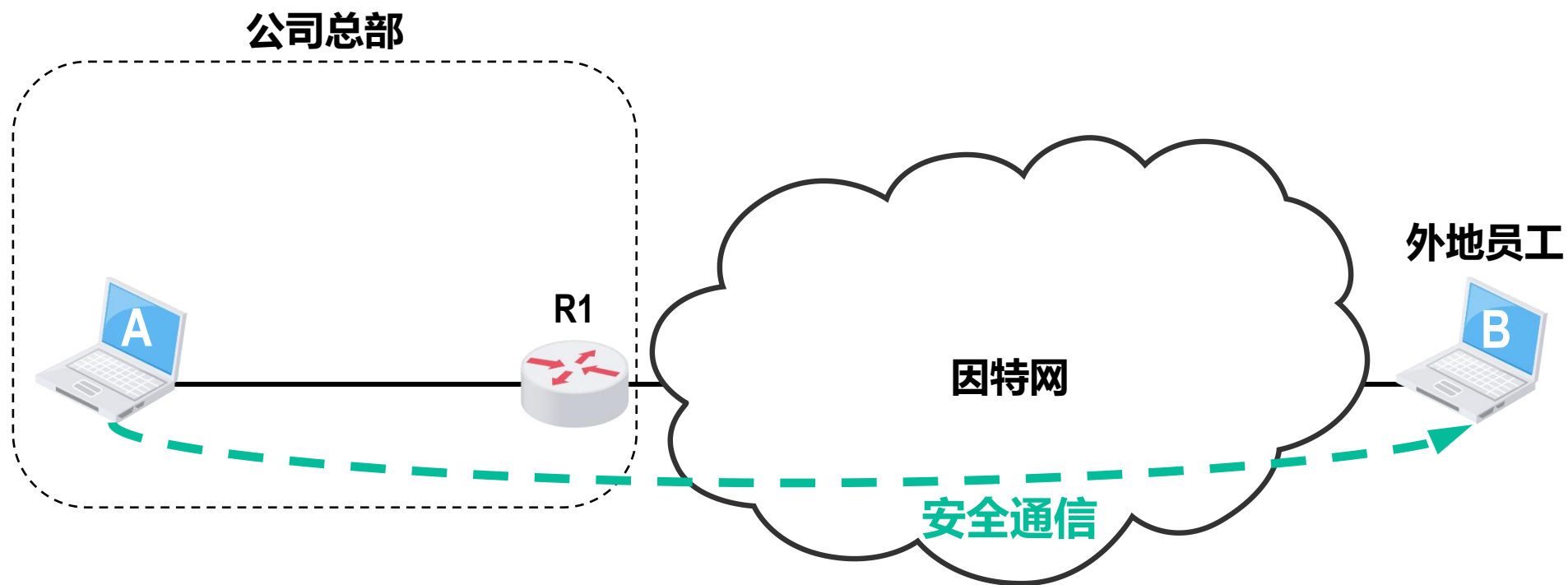
02 安全关联

在路由器和主机之间建立安全关联



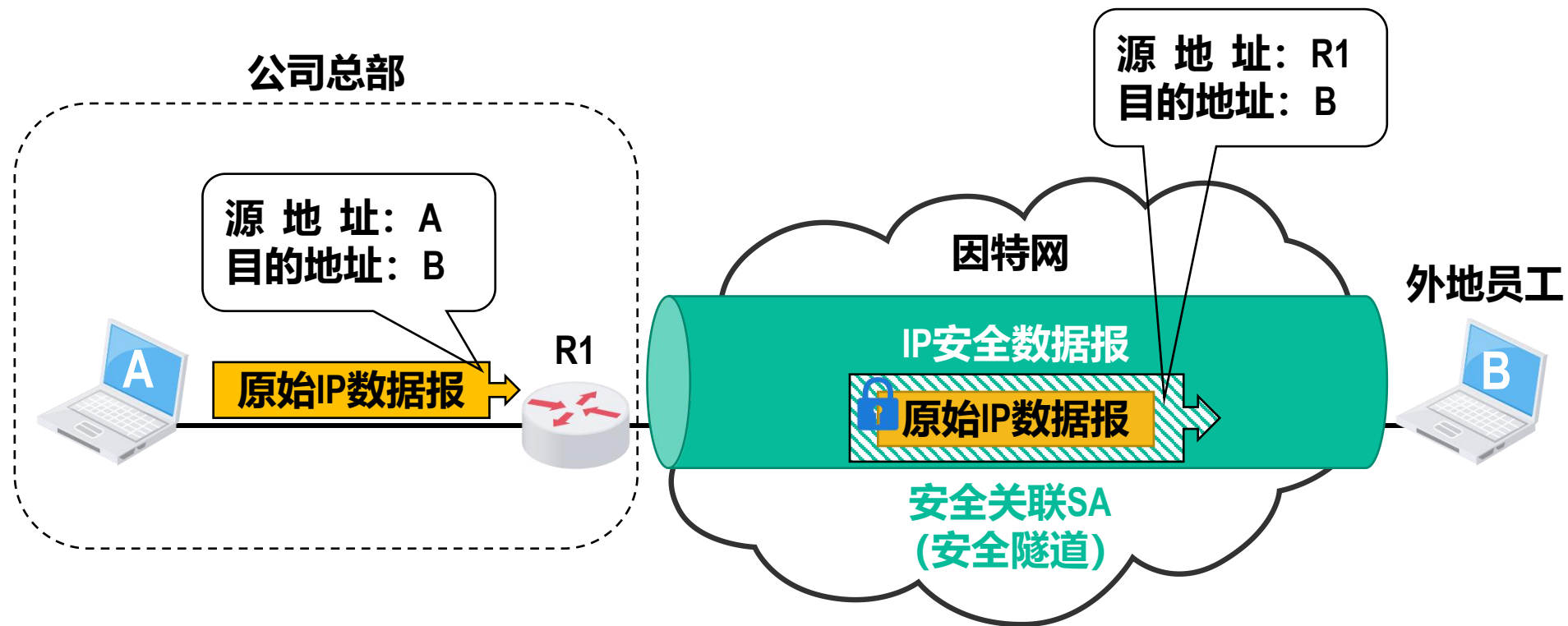
02 安全关联

在路由器和主机之间建立安全关联



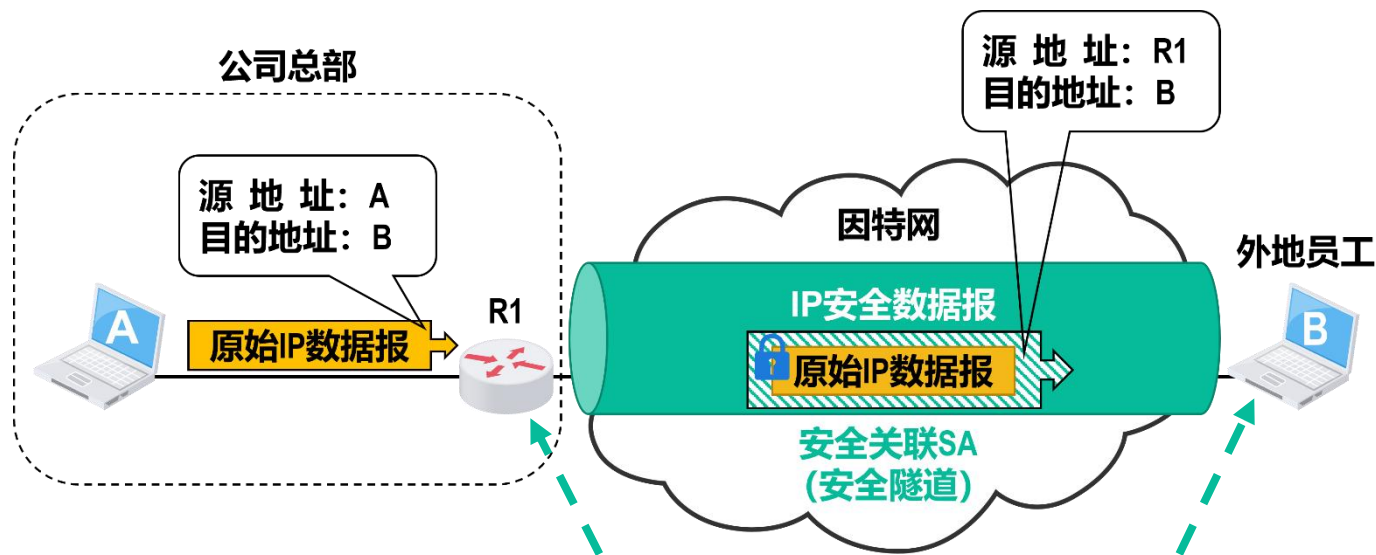
02 安全关联

在路由器和主机之间建立安全关联



02 安全关联

在路由器和主机之间建立安全关联

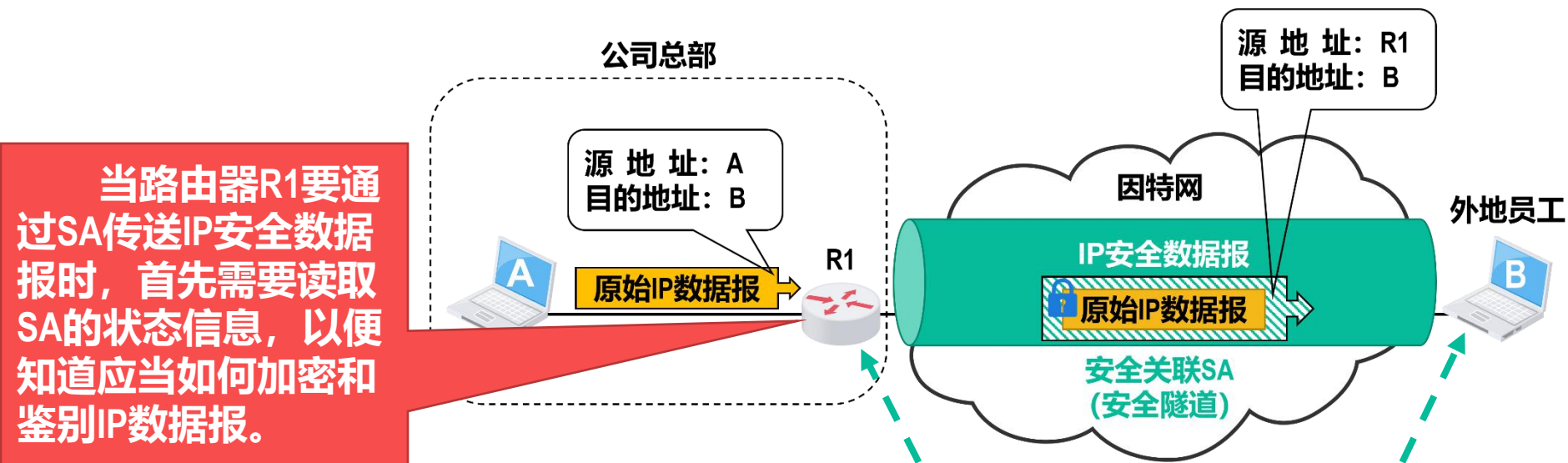


建立安全关联SA的路由器或主机，需要维护这条SA的状态信息

- 一个32位的连接标识符，称为安全参数索引（Security Parameter Index, SPI）
- SA的源点和终点的IP地址（图中路由器R1和主机B的IP地址）
- 所使用的加密类型（例如DES或AES）
- 加密的密钥
- 完整性检查的类型（例如，使用报文摘要MD5或SHA-1的报文鉴别码MAC）
- 鉴别使用的密钥

02 安全关联

在路由器和主机之间建立安全关联



建立安全关联SA的路由器或主机，需要维护这条SA的状态信息

- 一个32位的连接标识符，称为安全参数索引（Security Parameter Index, SPI）
- SA的源点和终点的IP地址（图中路由器R1和主机B的IP地址）
- 所使用的加密类型（例如DES或AES）
- 加密的密钥
- 完整性检查的类型（例如，使用报文摘要MD5或SHA-1的报文鉴别码MAC）
- 鉴别使用的密钥

03 IP安全数据报的格式

■ 在IPSec协议族中有两个主要的协议：**鉴别首部**（Authentication Header, **AH**）**协议**和**封装安全有效载荷**（Encapsulation Security Payload, **ESP**）**协议**。

☐ AH协议提供源点鉴别和数据完整性服务，但不能提供保密性服务。

☐ ESP协议比AH协议复杂得多，它提供源点鉴别、数据完整性和保密性服务。

■ IPSec既支持IPv4，也支持IPv6。在IPv6中，AH和ESP都是扩展首部的一部分。

■ 由于AH协议的功能都已包含在ESP协议中，因此使用ESP协议就无须使用AH协议。下面不再介绍AH协议，而只介绍ESP协议的要点。

■ 使用ESP或AH协议的IP数据报称为**IP安全数据报**（或**IPSec数据报**），它可以在两台主机之间、两台路由器之间或一台主机和一台路由器之间的安全关联SA（安全隧道）中传送。

03 IP安全数据报的格式

在隧道方式下，构建IP安全数据报的过程

在同一个SA中传送的IP安全数据报都使用同样的SPI值。

取值为4表明ESP的有效载荷为原始的IP数据报

安全参数索引SPI

每行32比特

序号

鉴别时防止
重放攻击。

填充

每行32比特

填充长度

下一个首部

协议字段的取值为50，
表明在接收端应将IP
安全数据报的数据载
荷交给ESP协议来处理。

ESP首部

原始的IP首部

原始IP数据报的数据载荷

ESP尾部

报文鉴别码MAC

ESP的有效载荷

加密的部分

鉴别的部分

新的IP首部

IP安全数据报的数据载荷

IP安全数据报



03 IP安全数据报的格式

在隧道方式下，接收方处理IP安全数据报的过程

检查SPI，以确定收到的IP安全数据报属于哪一个SA。

安全参数索引SPI

序号

每行32比特

根据协议字段的取值为50可知，应将该数据报的数据载荷用ESP协议进行处理。

ESP首部

原始的IP首部

原始IP数据报的数据载荷

ESP尾部

报文鉴别码MAC

ESP的有效载荷

加密的部分

鉴别的部分

新的IP首部

IP安全数据报的数据载荷

IP安全数据报

03 IP安全数据报的格式

在隧道方式下，接收方处理IP安全数据报的过程

检查SPI，以确定收到的IP安全数据报属于哪一个SA。

安全参数索引SPI

序号

每行32比特

根据序号可判断出是否被攻击者进行了重放攻击

根据填充长度，删除发送端填充的所有“全0”字节。

填充

每行32比特

填充长度

下一个首部

取值4表明应将ESP有效载荷交IP处理

根据协议字段的取值为50可知，应将该数据报的数据载荷用ESP协议进行处理。

ESP首部

原始的IP首部

原始IP数据报的数据载荷

ESP尾部

报文鉴别码MAC

ESP的有效载荷

加密的部分

解密

鉴别的部分

计算MAC与尾部的MAC进行比对

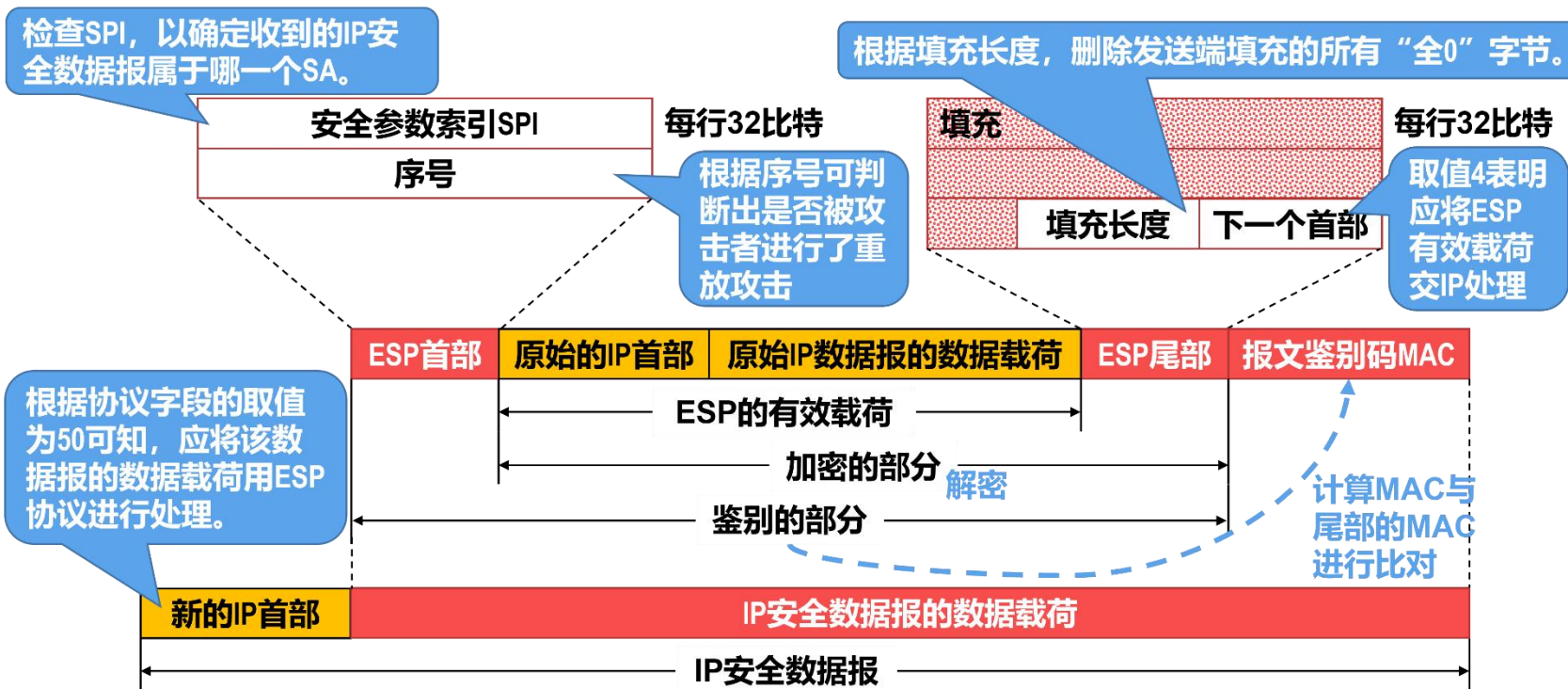
新的IP首部

IP安全数据报的数据载荷

IP安全数据报



03 IP安全数据报的格式



若某个IP安全数据报在因特网中被某个攻击者截获, 只要攻击者不知道该IP安全数据报的密码:

- 攻击者就仅能知道该IP安全数据报的首部信息 (例如源IP地址和目的IP地址), 但无法看懂其数据载荷的含义。
- 即使攻击者故意删除了该IP安全数据报的数据载荷中的一些字节, 由于接收端能够进行完整性验证, 因此不会接受这种含有差错的数据报。
- 如果攻击者尝试重放攻击, 但由于IP安全数据报使用了有效的序号, 因此使得重放攻击也不能成功。

04 IPSec的其他构件

安全关联数据库

(Security Association Database, SAD)

发送IP安全数据报的实体（路由器或主机）使用安全关联数据库SAD来存储可能要用到的很多条安全关联SA。

安全策略数据库

(Security Policy Database, SPD)

安全策略数据库SPD指明了什么样的IP数据报需要进行IPSec处理。

因特网密钥交换协议

(Internet Key Exchange, IKE)

因特网密钥交换IKE协议为IP安全数据报自动创建安全关联SA（而无需人工配置）。

7.7 （3） 网络体系结构各层采取的安全措施 —— 运输层

01

运输层安全实例：SSL/TLS

01 运输层安全实例：SSL/TLS

- (1) 顾客与销售商之间需要**相互鉴别**，以防止冒充者。
- (2) 要确保顾客与销售商之间的报文（例如购物清单和账单）在传输过程中**没有被篡改**。
- (3) 要确保顾客与销售商之间的敏感信息（例如顾客的信用卡号）**不被冒充者窃听**。

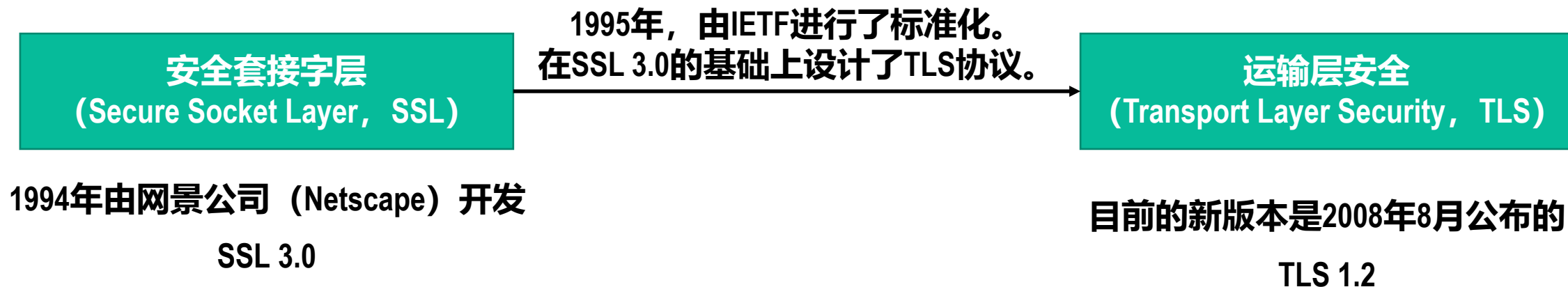
要实现上述这些安全服务，就需要使用**运输层的安全协议**。

为了基于因特网进行网上购物，必须要为顾客实现哪些安全服务呢？



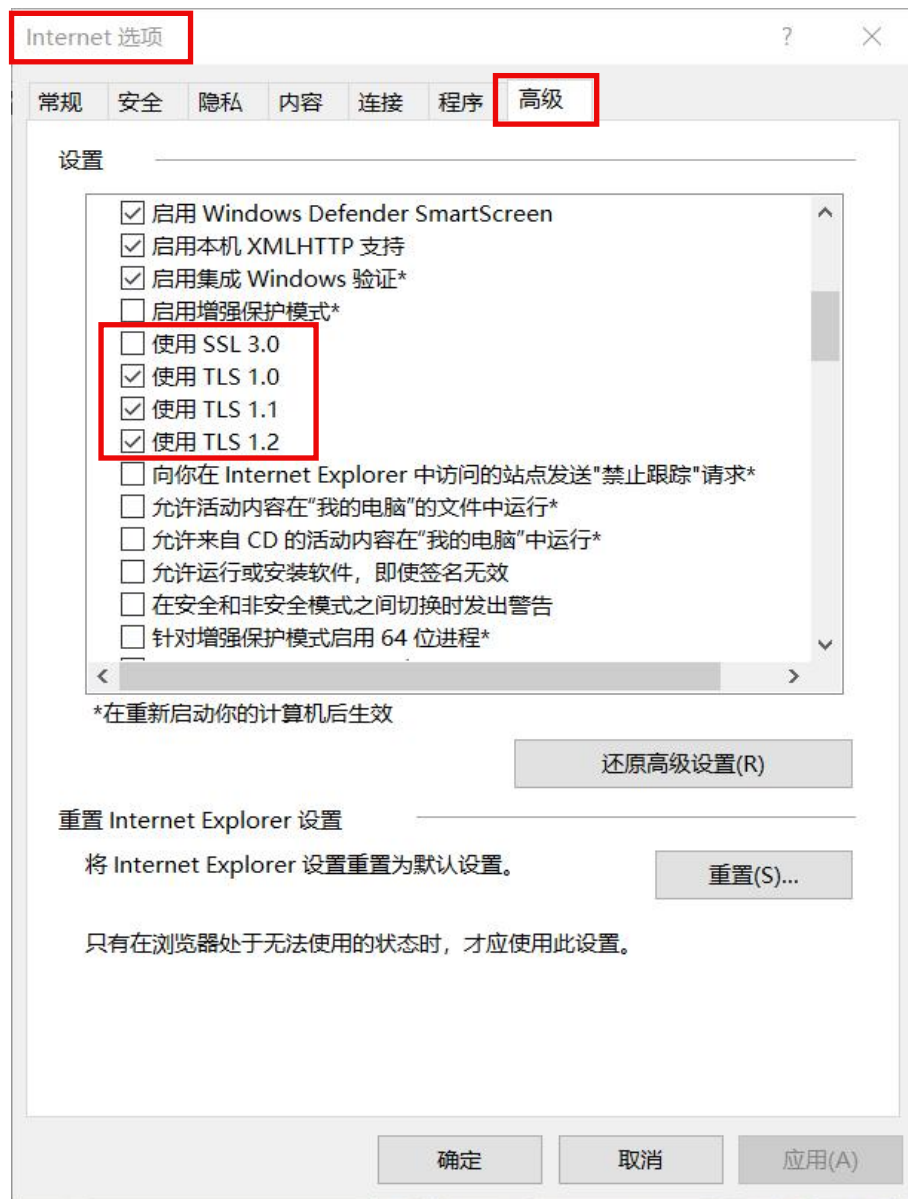
01 运输层安全实例：SSL/TLS

■ 现在广泛使用的运输层安全协议有以下两个：



01 运输层安全实例：SSL/TLS

■ 现在很多浏览器都已使用了SSL和TLS。



01 运输层安全实例：SSL/TLS

■ SSL/TLS作用于TCP/IP体系结构的应用层与运输层之间，在应用层中使用SSL/TLS最多的协议是HTTP。



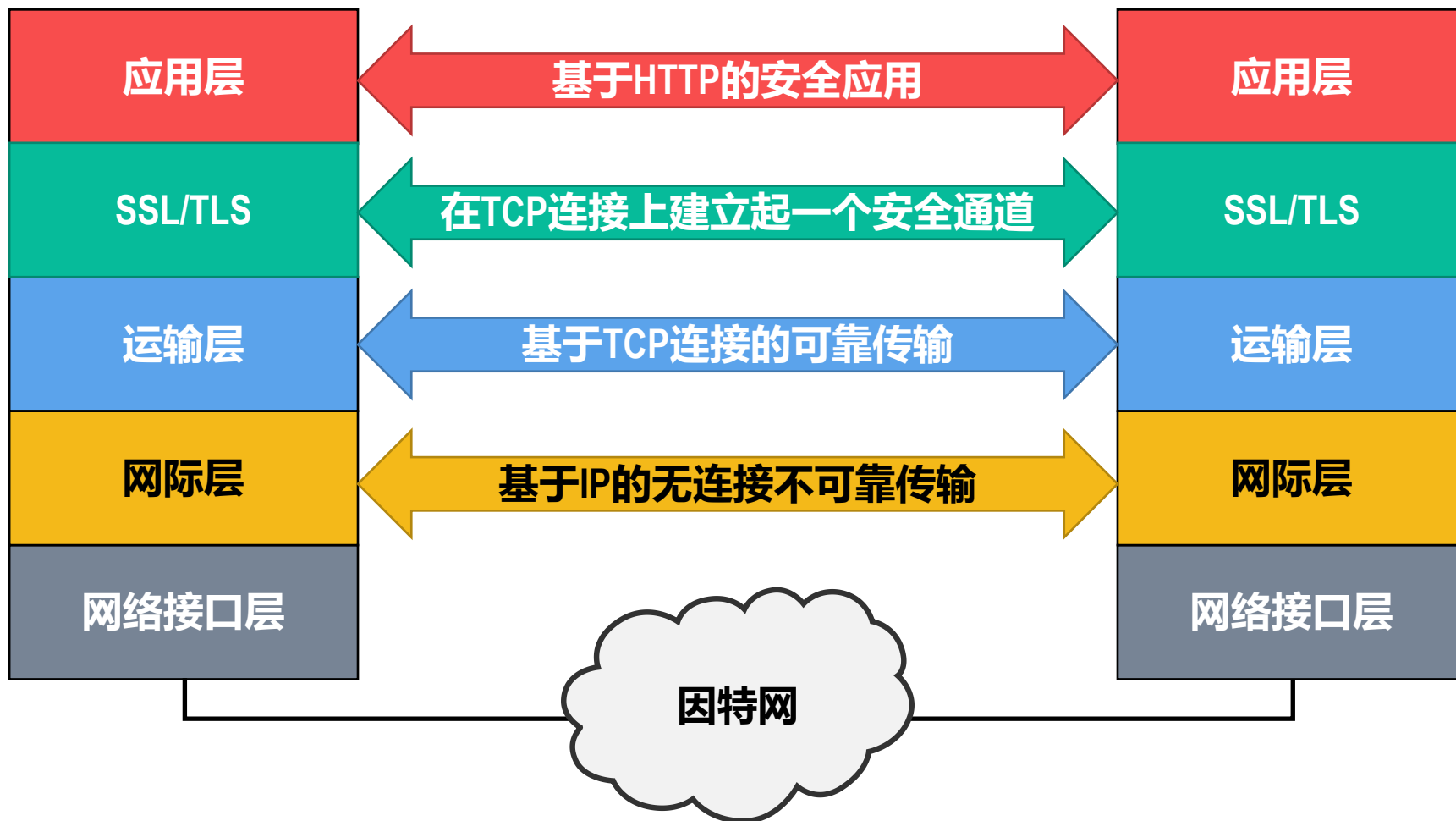
01 运输层安全实例：SSL/TLS

■ SSL/TLS作用于TCP/IP体系结构的应用层与运输层之间，在应用层中使用SSL/TLS最多的协议是HTTP。



01 运输层安全实例：SSL/TLS

■ SSL/TLS作用于TCP/IP体系结构的应用层与运输层之间，在应用层中使用SSL/TLS最多的协议是HTTP。



01 运输层安全实例：SSL/TLS（为了简单起见，用SSL简单表示）

■ SSL提供以下三种安全服务：

SSL服务器鉴别

支持SSL的客户端通过**验证来自服务器的证书**，来鉴别服务器的真实身份并**获得服务器的公钥**。

SSL客户鉴别

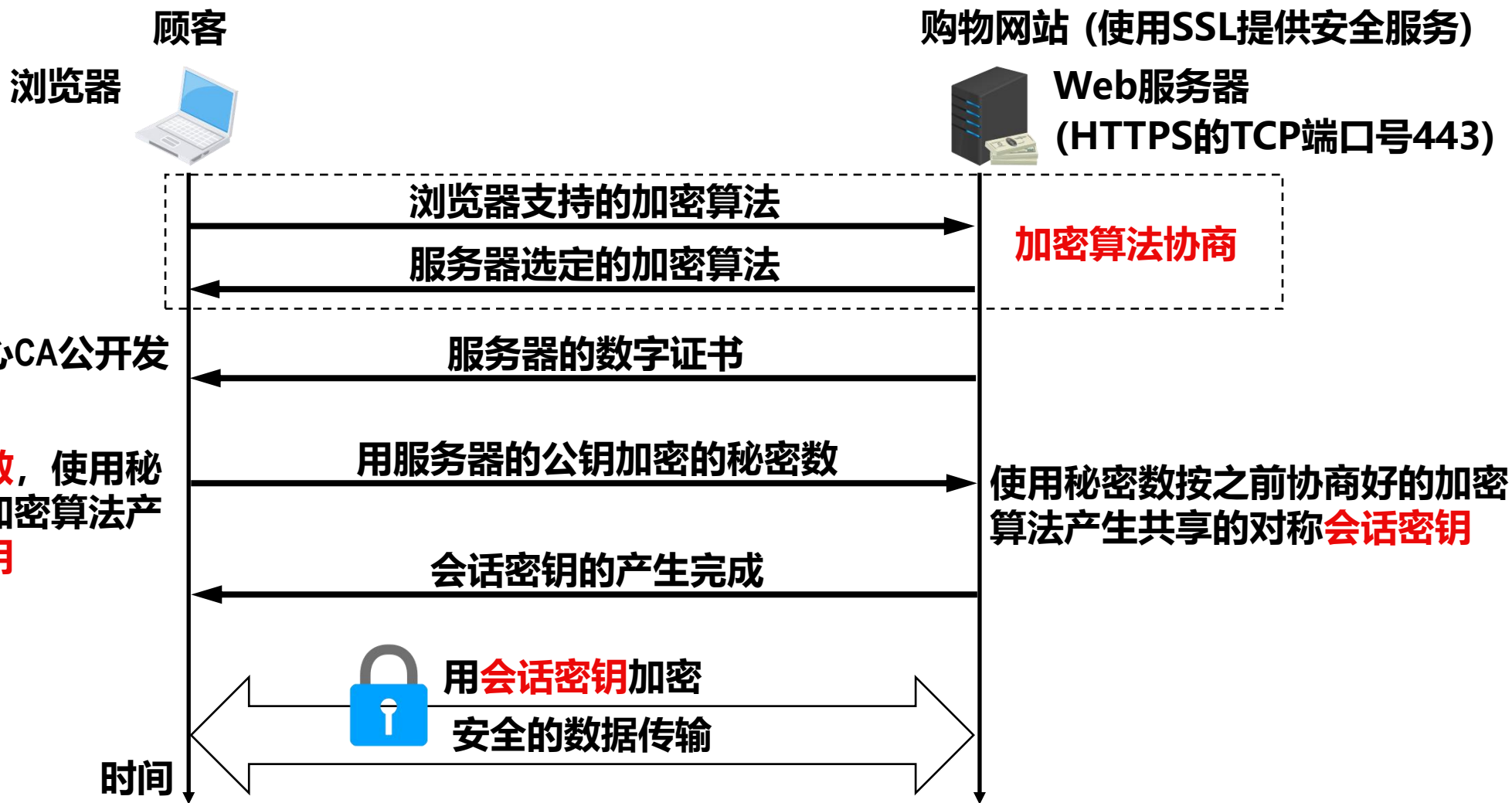
用于**服务器证实客户的身份**，这是SSL的可选安全服务。

加密的SSL会话

加密客户和服务器之间传送的所有报文，并检测报文是否被篡改。

01 运输层安全实例：SSL/TLS（为了简单起见，用SSL简单表示）

以基于因特网的网上购物为例，说明SSL的基本工作过程



7.7 （4） 网络体系结构各层采取的安全措施 —— 应用层

01

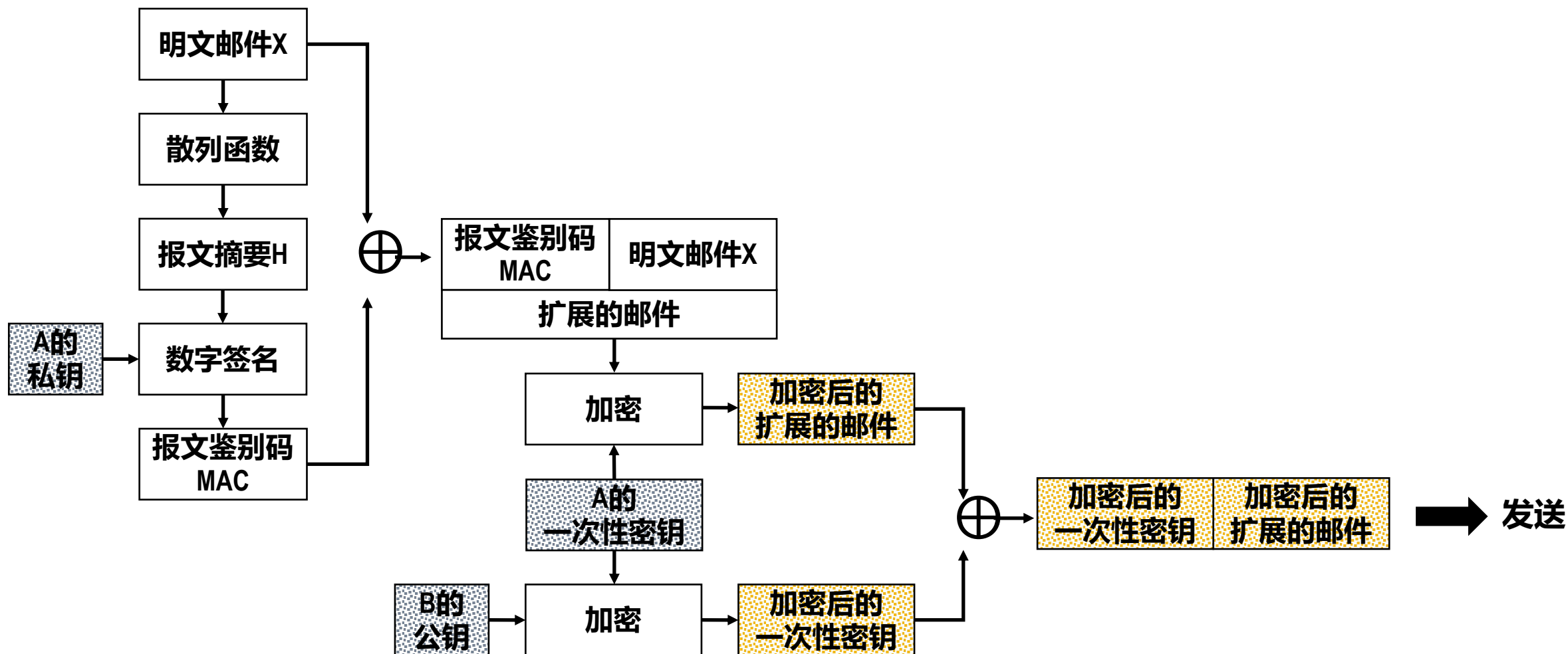
应用层安全实例：PGP

01 应用层安全实例：PGP

- 相较于计算机网络体系结构的其他各层，在应用层实现安全服务相对简单。
- TCP/IP体系结构的应用层中包含大量协议，本节课以电子邮件相关安全协议为例进行介绍。
- **PGP**（Pretty Good Privacy）是已被广泛应用的，为电子邮件提供加密、鉴别、电子签名和压缩等技术的**电子邮件安全软件包**，它是Zimmermann于1995年开发的。
 - ☐ PGP使用**对称密钥和公钥的组合**进行加密，为电子邮件提供**保密性**。
 - ☐ PGP通过**报文摘要和数字签名**技术为电子邮件提供**完整性和不可否认性**。

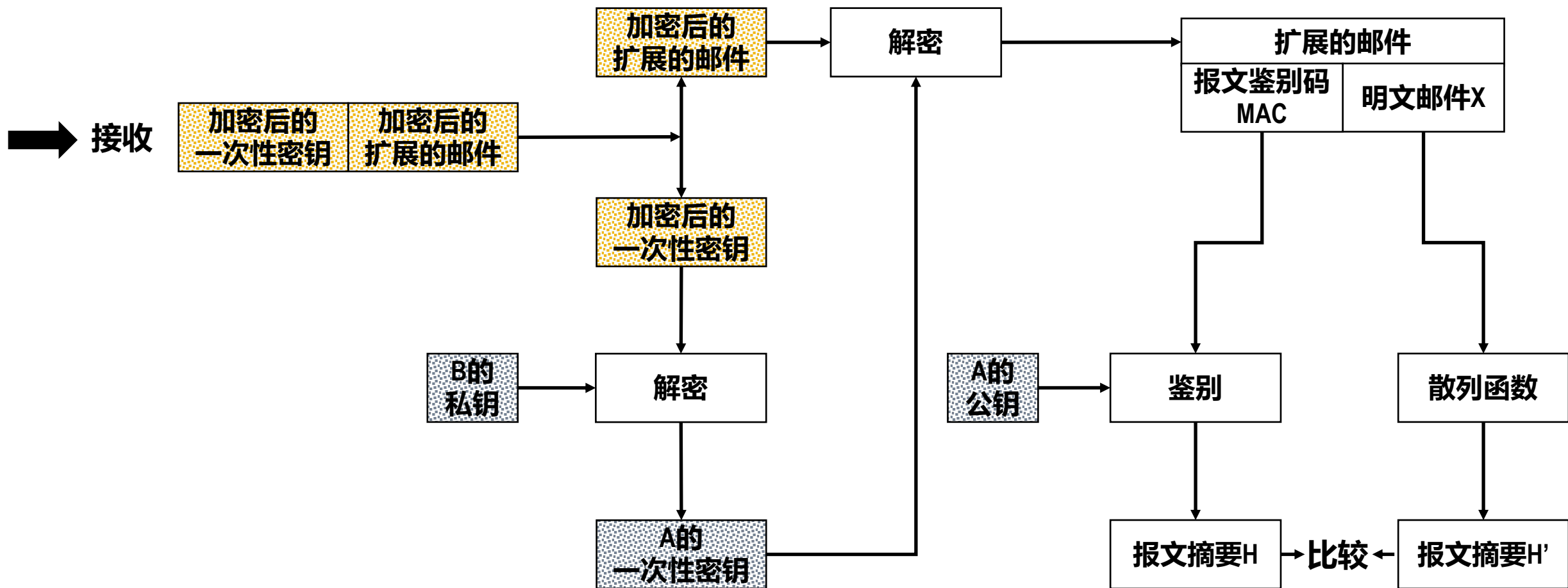
01 应用层安全实例：PGP —— 邮件发送方的PGP处理过程

【举例】假设用户A给B发送电子邮件的明文为X，要使用PGP来确保该邮件的安全。



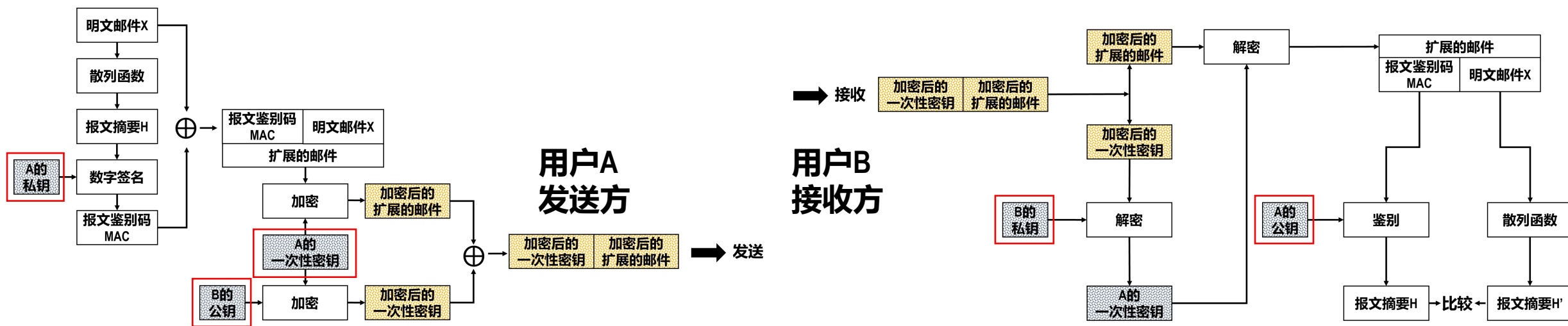
01 应用层安全实例：PGP —— 邮件接收方的PGP处理过程

【举例】假设用户A给B发送电子邮件的明文为X，要使用PGP来确保该邮件的安全。



01 应用层安全实例：PGP

【举例】假设用户A给B发送电子邮件的明文为X，要使用PGP来确保该邮件的安全。



- 邮件的收发双方获取对方公钥的最安全的方法是双方面对面直接交换公钥，但在大多数情况下这并不现实。
- 一般的做法是通过认证中心CA签发的证书来验证公钥持有者的合法身份。然而，PGP并没有要求使用CA，而允许使用一种第三方签署的方式来解决该问题。
- 需要说明的是，用户发布其公钥的最常见方式，还是通过电子邮件进行分发或把公钥发布在他们的个人网页上。具体采用哪种方式发布自己的公钥，取决于用户对安全性的要求。

7.8 防火墙访问控制和入侵检测系统

01

防火墙

02

入侵检测系统

网络体系结构



安全实例

PGP

SSL/TLS

IPsec

IEEE 802.11i

信道加密

基本安全服务

保密性

报文完整性

实体鉴别

不可否认性

仍无法应对的安全问题

- 非法用户利用系统漏洞进行未授权登录
- 授权用户非法获取更高级别的权限
- 通过网络传播病毒、蠕虫和特洛伊木马
- 阻止合法用户正常使用服务的拒绝服务攻击

防火墙

严格控制出入网络边界的分组，禁止任何不必要的通信，从而减少入侵的发生。

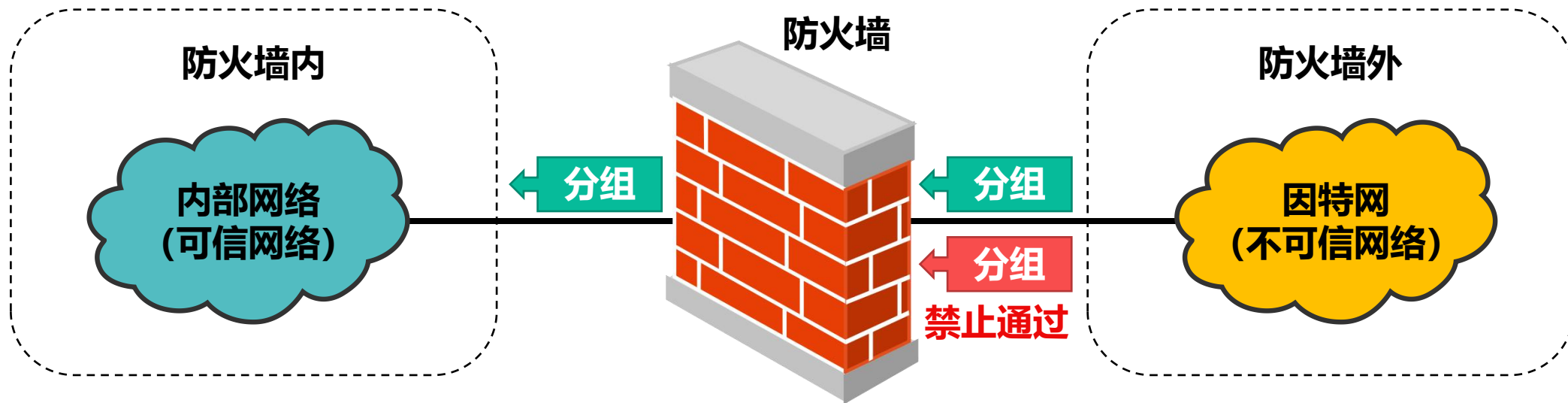
入侵检测系统

通过对进入网络的分组进行检测与深度分析，来发现疑似入侵行为的网络活动，并进行报警以便进一步采取相应措施。

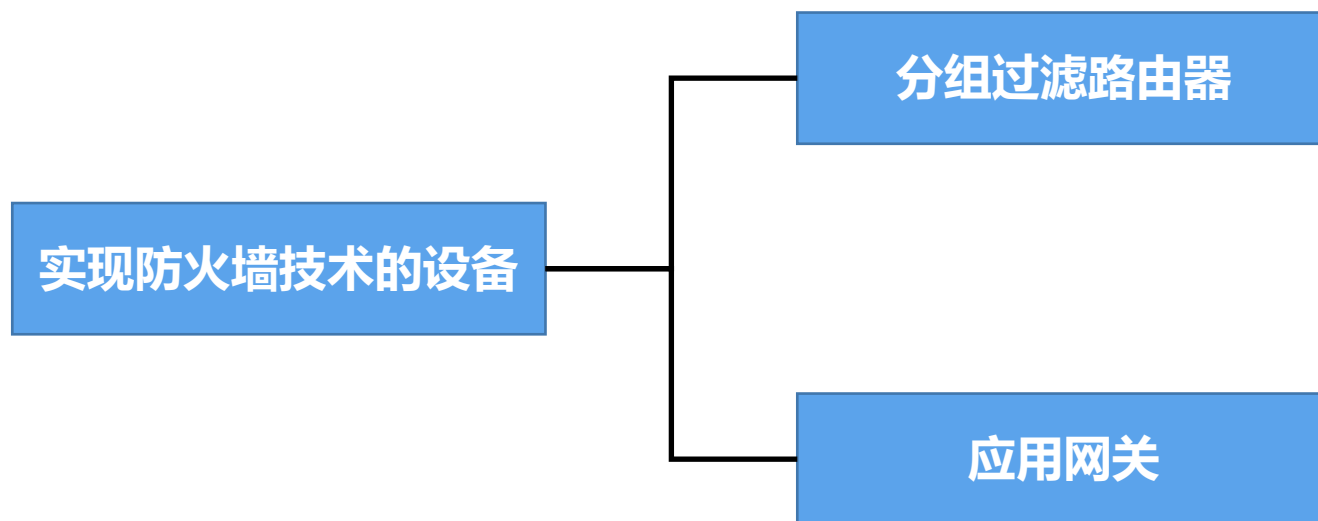
01 防火墙

■ 防火墙（Firewall）属于一种**访问控制技术**，具体实现为一种可编程的特殊路由器。

- ☐ 防火墙把一个单位（机构或公司）的**内部网络与其他网络**（一般为因特网）进行**安全隔离**。
- ☐ 根据防火墙中配置的**访问控制策略**，某些分组允许通过防火墙，而某些分组则被禁止通过。
- ☐ 访问控制策略由使用防火墙的单位根据自己的安全需要自行制定。



01 防火墙



01 防火墙

分组过滤路由器

应用网关

- 分组过滤路由器是一种具有分组过滤功能的路由器，它根据所配置的**分组过滤规则**对出入内部网络的分组执行转发或丢弃（即分组过滤）。
- 分组过滤规则所采用的各参数来自分组的网际层和/或运输层首部中的某些字段的值。
 - ☐ 网际层：源IP地址和目的IP地址
 - ☐ 运输层：源端口和目的端口、以及协议类型（TCP或UDP）

01 防火墙

分组过滤路由器

应用网关



01 防火墙

分组过滤路由器

应用网关

■ 通常，分组过滤规则以**访问控制列表**（Access Control List, **ACL**）的形式存储在分组过滤路由器中。

☐ 网络管理人员可以通过**命令行**或**图形界面**来配置ACL中的规则。

编号	方向	源IP地址	目的IP地址	协议	源端口	目的端口	处理方法
1	出	内网地址	因特网地址	TCP	大于1023	80	允许通过
2	入	因特网地址	内网地址	TCP	80	大于1023	允许通过
3	出	192.168.1.252	因特网地址	TCP	25	大于1023	允许通过
4	入	因特网地址	192.168.1.252	TCP	大于1023	25	允许通过
5	入	211.67.230.1	内网地址	任意	任意	任意	拒绝通过

01 防火墙

分组过滤路由器

应用网关

■ 通常，分组过滤规则以**访问控制列表**（Access Control List, **ACL**）的形式存储在分组过滤路由器中。

□ 网络管理人员可以通过**命令行**或**图形界面**来配置ACL中的规则。

使得内网中的主机
可以访问因特网中的各
种Web服务器。

编号	方向	源IP地址	目的IP地址	协议	源端口	目的端口	处理方法
1	出	内网地址	因特网地址	TCP	大于1023	80	允许通过
2	入	因特网地址	内网地址	TCP	80	大于1023	允许通过
3	出	192.168.1.252	因特网地址	TCP	25	大于1023	允许通过
4	入	因特网地址	192.168.1.252	TCP	大于1023	25	允许通过
5	入	211.67.230.1	内网地址	任意	任意	任意	拒绝通过

01 防火墙

分组过滤路由器

应用网关

■ 通常，分组过滤规则以**访问控制列表**（Access Control List, **ACL**）的形式存储在分组过滤路由器中。

□ 网络管理人员可以通过**命令行**或**图形界面**来配置ACL中的规则。

使得因特网中的主机
可以访问内网中IP地址为
192.168.1.252的电子邮件
服务器。

编号	方向	源IP地址	目的IP地址	协议	源端口	目的端口	处理方法
1	出	内网地址	因特网地址	TCP	大于1023	80	允许通过
2	入	因特网地址	内网地址	TCP	80	大于1023	允许通过
3	出	192.168.1.252	因特网地址	TCP	25	大于1023	允许通过
4	入	因特网地址	192.168.1.252	TCP	大于1023	25	允许通过
5	入	211.67.230.1	内网地址	任意	任意	任意	拒绝通过

01 防火墙

分组过滤路由器

应用网关

■ 通常，分组过滤规则以**访问控制列表**（Access Control List, **ACL**）的形式存储在分组过滤路由器中。

□ 网络管理人员可以通过**命令行**或**图形界面**来配置ACL中的规则。

禁止因特网中IP地址为211.67.230.1的主机访问内网中的任何主机。

编号	方向	源IP地址	目的IP地址	协议	源端口	目的端口	处理方法
1	出	内网地址	因特网地址	TCP	大于1023	80	允许通过
2	入	因特网地址	内网地址	TCP	80	大于1023	允许通过
3	出	192.168.1.252	因特网地址	TCP	25	大于1023	允许通过
4	入	因特网地址	192.168.1.252	TCP	大于1023	25	允许通过
5	入	211.67.230.1	内网地址	任意	任意	任意	拒绝通过

01 防火墙

分组过滤路由器

应用网关

■ 通常，分组过滤规则以**访问控制列表**（Access Control List, **ACL**）的形式存储在分组过滤路由器中。

☐ 网络管理人员可以通过**命令行**或**图形界面**来配置ACL中的规则。

该ACL所进行的分组过滤是**无状态**的，也就是独立地处理每一个分组。

功能更强的分组过滤路由器还支持**有状态**的分组过滤，也就是要跟踪每个连接或会话的通信状态，并根据这些状态信息来决定是否转发分组。

编号	方向	源IP地址	目的IP地址	协议	源端口	目的端口	处理方法
1	出	内网地址	因特网地址	TCP	大于1023	80	允许通过
2	入	因特网地址	内网地址	TCP	80	大于1023	允许通过
3	出	192.168.1.252	因特网地址	TCP	25	大于1023	允许通过
4	入	因特网地址	192.168.1.252	TCP	大于1023	25	允许通过
5	入	211.67.230.1	内网地址	任意	任意	任意	拒绝通过

01 防火墙

分组过滤路由器

应用网关

■ 分组过滤路由器**简单高效**，对用户是**透明**的（用户感觉不到分组过滤路由器的存在）。

■ 然而，**分组过滤路由器不能对应用层数据进行过滤**。

☐ 不能禁止某个用户对某个特定网络应用进行某个特定的操作。

☐ 不支持应用层用户鉴别。

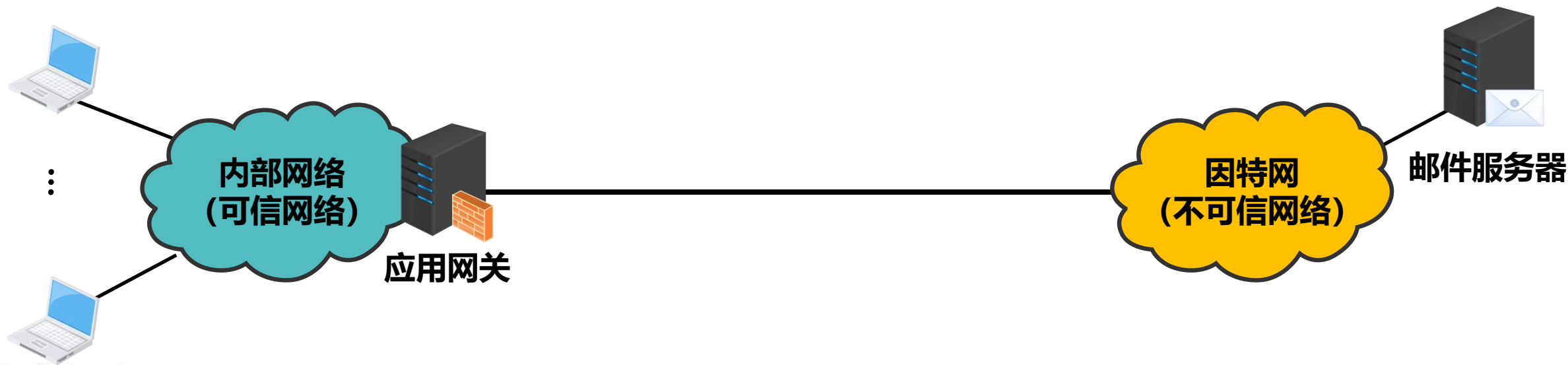
需要使用应用网关来实现

01 防火墙

分组过滤路由器

应用网关

- **应用网关**又称为**代理服务器**（Proxy Server），它可以实现**应用层数据的过滤**和**高层用户的鉴别**。
- 当用户通过应用网关访问内网或外网资源时，应用网关可以要求用户进行身份鉴别，然后**根据用户身份对用户做出相应的访问控制**。

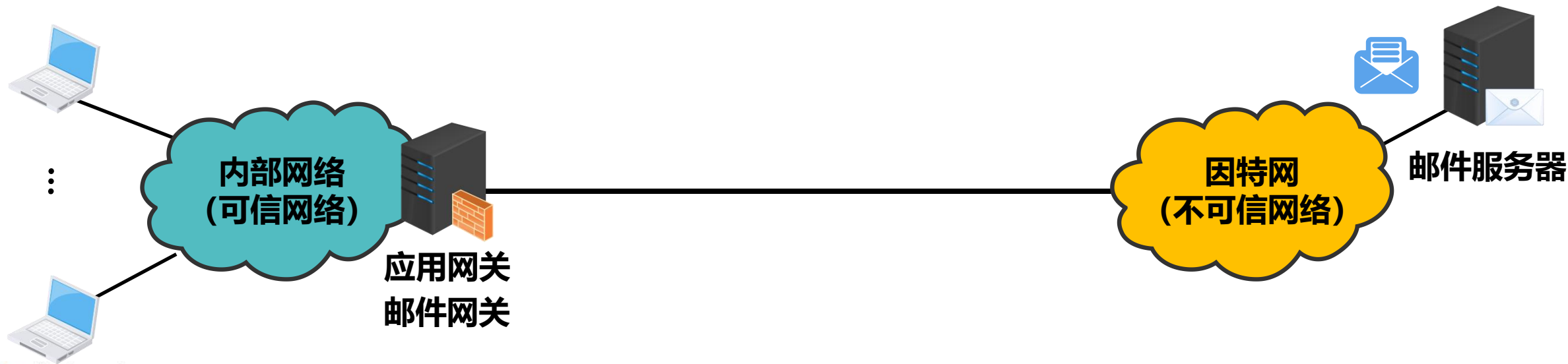


01 防火墙

分组过滤路由器

应用网关

- **应用网关**又称为**代理服务器**（Proxy Server），它可以实现**应用层数据的过滤**和**高层用户的鉴别**。
- 当用户通过应用网关访问内网或外网资源时，应用网关可以要求用户进行身份鉴别，然后**根据用户身份对用户做出相应的访问控制**。

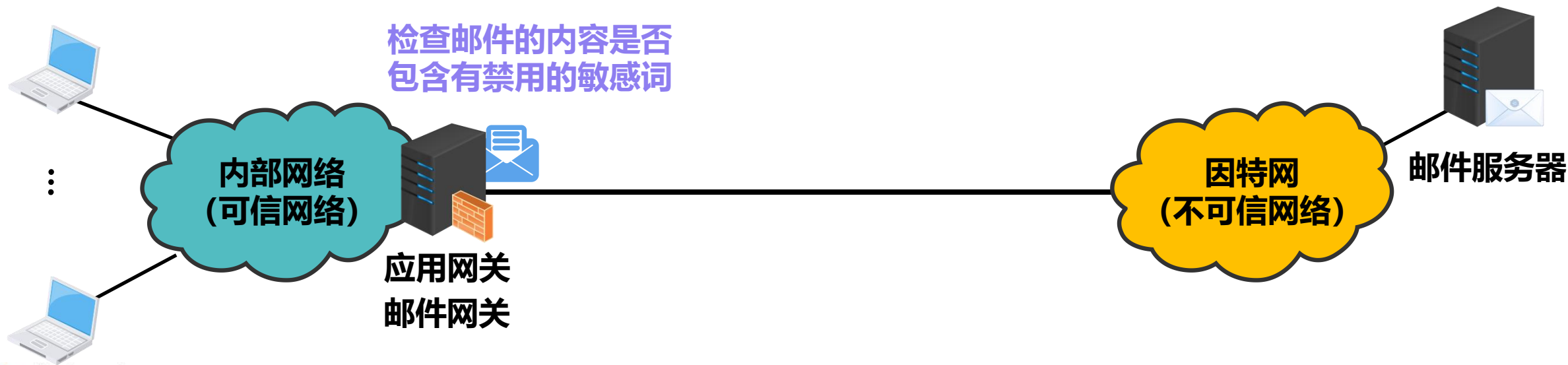


01 防火墙

分组过滤路由器

应用网关

- **应用网关**又称为**代理服务器**（Proxy Server），它可以实现**应用层数据的过滤**和**高层用户的鉴别**。
- 当用户通过应用网关访问内网或外网资源时，应用网关可以要求用户进行身份鉴别，然后**根据用户身份对用户做出相应的访问控制**。



01 防火墙

分组过滤路由器

应用网关

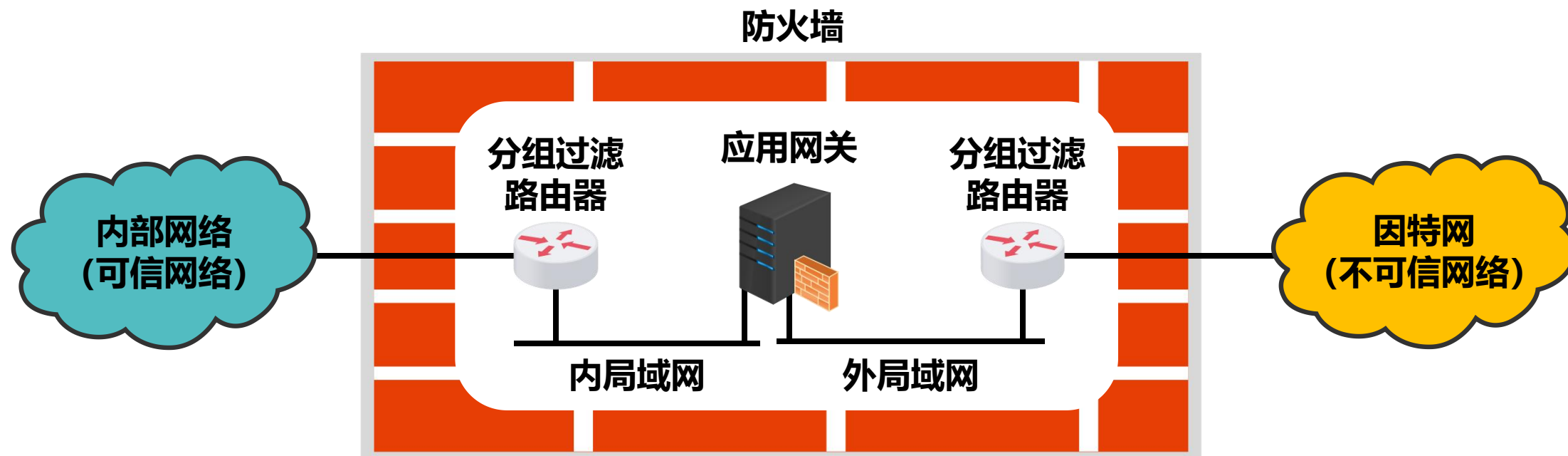
■ 应用网关也有一些**局限**：

- ☐ 每种网络应用都需要一个专用的应用网关。当然，多个不同的应用网关可以运行在同一台主机上。
- ☐ 在应用层处理和转发报文，**处理负担较重**。
- ☐ **应用网关对应用程序是不透明的**，用户需要在应用程序客户端指明应用网关（代理服务器）的地址。

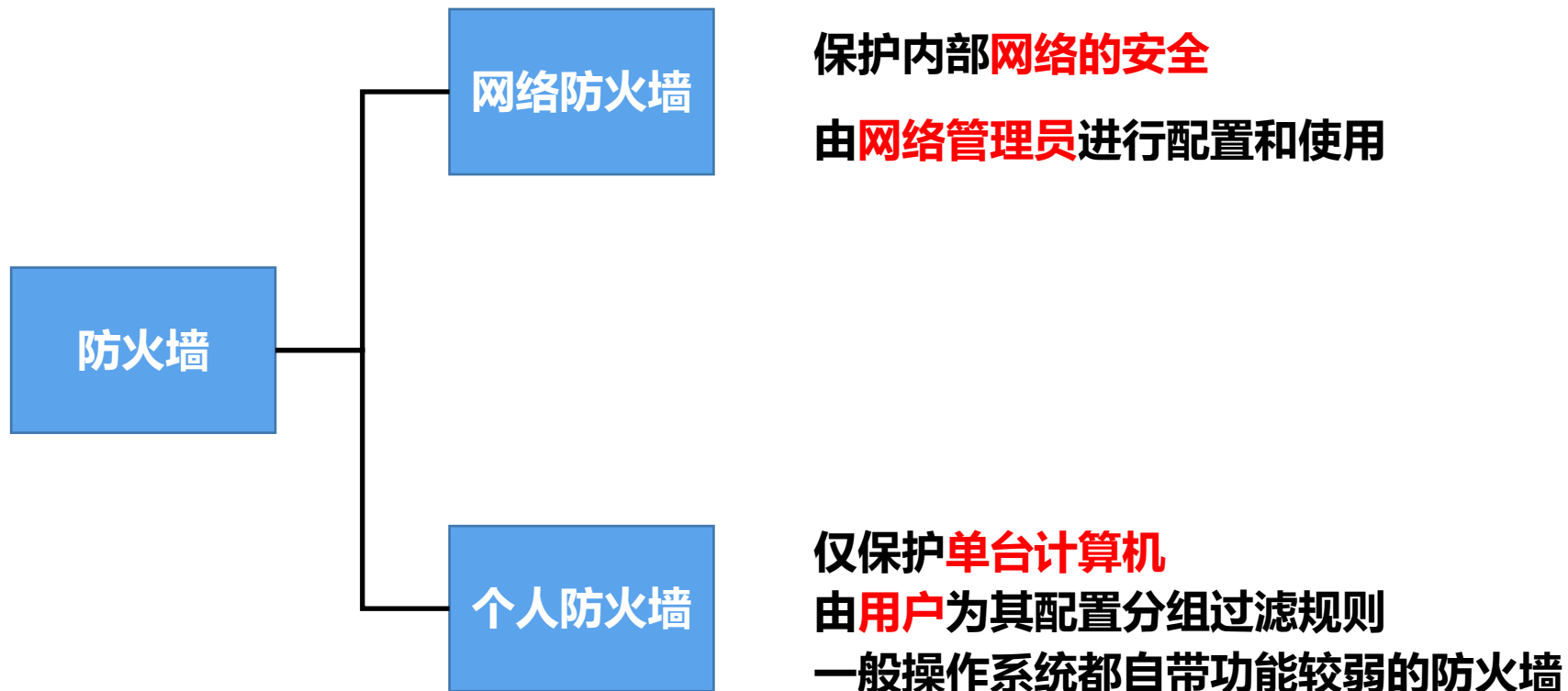
01 防火墙

分组过滤路由器

应用网关



01 防火墙



01 防火墙

■ 尽管**防火墙**提高了内部网络的安全防护程度，但仍存在以下**局限**：

- ① 对防火墙的**配置是否正确和完善**，在很大程度上决定了防火墙可以发挥的安全防护作用。
- ② 防火墙**对恶意代码（病毒、木马等）的查杀能力非常有限**，因此不能有效地防止恶意代码通过网络的传播。
 - 由于查杀恶意代码的计算开销非常大，若提高防火墙的查杀力度，则会降低防火墙的处理速度，进而降低用户的网络带宽。
- ③ 防火墙**对于一些利用系统漏洞或网络协议漏洞进行的攻击是无法防范的**。
 - 攻击者通过分组过滤规则中允许的端口对某个服务器的漏洞进行攻击，这对于一般的分组过滤路由器是无法防护的。
 - 即使使用应用网关，也必须具有能够识别该特定漏洞的应用网关才能阻断攻击。
- ④ 防火墙技术**自身存在不足**。
 - 分组过滤路由器不能防止IP地址和端口号欺骗。
 - 应用软件自身也可能有软件漏洞而存在被渗透攻击的风险。

02 入侵检测系统

■ 防火墙并不能阻止所有的入侵行为。

■ 在入侵已经开始但还未造成危害或在造成更大危害之前，**及时检测到入侵并尽快阻止入侵**，尽量把危害降到最小，就是非常有必要的。**入侵检测系统**（Intrusion Detection System, IDS）正是这样一种技术。

■ IDS对出入网络的分组执行**深度检查**，当**检查到可疑分组**时，会**及时向网络管理员发出警报或进行阻断**。

☐ 由于IDS的误报率较高，因此**一般情况下不建议对可疑分组进行自动阻断**。

■ IDS能够检测多种网络攻击：

端口扫描

拒绝服务攻击

网络映射

恶意代码

系统漏洞

02 入侵检测系统

只能检测已知攻击，
对于未知攻击则无法防范。

基于**特征**的入侵检测系统

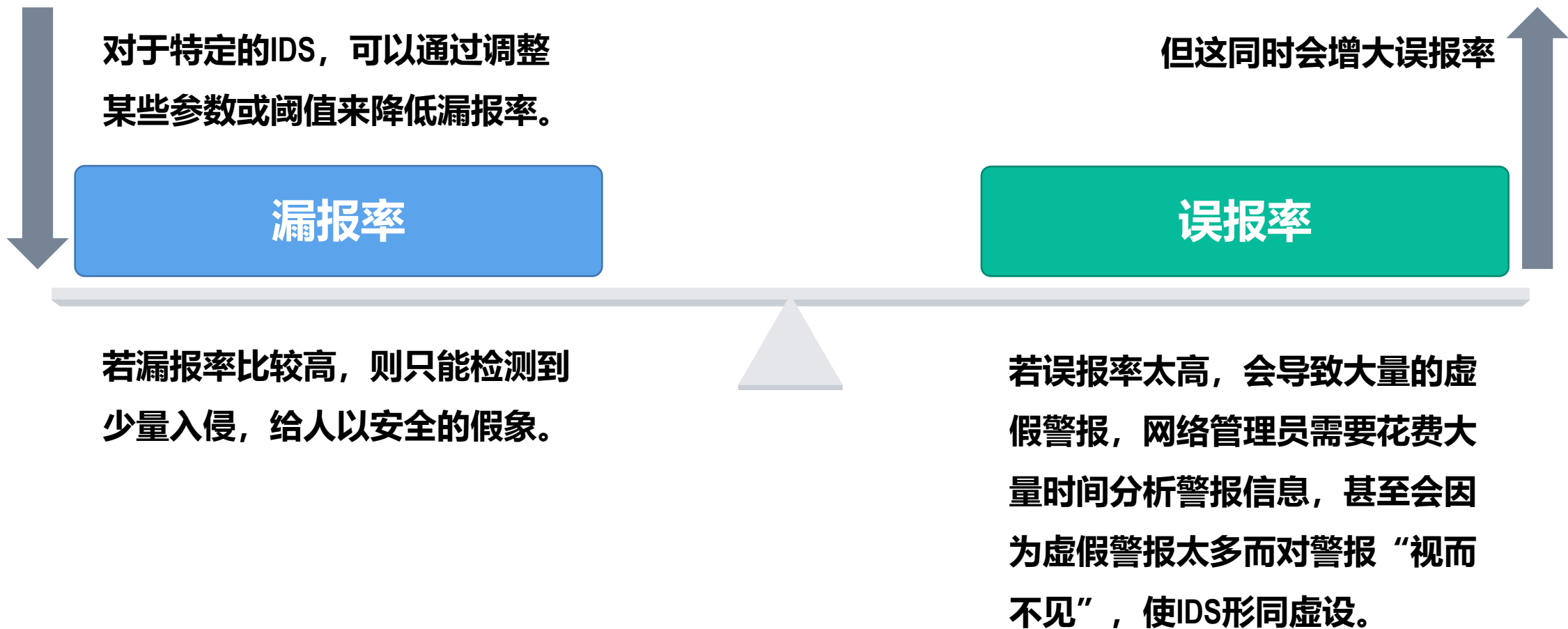
- 维护一个**已知各类攻击的标志性特征的数据库**。
- 检测到**与某种攻击特征匹配的分组或分组序列**时，就判断可能出现了某种入侵行为。
- 标志性特征必须具有**很好的区分度**。
- **标志性特征一般由网络安全专家提供**，由单位的网络管理员定制并将其加入到数据库中。

基于**异常**的入侵检测系统

- 通过观察正常运行的网络流量来**学习正常网络流量的统计特性和规律**。
- 检测到网络流量的某种统计规律不符合正常情况时，则判断可能发生了入侵行为。
- **区分正常流量和统计异常流量是非常困难的**。
- 现在很多研究致力于**将机器学习方法应用于入侵检测**，减少对网络安全专家的依赖。

02 入侵检测系统

衡量入侵检测系统IDS的重要依据



7.9 常见的网络攻击及其防范

01

网络扫描

02

网络监听

03

拒绝服务攻击

01 网络扫描

■ 网络扫描是**获取攻击目标信息**的一种重要技术。

☐ 攻击目标信息包括目的**主机的IP地址、操作系统、运行的程序及存在的漏洞**等。

☐ 在进行网络攻击之前，**对攻击目标的信息掌握得越全面和具体，就越能有效合理地制定出攻击策略和攻击方法，进而提高网络攻击的成功率。**

■ 网络扫描主要有四种类型：

主机发现

端口扫描

操作系统检测

漏洞扫描

01 网络扫描

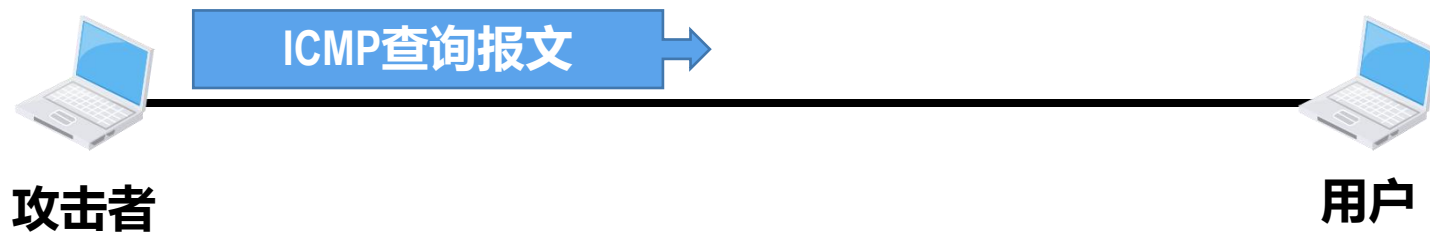
主机发现

端口扫描

操作系统检测

漏洞扫描

- 主机发现是指搜索要攻击的主机，这是对其进行攻击的前提。搜索要攻击的主机，实际上是要**确定该目标主机的IP地址**。
- 进行主机发现的主要方法是利用**网际控制报文协议ICMP**。



01 网络扫描

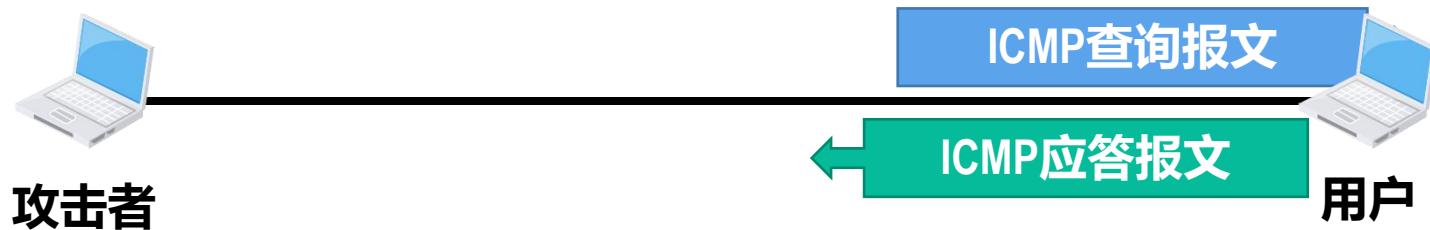
主机发现

端口扫描

操作系统检测

漏洞扫描

- 主机发现是指搜索要攻击的主机，这是对其进行攻击的前提。搜索要攻击的主机，实际上是要**确定该目标主机的IP地址**。
- 进行主机发现的主要方法是利用**网际控制报文协议ICMP**。



01 网络扫描

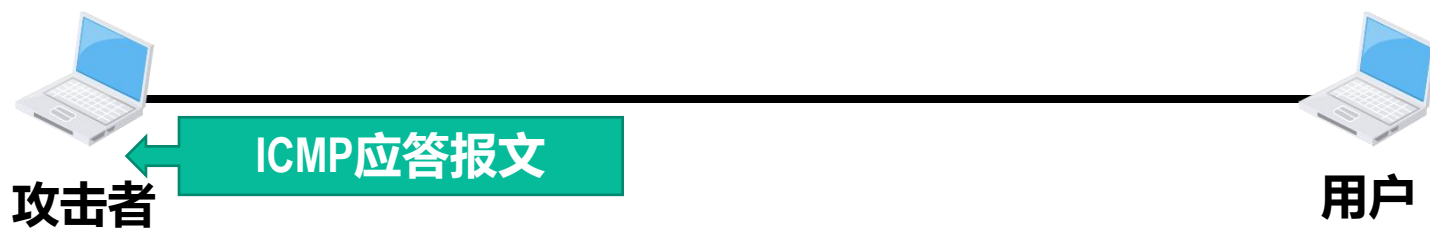
主机发现

端口扫描

操作系统检测

漏洞扫描

- 主机发现是指搜索要攻击的主机，这是对其进行攻击的前提。搜索要攻击的主机，实际上是要**确定该目标主机的IP地址**。
- 进行主机发现的主要方法是利用**网际控制报文协议ICMP**。



知道了目标主机正在运行

01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描

- 主机发现是指搜索要攻击的主机，这是对其进行攻击的前提。搜索要攻击的主机，实际上是要**确定该目标主机的IP地址**。
- 进行主机发现的主要方法是利用**网际控制报文协议ICMP**。

使用ping命令对某个IP地址范围内的所有IP地址进行连通性测试，来发现正在运行的目标主机。

攻击者

网络

可以配置主机（服务器或路由器）对ICMP查询报文不进行响应。

01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描

■ 主机发现是指搜索要攻击的主机，这是对其进行攻击的前提。搜索要攻击的主机，实际上是要**确定该目标主机的IP地址**。

■ 进行主机发现的主要方法是利用**网际控制报文协议ICMP**。

使用ping命令对某个IP地址范围内的所有IP地址进行连通性测试，来发现正在运行的目标主机。

配置防火墙不允许通过ICMP查询报文

攻击者

网络

01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描

正常访问湖南科技大学的官网



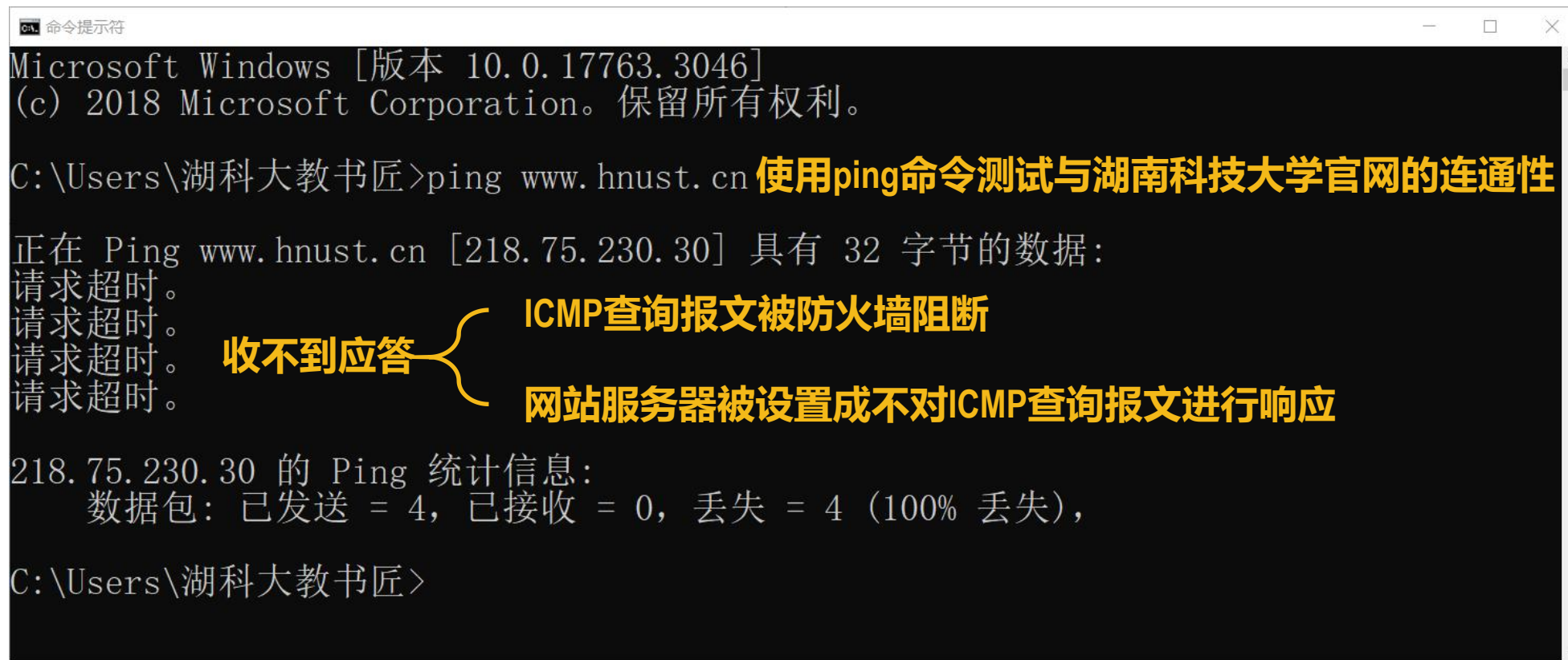
01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描



```
命令提示符
Microsoft Windows [版本 10.0.17763.3046]
(c) 2018 Microsoft Corporation。保留所有权利。

C:\Users\湖科大教书匠>ping www.hnust.cn 使用ping命令测试与湖南科技大学官网的连通性

正在 Ping www.hnust.cn [218.75.230.30] 具有 32 字节的数据:
请求超时。
请求超时。
请求超时。
请求超时。

218.75.230.30 的 Ping 统计信息:
    数据包: 已发送 = 4, 已接收 = 0, 丢失 = 4 (100% 丢失),

C:\Users\湖科大教书匠>
```

收不到应答

- ICMP查询报文被防火墙阻断
- 网站服务器被设置成不对ICMP查询报文进行响应

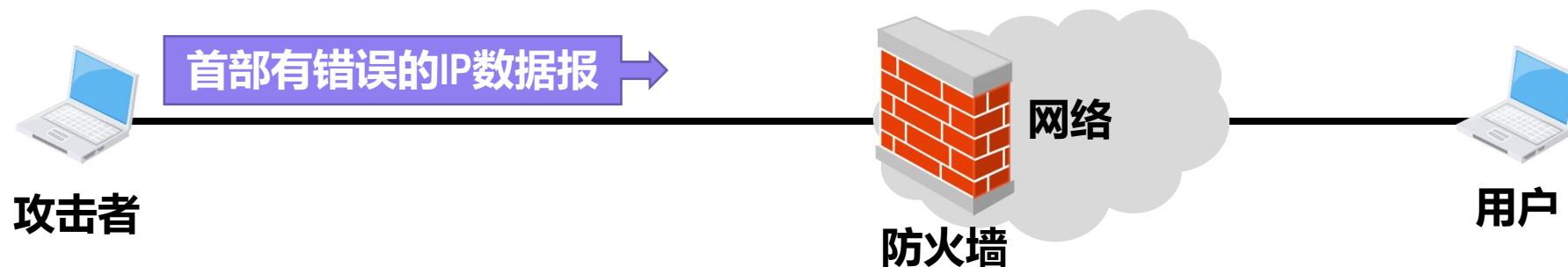
01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描



01 网络扫描

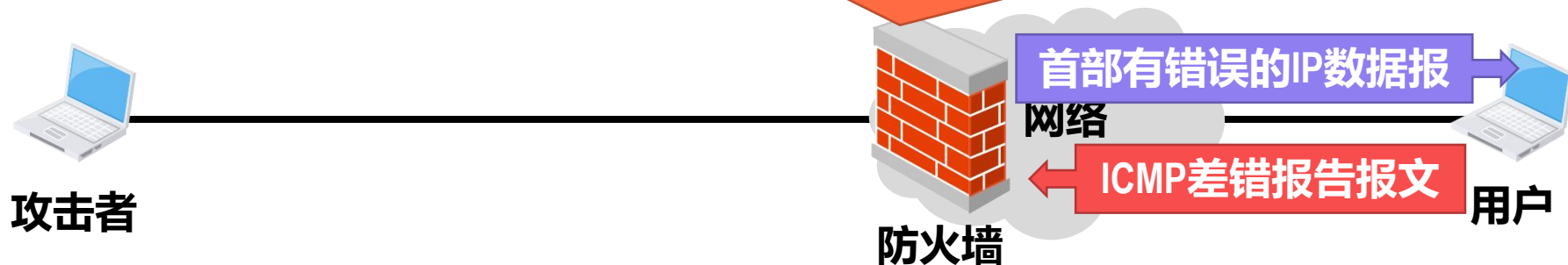
主机发现

端口扫描

操作系统检测

漏洞扫描

一般情况下，防火墙不会阻断ICMP差错报告报文，否则目标主机将失去进行ICMP差错报告的功能，而影响正常的网络通信。



01 网络扫描

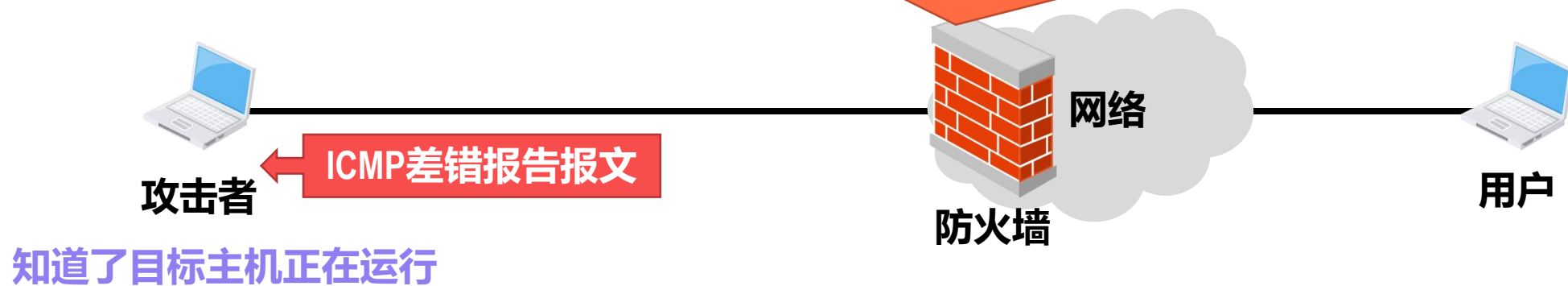
主机发现

端口扫描

操作系统检测

漏洞扫描

一般情况下，防火墙不会阻断ICMP差错报告报文，否则目标主机将失去进行ICMP差错报告的功能，而影响正常的网络通信。



01 网络扫描

主机发现

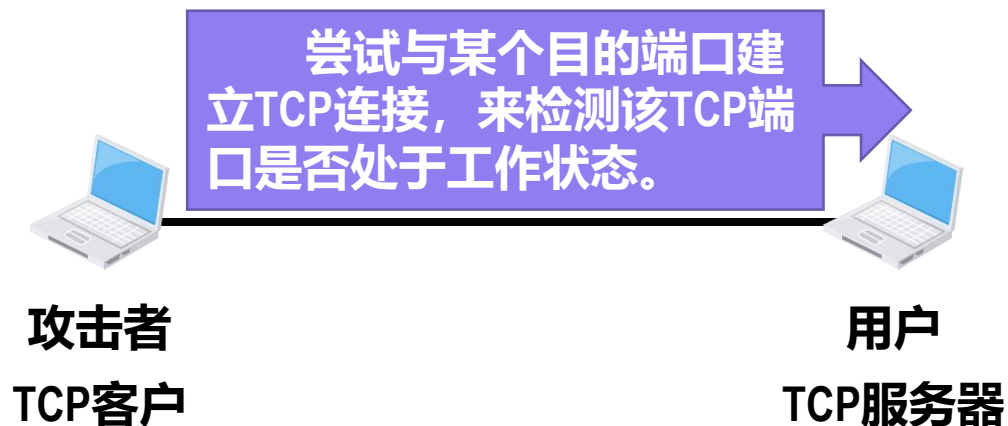
端口扫描

操作系统检测

漏洞扫描

■ 在进行主机发现确定了要攻击的目标主机后，攻击者可以进一步通过端口扫描来获取目标主机所有端口的工作状态，进而得出目标主机上开放了哪些网络服务。

应用层协议	DNS	DHCP	TFTP	SNMP	RIP	BGP	SMTP	FTP	HTTP	HTTPS
运输层端口号	53	67/68	69	161	520	179	25	21/20	80	443
运输层协议	UDP					TCP				



01 网络扫描

主机发现

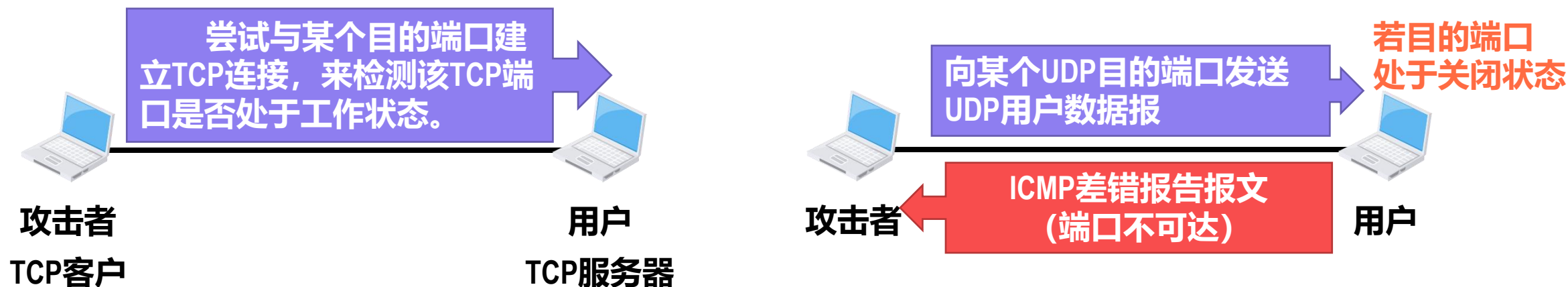
端口扫描

操作系统检测

漏洞扫描

■ 在进行主机发现确定了要攻击的目标主机后，攻击者可以进一步通过端口扫描来获取目标主机所有端口的工作状态，进而得出目标主机上开放了哪些网络服务。

应用层协议	DNS	DHCP	TFTP	SNMP	RIP	BGP	SMTP	FTP	HTTP	HTTPS
运输层端口号	53	67/68	69	161	520	179	25	21/20	80	443
运输层协议	UDP					TCP				



01 网络扫描

主机发现

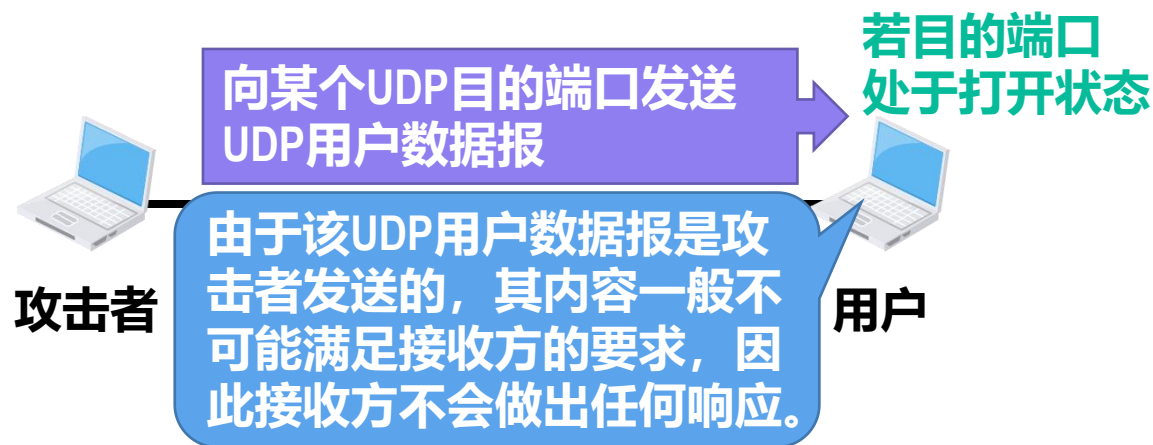
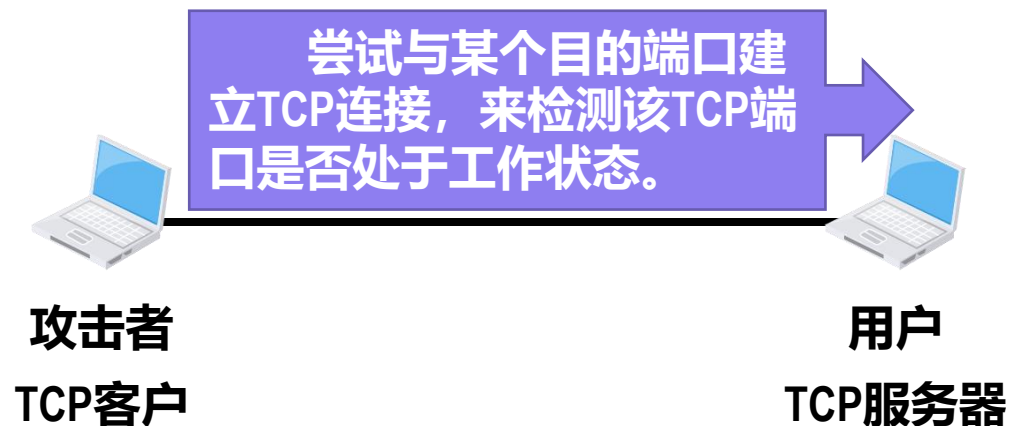
端口扫描

操作系统检测

漏洞扫描

在进行主机发现确定了要攻击的目标主机后，攻击者可以进一步通过端口扫描来获取目标主机所有端口的工作状态，进而得出目标主机上开放了哪些网络服务。

应用层协议	DNS	DHCP	TFTP	SNMP	RIP	BGP	SMTP	FTP	HTTP	HTTPS
运输层端口号	53	67/68	69	161	520	179	25	21/20	80	443
运输层协议	UDP					TCP				



01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描

不同的操作系统所存在的安全漏洞可能有很多不同。要利用这些安全漏洞进行攻击，首先必须检测远程目标主机所使用的操作系统类型，通常有三种方法：

获取操作系统旗标信息

- 在客户机与服务器建立连接的过程中，**服务器往往会返回各种独特的欢迎信息。**
- 攻击者可根据这些信息来推断出服务器的操作系统类型。

01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描

不同的操作系统所存在的安全漏洞可能有很多不同。要利用这些安全漏洞进行攻击，首先必须检测远程目标主机所使用的操作系统类型，通常有三种方法：

获取操作系统旗标信息

- 在客户机与服务器建立连接的过程中，服务器往往会返回各种独特的欢迎信息。
- 攻击者可根据这些信息来推断出服务器的操作系统类型。

获取主机端口状态信息

- 操作系统通常会默认开启一些常用的网络服务，这些服务会打开各自特定的端口进行网络监听。
- 攻击者可对目标主机进行端口扫描，根据端口扫描结果来推断目标主机的操作系统类型。

01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描

不同的操作系统所存在的安全漏洞可能有很多不同。要利用这些安全漏洞进行攻击，首先必须检测远程目标主机所使用的操作系统类型，通常有三种方法：

获取操作系统旗标信息

- 在客户机与服务器建立连接的过程中，服务器往往会返回各种独特的欢迎信息。
- 攻击者可根据这些信息来推断出服务器的操作系统类型。

获取主机端口状态信息

- 操作系统通常会默认开启一些常用的网络服务，这些服务会打开各自特定的端口进行网络监听。
- 攻击者可对目标主机进行端口扫描，根据端口扫描结果来推断目标主机的操作系统类型。

获取TCP/IP协议栈指纹

- 尽管RFC文档严格规定了各种协议的三要素（语法、语义和同步），但并没有规定各种协议的具体实现。
- 同一个协议在不同操作系统中的实现细节可能会有所不同，攻击者可据此推断目标主机的操作系统类型。

01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描

不同的操作系统所存在的安全漏洞可能有很多不同。要利用这些安全漏洞进行攻击，首先必须检测远程目标主机所使用的操作系统类型，通常有三种方法：

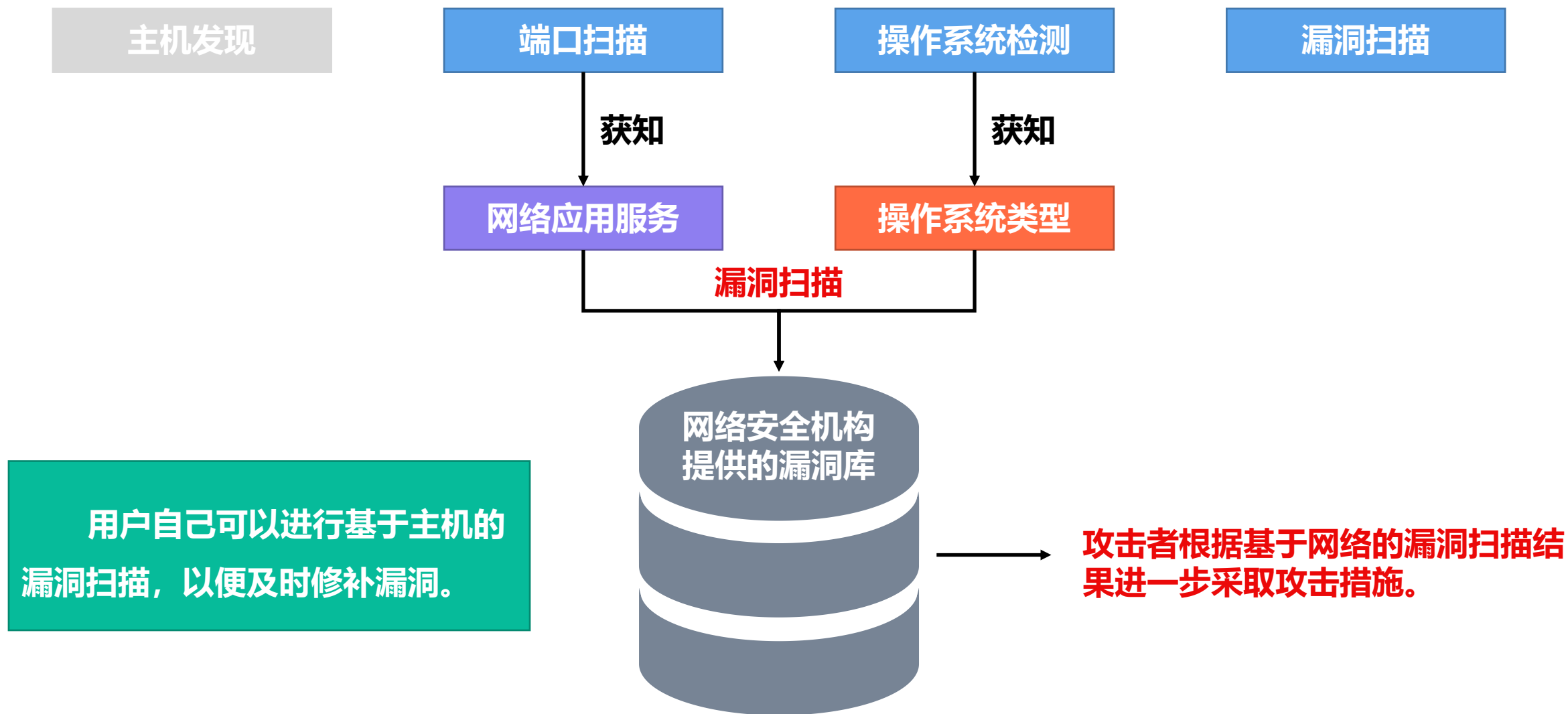
操作系统	默认TTL值
Linux (2.4 kernel)	255
Windows 10	128
MacOS X (10.5.6)	64

操作系统	TCP窗口默认初始值
Windows	8KB
Solaris	52KB
FreeBSD	发送=32KB，接收=56KB

获取TCP/IP协议栈指纹

- 尽管RFC文档严格规定了各种协议的三要素（语法、语义和同步），但并没有规定各种协议的具体实现。
- 同一个协议在不同操作系统中的实现细节可能会有所不同，攻击者可据此推断目标主机的操作系统类型。

01 网络扫描



01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描

防范上述各种类型的网络扫描，可采取以下措施

- 仅打开确实需要使用的端口，关闭闲置和危险端口。
- 限制因特网（不可信网络）中的主机主动与内部网络（可信网络）中的主机进行通信。
- 设置防火墙，根据安全要求设置分组过滤策略（例如过滤不必要的ICMP报文）。
- 使用入侵检测系统IDS及时发现网络扫描行为和攻击者IP地址，配置防火墙对来自该地址的分组进行阻断。
 - 网络扫描的行为特征是比较明显的，例如在短时间内对某一IP地址范围内的每个地址和端口发起连接等。
 - 目前，大部分防火墙都具有识别简单的网络扫描行为的功能。
 - 然而，很多攻击者也在研究如何隐蔽自己的网络攻击行为。例如利用虚假源地址、减缓扫描速度、动态调整扫描顺序、分布式扫描等。

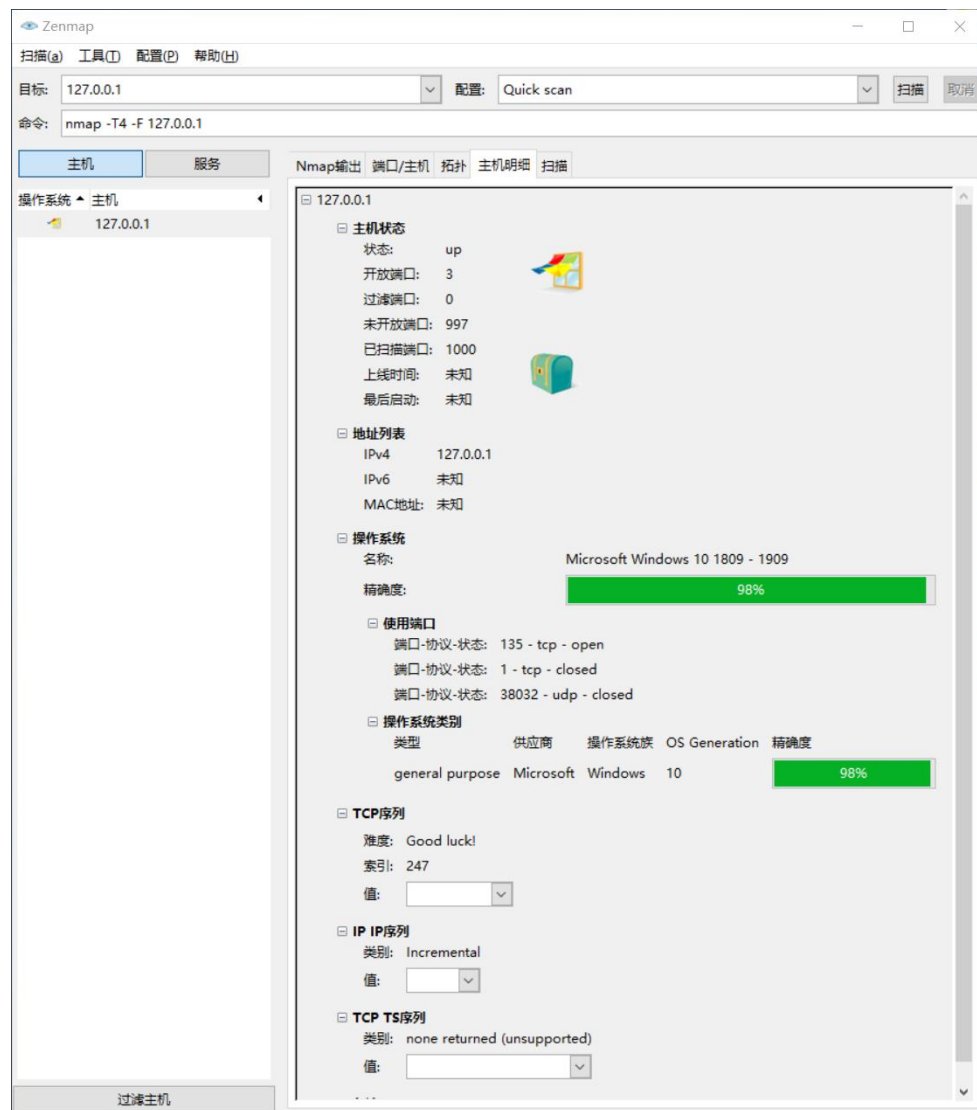
01 网络扫描

主机发现

端口扫描

操作系统检测

漏洞扫描



网络扫描工具
(Nmap、SuperScan、Queso等)

网络安全的“双刃剑”

02 网络监听

网络中传输的数据大部分都是明文形式。如果攻击者对网络进行监听并截获了包含有大量明文信息的一系列分组，则可从这些分组中直接分析出账号、密码等敏感信息。

常见的网络监听类型有：

分组嗅探器

交换机毒化攻击

ARP欺骗

02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

■ 分组嗅探器（Packet Sniffer）是一种网络监听工具软件，它运行在网络中的某台主机上，**被动接收所有出入该主机的网络适配器（网卡）的数据链路层协议数据单元（即帧）。**

02 网络监听

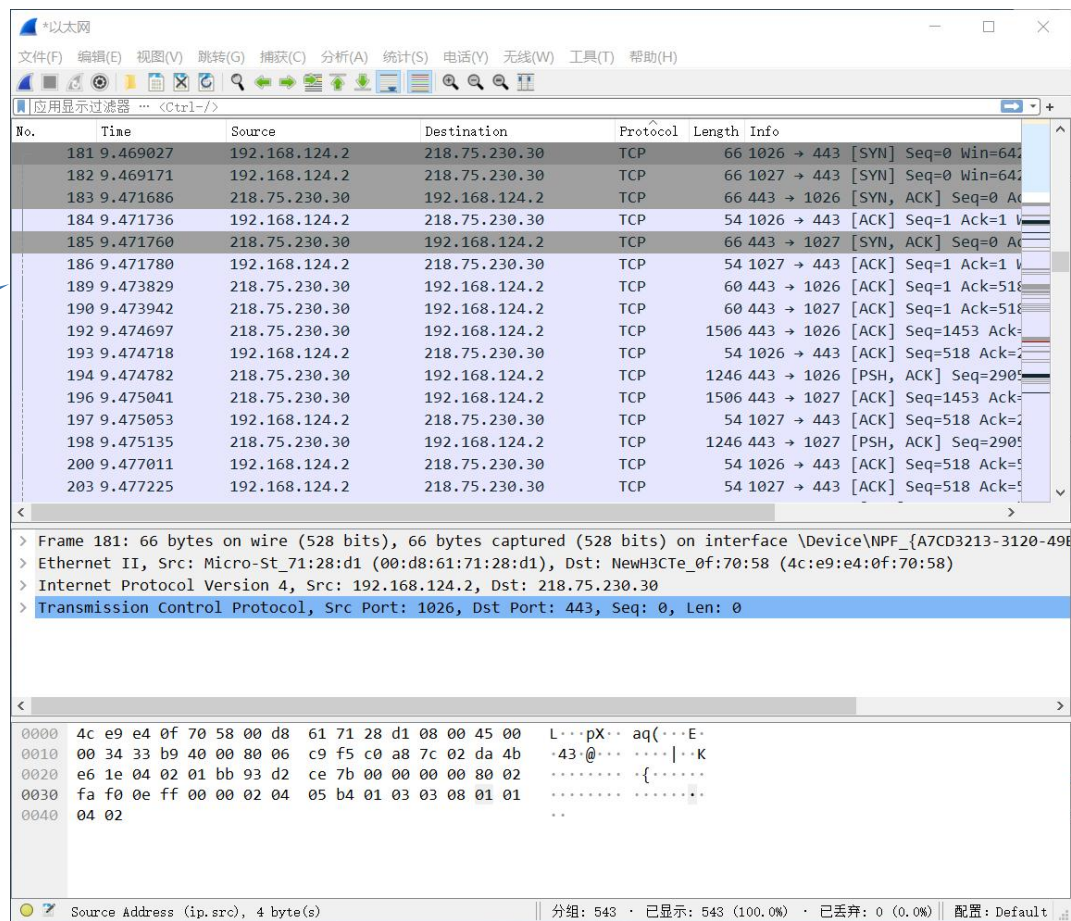
分组嗅探器

交换机毒化攻击

ARP欺骗

分组嗅探器（Packet Sniffer）是一种网络监听工具软件，它运行在网络中的某台主机上，被动接收所有出入该主机的网络适配器（网卡）的数据链路层协议数据单元（即帧）。

某个内网主机（IP地址为192.168.124.2）访问湖南科技大学官网（IP地址为218.75.230.30）的过程中，主机中的分组嗅探器软件Wireshark捕获到的出入该主机网络适配器的一系列相关分组。



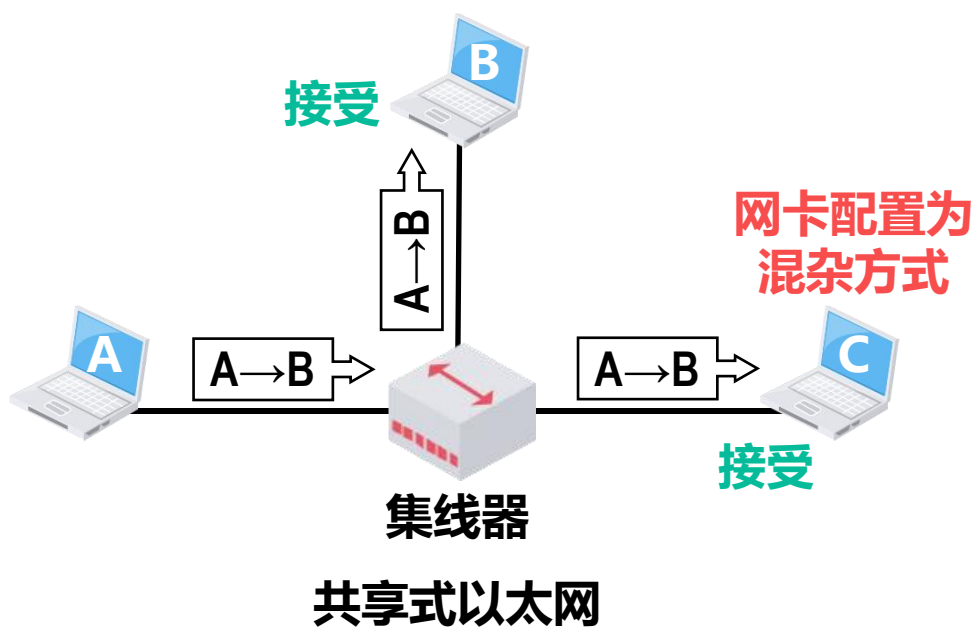
02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

- 分组嗅探器（Packet Sniffer）是一种网络监听工具软件，它运行在网络中的某台主机上，**被动接收所有出入该主机的网络适配器（网卡）的数据链路层协议数据单元（即帧）**。
- 如果将网络适配器配置为**混杂方式**，网络适配器就会接收所有进入自己接口的MAC帧，而不管这些帧的目的MAC地址是否指向该网络适配器。



类似



802.11无线局域网

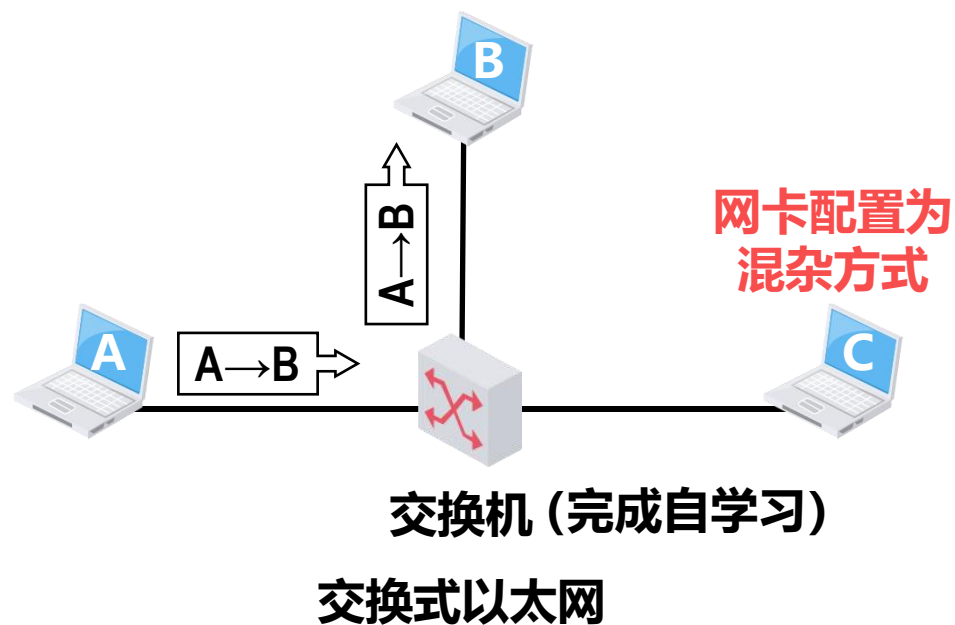
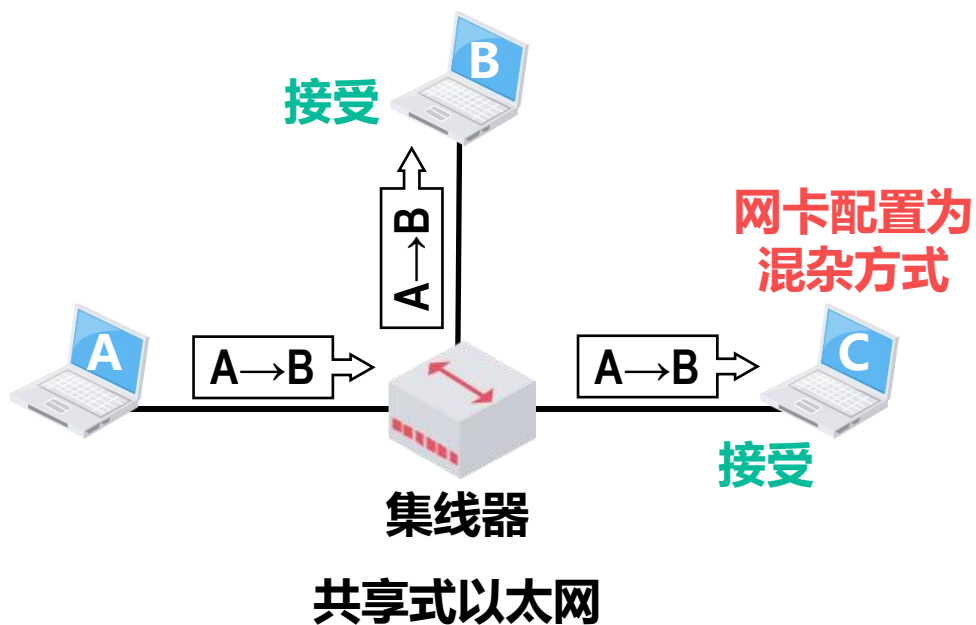
02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

- 分组嗅探器 (Packet Sniffer) 是一种网络监听工具软件, 它运行在网络中的某台主机上, **被动接收所有出入该主机的网络适配器 (网卡) 的数据链路层协议数据单元 (即帧)**。
- 如果将网络适配器配置为**混杂方式**, 网络适配器就会接收所有进入自己接口的MAC帧, 而不管这些帧的目的MAC地址是否指向该网络适配器。

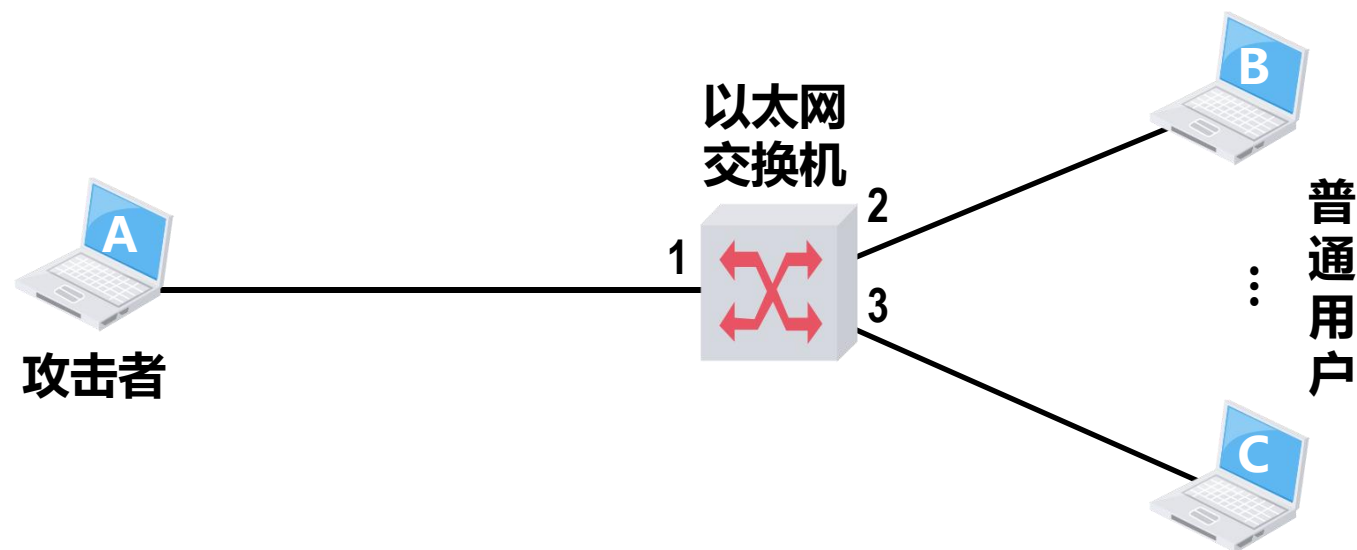


02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

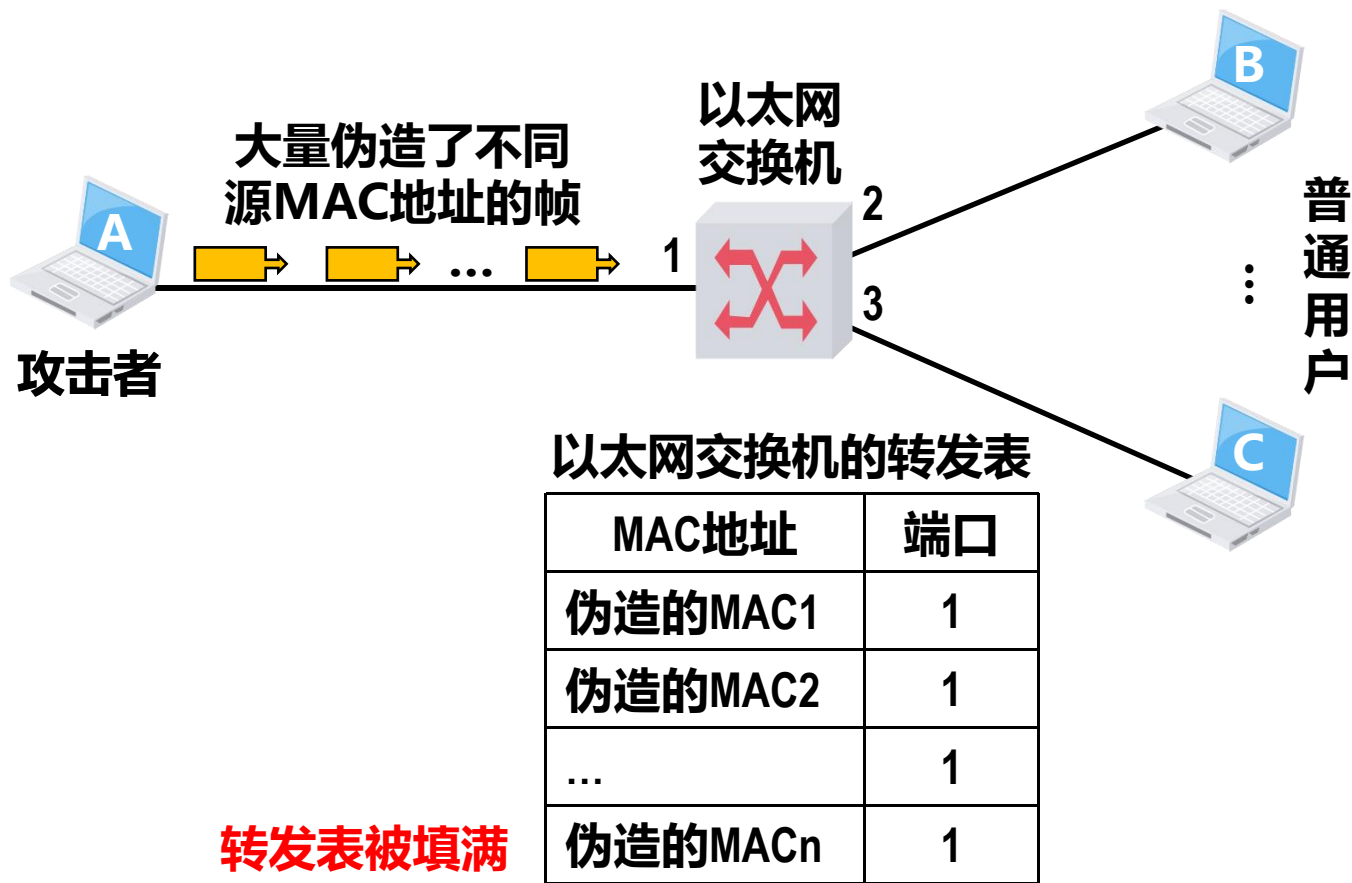


02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

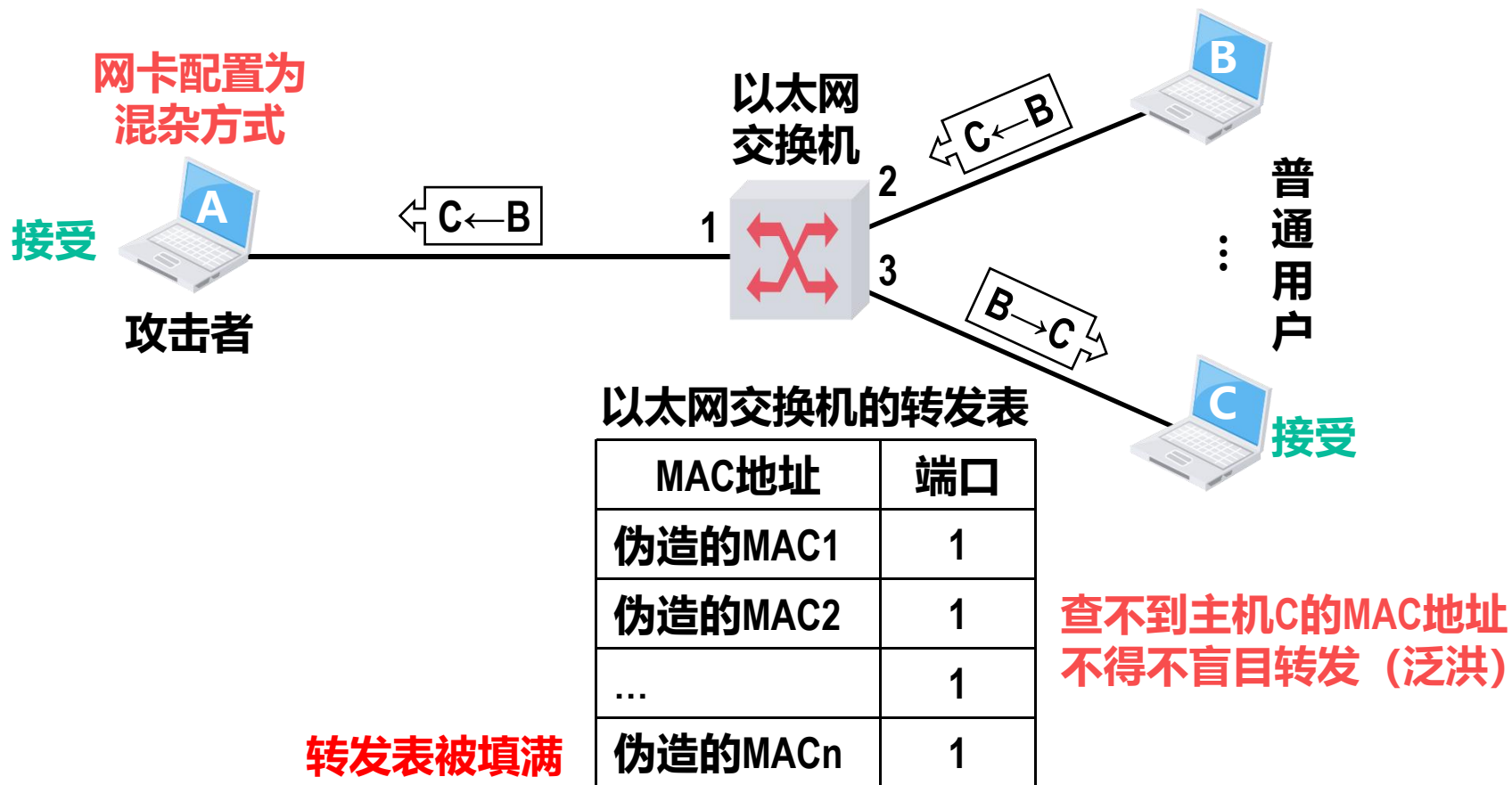


02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

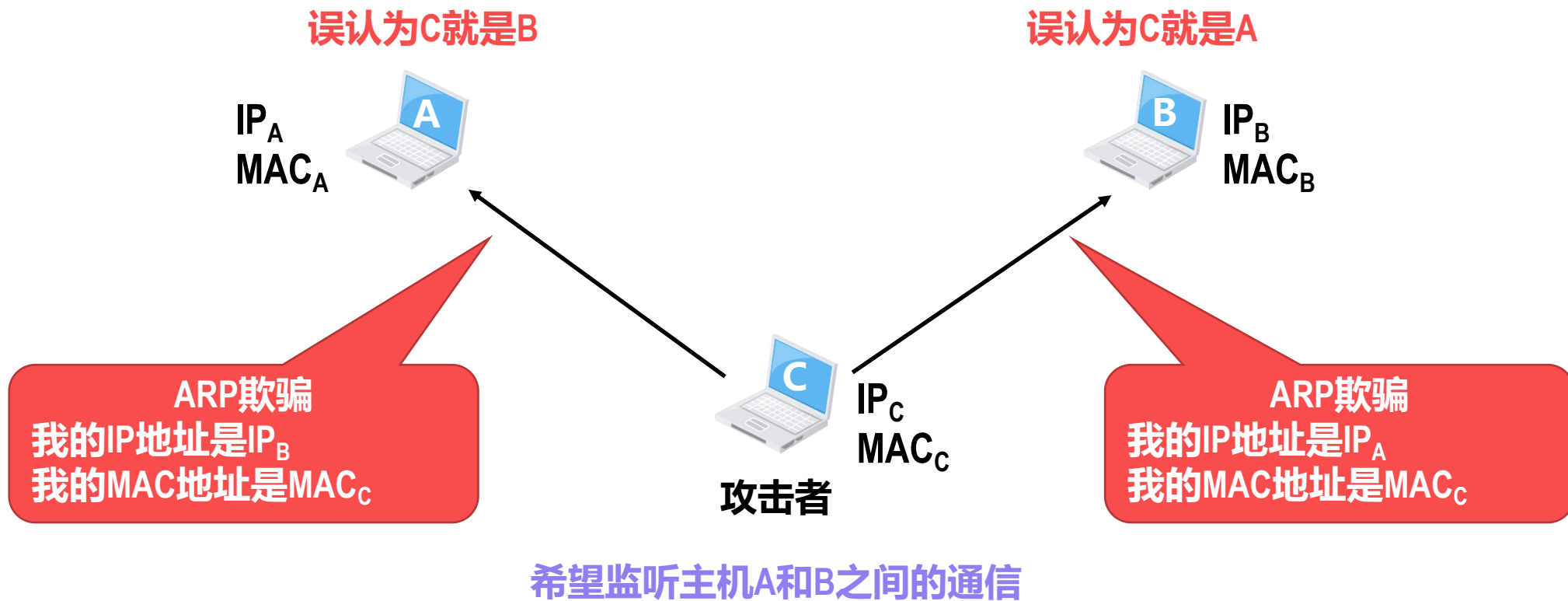


02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

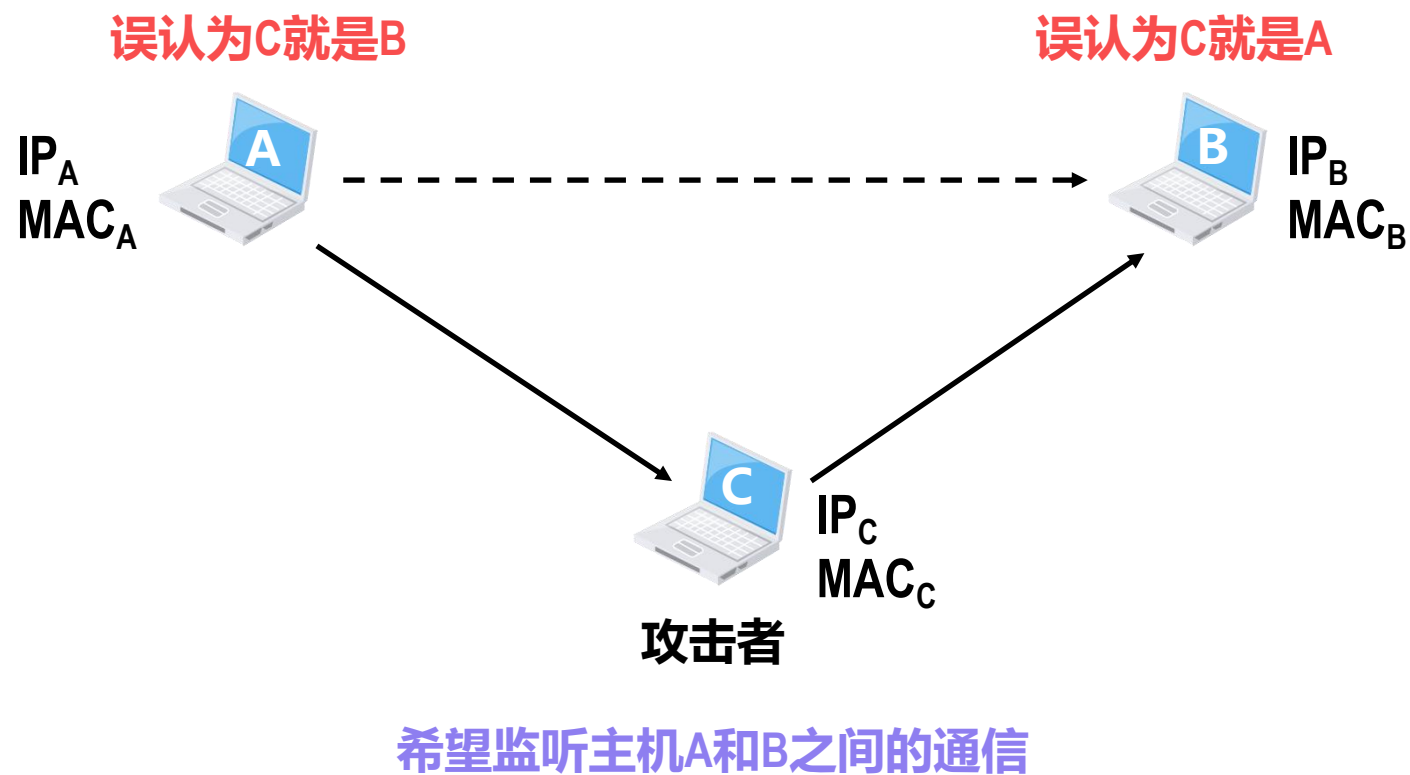


02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

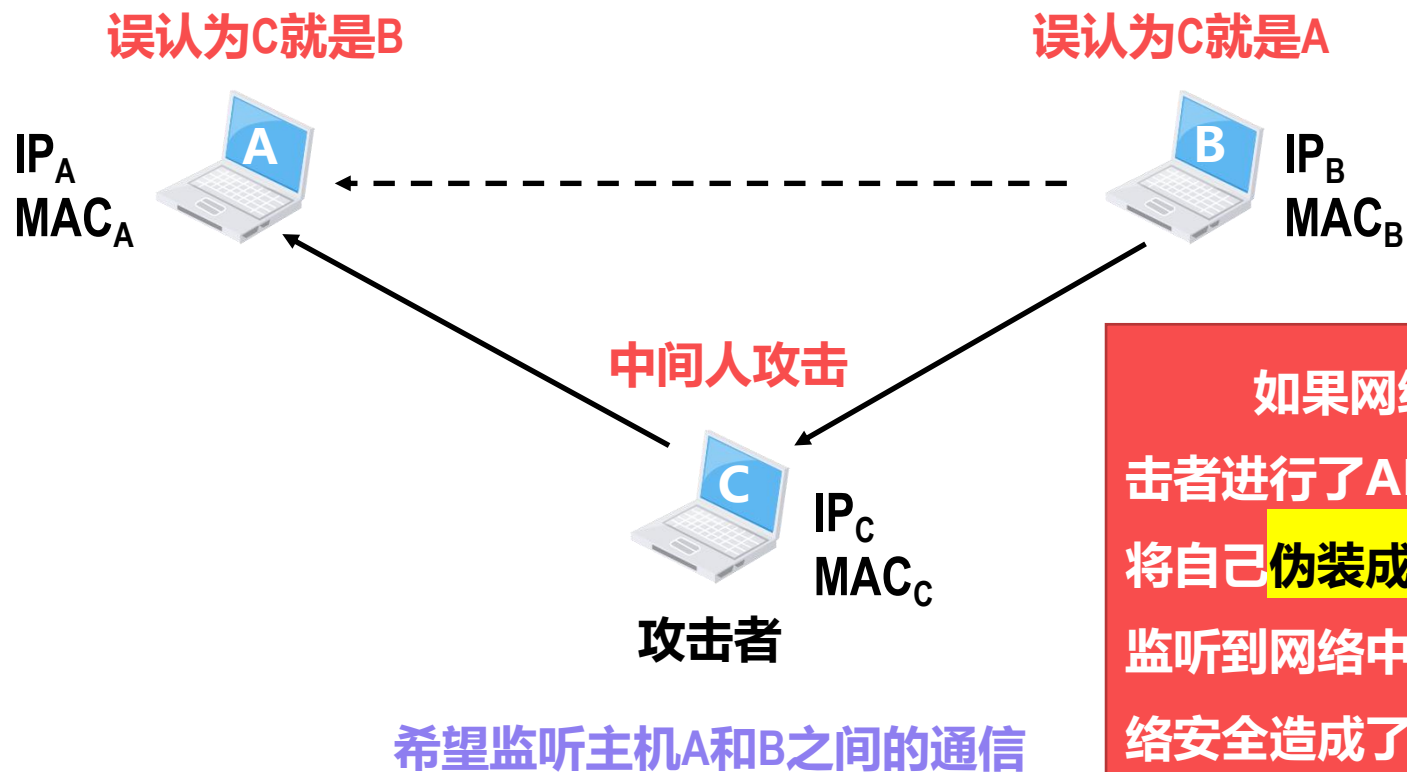


02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗



如果网络中的所有主机都被攻击者进行了ARP欺骗，则攻击者就将自己伪装成了路由器，从而可以监听到网络中的所有通信，这对网络安全造成了极大的危害。

02 网络监听

分组嗅探器

交换机毒化攻击

ARP欺骗

防范上述各种类型的网络监听，可采取以下措施

- 使用交换机替代集线器，这不但可以提高网络性能，还能使攻击者在交换机环境中更难实施监听。
- 禁用交换机的自学习功能，将IP地址、MAC地址与交换机的接口进行静态绑定，这样可以限制非法主机的接入，使攻击者无法实施交换机毒化攻击，也使ARP欺骗难以实施。
- 对于ARP欺骗，主机或路由器可以仅使用静态ARP表，而不再依据ARP请求报文或响应报文动态更新。
- 划分VLAN可以限制攻击者的监听范围，因为分组嗅探器只能在单个局域网范围内进行。
- 防范网络监听的最有效的方法是进行数据加密和实体鉴别技术。

03 拒绝服务攻击

■ 拒绝服务DoS攻击是**最容易实现却又最难防范**的攻击手段。

■ DoS攻击类型有：

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

■ 主要利用**网络协议漏洞**或**操作系统漏洞**。攻击者向目标系统发送一些特殊分组，使目标系统在处理这些分组时出现异常，甚至崩溃。这种攻击又称为**剧毒包**或**杀手包（Killer Packet）攻击**。

“死亡之ping”攻击

超长的ICMP回送请求报文

攻击者



用户

03 拒绝服务攻击

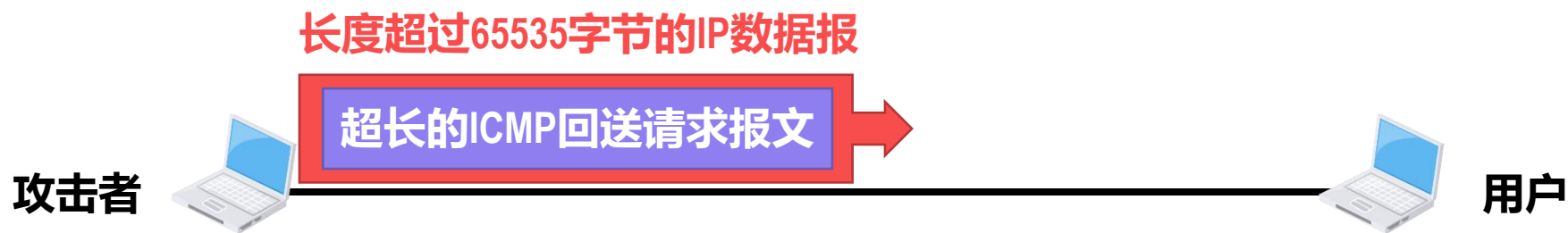
基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

■ 主要利用**网络协议漏洞**或**操作系统漏洞**。攻击者向目标系统发送一些特殊分组，使目标系统在处理这些分组时出现异常，甚至崩溃。这种攻击又称为**剧毒包**或**杀手包**（Killer Packet）攻击。

“死亡之ping”攻击



03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

主要利用**网络协议漏洞**或**操作系统漏洞**。攻击者向目标系统发送一些特殊分组，使目标系统在处理这些分组时出现异常，甚至崩溃。这种攻击又称为**剧毒包**或**杀手包**（Killer Packet）攻击。

“死亡之ping”攻击



03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

■ 这种攻击是DoS攻击中采用**最多的一种攻击**。攻击者通过**向目标系统发送大量的分组**，从而**耗尽目标系统的资源**，致使目标系统崩溃而**无法向正常用户提供服务**。

03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

“TCP SYN洪泛” 攻击

攻击者
TCP客户

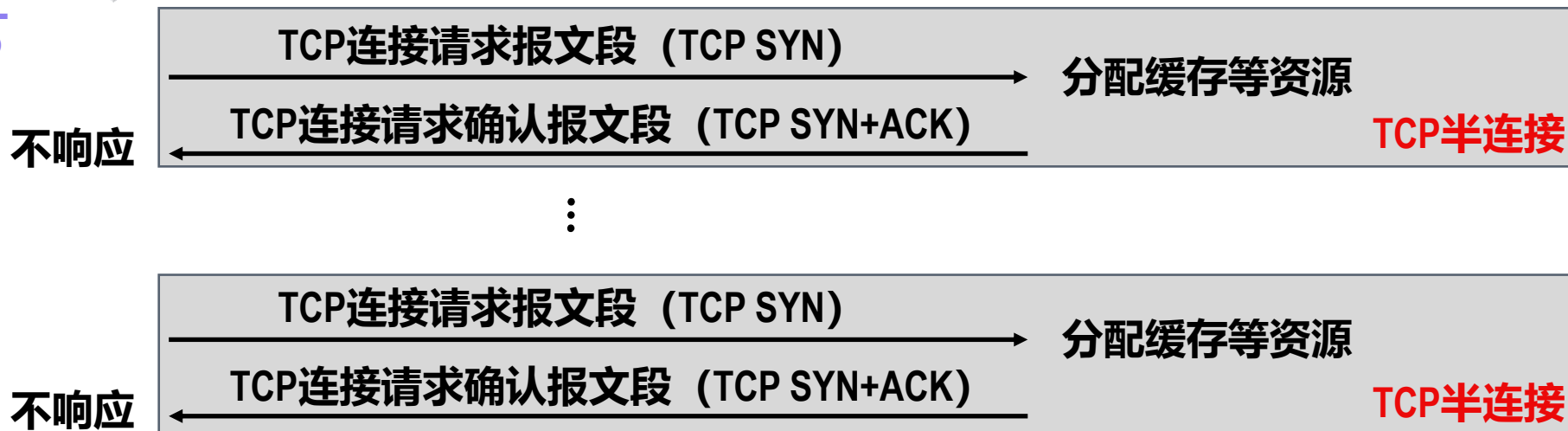
伪造大量不同的IP地址，并以这些IP地址发送大量TCP连接请求



TCP服务器



当半连接的数量超过了系统允许的上限时，系统就不会再接受任何TCP连接请求，这将导致TCP服务器无法为正常客户提供服务。



03 拒绝服务攻击

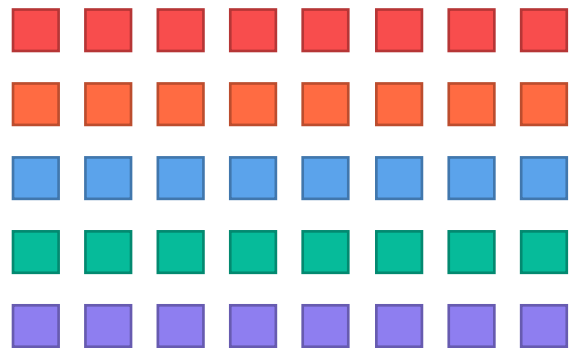
基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

与“TCP SYN洪泛”攻击思想类似的另一种攻击方法

大量不同IP数据报的分片



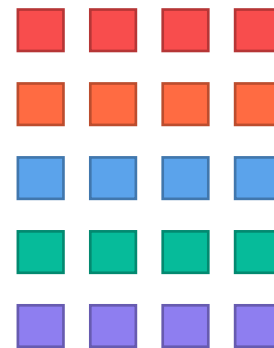
⋮

攻击者



不会发送完构成任何一个IP数据报的所有分片

用户

一直缓存已收到的部分分片，
这将耗费目标主机越来越多的
系统缓存，直到系统崩溃。

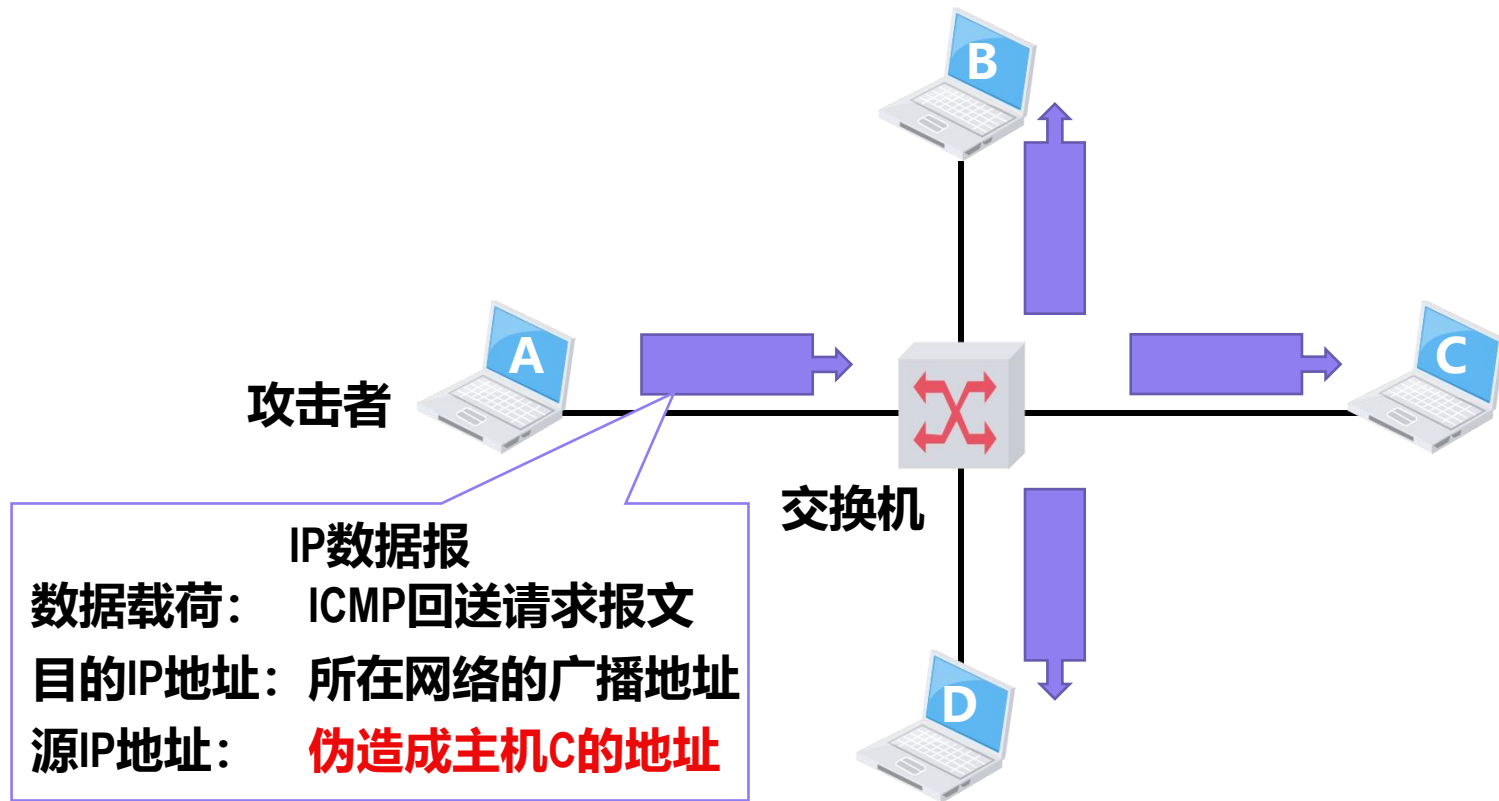
03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

反射攻击（例如Smurf攻击）



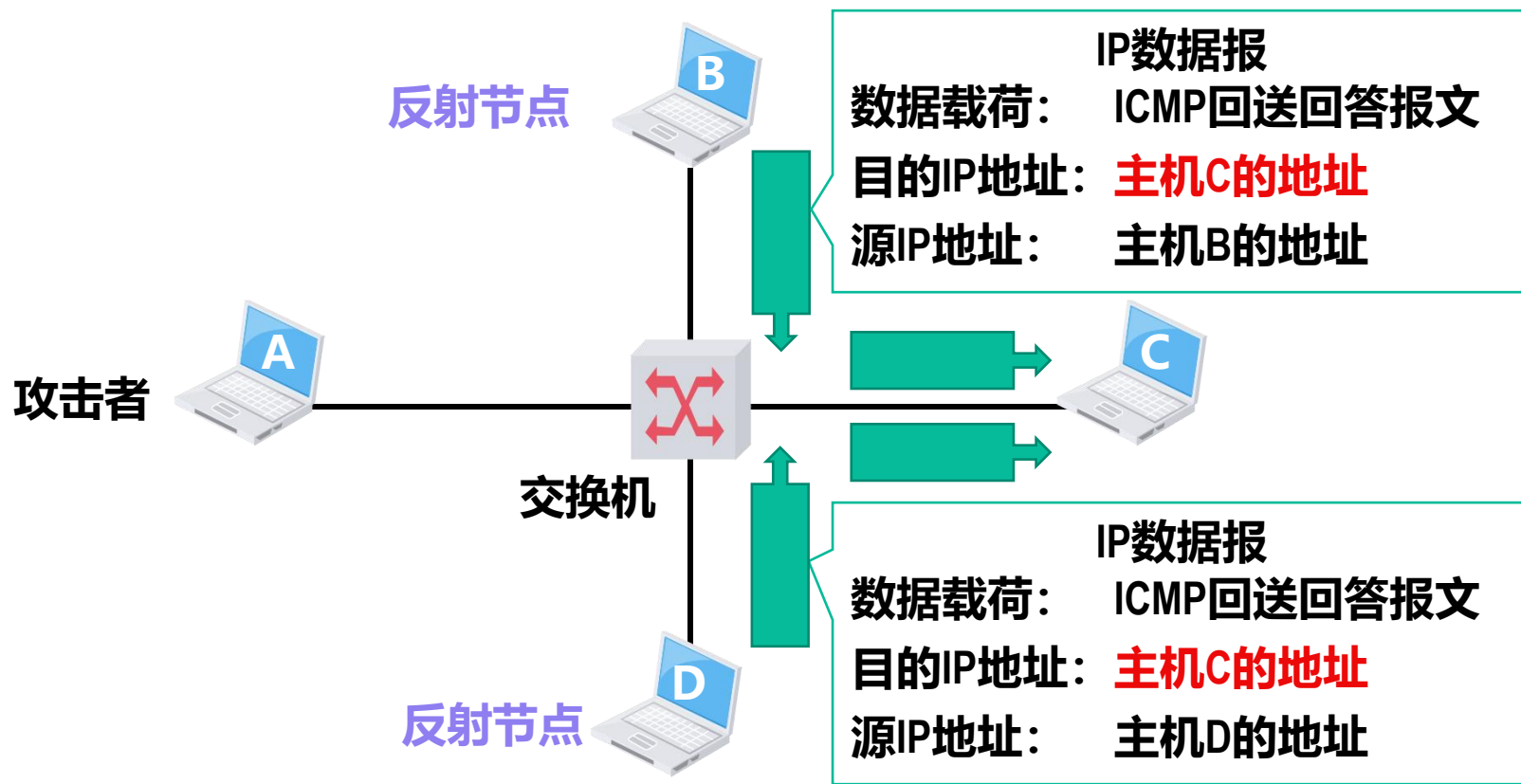
03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

反射攻击（例如Smurf攻击）



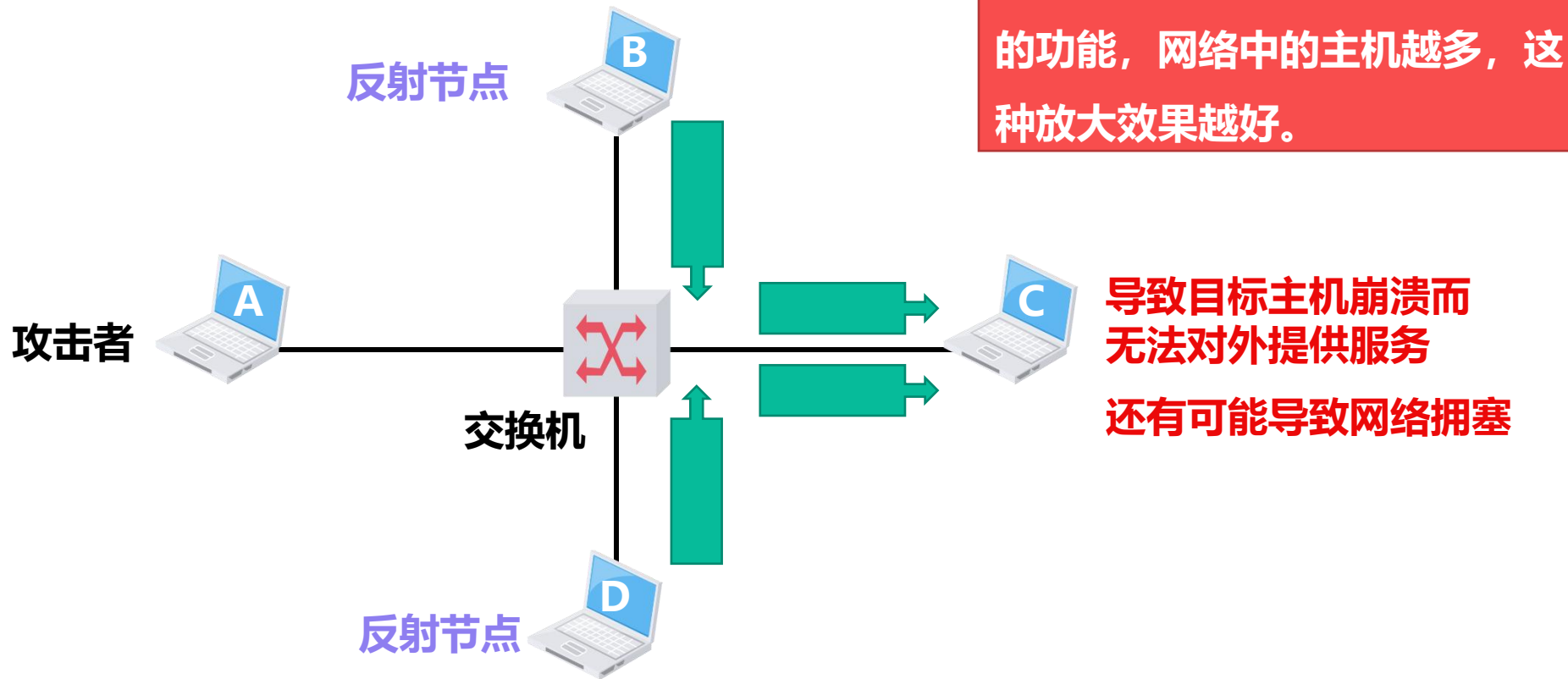
03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

反射攻击（例如Smurf攻击）



03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

攻击者向目标主机
发送大量的分组

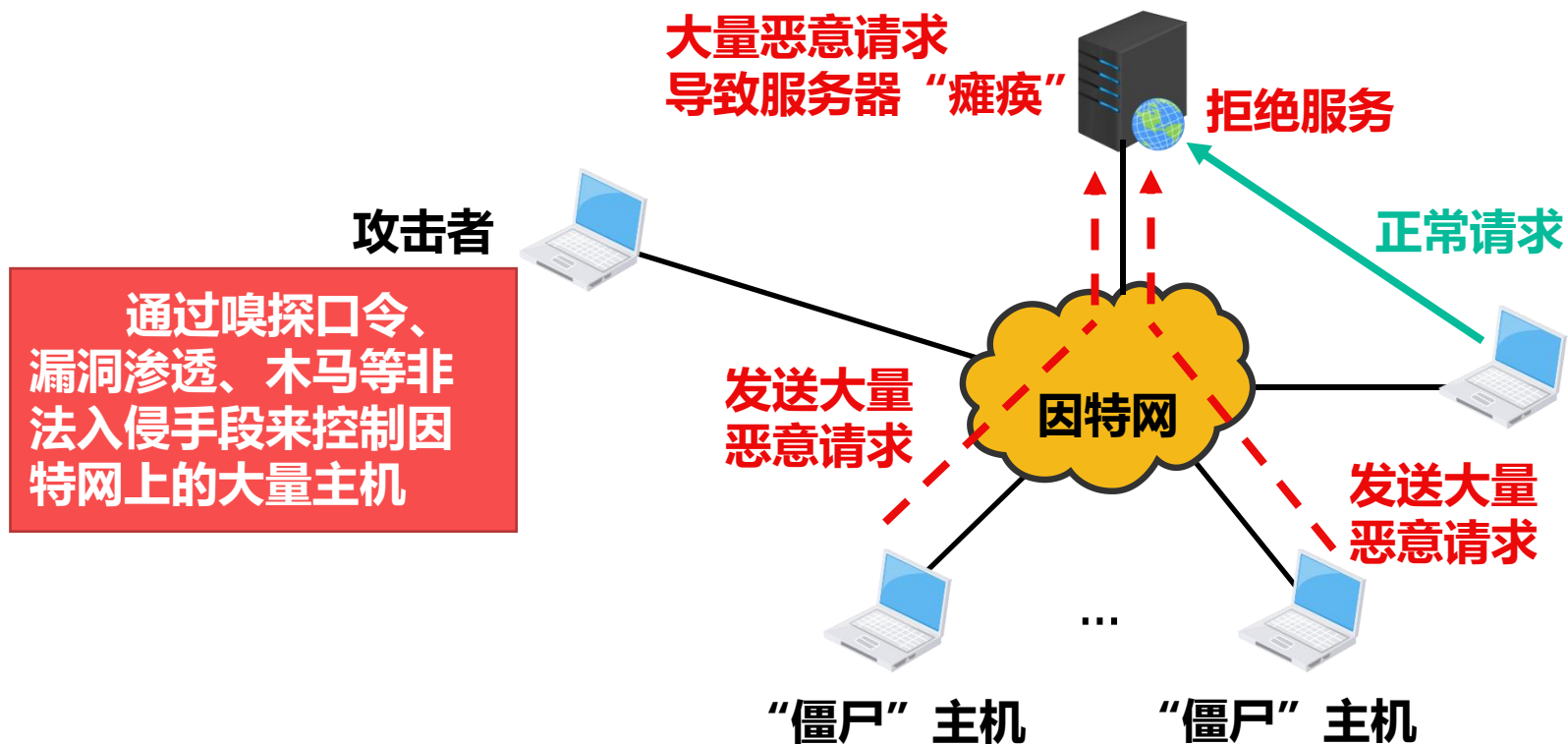
仅靠一个攻击源
很难达到效果

03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击



03 拒绝服务攻击

基于漏洞的DoS攻击

基于资源消耗的DoS攻击

分布式DoS攻击

防范上述各种类型的拒绝服务攻击，可采取以下措施

- **利用防火墙对恶意分组进行过滤**，例如过滤掉所有ICMP回送请求报文可以防范Smurf攻击。然而，对于像“TCP SYN洪泛”这类攻击，一般很难区分哪些TCP连接请求报文是恶意的。
- **使用支持源端过滤的路由器**，尽量减少IP地址伪造的现象。如果要通过源端过滤来防范DoS攻击，则必须使因特网上所有的路由器都具有源端过滤的功能。然而，目前源端过滤并不是路由器的强制功能，支持源端过滤的路由器还是少数。
- **追溯DoS攻击源**。路由器对通过自己的IP数据报的首部进行标记，通过该标记可追溯到DoS攻击源。这个过程通常很慢，并且需要人工干预，因此目前主要用于事后追查以及采取相应的法律手段提供依据。
- **进行DoS攻击检测**，通过分析分组首部特征和流量特征来检测正在发生的DoS攻击并发出警报。

上述措施并不能彻底防范DoS攻击，DoS攻击是目前最容易实现却又最难防范的攻击手段。